

Processo: 206.972-5/22

Origem/Jurisdicionado: PREFEITURA RIO DAS FLORES e outros

Natureza: RELATÓRIO DE AUDITORIA GOVERNAMENTAL – AUDITORIA DE CONFORMIDADE – ORDINÁRIA

Interessado: COORDENADORIA SETORIAL DE AUDITORIA EM POLÍTICAS DE TECNOLOGIA DA INFORMAÇÃO

Observação: Verificar a conformidade à Lei 13.709/2018, conhecida como Lei Geral de Proteção aos Dados - LGPD, das prefeituras municipais jurisdicionadas.

RELATÓRIO DE AUDITORIA GOVERNAMENTAL

DADOS DA FISCALIZAÇÃO

Número da fiscalização: 184/2022

Modalidade: AUDITORIA DE CONFORMIDADE

Forma de autorização: ORDINÁRIA

Ato originário: Processo TCE-RJ nº 302.295-8/21

Jurisdicionado: PMRF - PREFEITURA RIO DAS FLORES; PMRC - PREFEITURA RIO CLARO; PMRB - PREFEITURA RIO BONITO; PMR - PREFEITURA RESENDE; PMQ - PREFEITURA QUISSAMA; PMQ - PREFEITURA QUEIMADOS; PMQ - PREFEITURA QUATIS; PMPR - PREFEITURA PORTO REAL; PMP - PREFEITURA PORCIUNCULA; PMP - PREFEITURA PINHEIRAL; PMRO - PREFEITURA RIO DAS OSTRAS; PMP - PREFEITURA PETROPOLIS; PMPA - PREFEITURA PATY DO ALFERES; PMP - PREFEITURA PARATY; PMPS - PREFEITURA PARAIBA DO SUL; PMP - PREFEITURA PARACAMBI; PMNI - PREFEITURA NOVA IGUAÇU; PMNF - PREFEITURA NOVA FRIBURGO; PMN - PREFEITURA NITEROI; PMP - PREFEITURA PIRAI; PMSMM - PREFEITURA SANTA MARIA MADALENA; PMSF - PREFEITURA SAO FIDÉLIS; PMN - PREFEITURA NATIVIDADE; PMVR - PREFEITURA VOLTA REDONDA; PMV - PREFEITURA VASSOURAS; PMVS - PREFEITURA VARRE-SAI; PMV - PREFEITURA VALENÇA; PMTR - PREFEITURA TRES RIOS; PMTM - PREFEITURA TRAJANO DE MORAES; PMT - PREFEITURA TERESOPOLIS; PMT - PREFEITURA TANGUA; PMSG - PREFEITURA SÃO GONÇALO; PMSAP - PREFEITURA SANTO ANTONIO DE PADUA; PMSJ - PREFEITURA SILVA JARDIM; PMS - PREFEITURA SAQUAREMA; PMS - PREFEITURA SAPUCAIA; PMSSA - PREFEITURA SAO SEBASTIAO DO ALTO; PMSPA - PREFEITURA SAO PEDRO DA ALDEIA; PMSJVRP - PREFEITURA SAO JOSE DO VALE DO RIO PRETO; PMSJU - PREFEITURA SAO JOSE DE UBA; PMSJM - PREFEITURA SAO JOAO DE MERITI; PMSJB - PREFEITURA SAO JOAO DA BARRA; PMSFI - PREFEITURA SAO FRANCISCO DE ITABAPOANA; PMS - PREFEITURA SEROPEDICA; PMS - PREFEITURA MUN SUMIDOURO; PMN - PREFEITURA NILOPOLIS; PMMP - PREFEITURA MIGUEL PEREIRA; PMM - PREFEITURA MIRACEMA; PMC - PREFEITURA CARMO; PMCM - PREFEITURA CARDOSO MOREIRA; PMC - PREFEITURA CARAPEBUS; PMC - PREFEITURA CANTAGALO; PMCG - PREFEITURA CAMPOS DOS GOYTACAZES; PMC - PREFEITURA CAMBUCI; PMCM - PREFEITURA CACHOEIRAS DE MACACU; PMCF - PREFEITURA CABO FRIO; PMCLG - PREFEITURA COMENDADOR

LEVY GASPARIAN; PMBJI - PREFEITURA BOM JESUS DO ITABAPOANA; PMBR - PREFEITURA BELFORD ROXO; PMBM - PREFEITURA BARRA MANSA; PMBP - PREFEITURA BARRA DO PIRAI; PMAC - PREFEITURA ARRAIAL DO CABO; PMAB - PREFEITURA ARMAÇÃO DOS BÚZIOS; PMA - PREFEITURA AREAL; PMA - PREFEITURA ARARUAMA; PMA - PREFEITURA APERIBE; PMAR - PREFEITURA ANGRA DOS REIS; PMBJ - PREFEITURA BOM JARDIM; PMCM - PREFEITURA CONCEIÇÃO DE MACABU; PMCA - PREFEITURA CASIMIRO DE ABREU; PMDB - PREFEITURA DUAS BARRAS; PMM - PREFEITURA MESQUITA; PMM - PREFEITURA MENDES; PMM - PREFEITURA MARICA; PMM - PREFEITURA MANGARATIBA; PMM - PREFEITURA MAGE; PMM - PREFEITURA MACUCO; PMC - PREFEITURA CORDEIRO; PMLM - PREFEITURA LAJE DO MURIAE; PMJ - PREFEITURA JAPERI; PMM - PREFEITURA MACAE; PMI - PREFEITURA ITAPERUNA; PMI - PREFEITURA ITATIAIA; PMPF - PREFEITURA ENGENHEIRO PAULO DE FRONTIN; PMG - PREFEITURA GUAPIMIRIM; PMIG - PREFEITURA IGUABA GRANDE; PMDC - PREFEITURA DUQUE DE CAXIAS; PMI - PREFEITURA ITAGUAI; PMI - PREFEITURA ITALVA; PMI - PREFEITURA ITAOCARA; PMI - PREFEITURA ITABORAI

Objetivo da fiscalização: Verificar a conformidade à Lei 13.709/2018, conhecida como Lei Geral de Proteção aos Dados - LGPD, das prefeituras municipais jurisdicionadas.

Ofício de apresentação: AUD/SGE/GAP nº 817/22, de 28/03/2022 PMRF - PREFEITURA RIO DAS FLORES
AUD/SGE/GAP nº 818/22, de 28/03/2022 PMRC - PREFEITURA RIO CLARO
AUD/SGE/GAP nº 819/22, de 28/03/2022 PMRB - PREFEITURA RIO BONITO
AUD/SGE/GAP nº 820/22, de 28/03/2022 PMR - PREFEITURA RESENDE
AUD/SGE/GAP nº 821/22, de 28/03/2022 PMQ - PREFEITURA QUISSAMA
AUD/SGE/GAP nº 822/22, de 28/03/2022 PMQ - PREFEITURA QUEIMADOS
AUD/SGE/GAP nº 823/22, de 28/03/2022 PMQ - PREFEITURA QUATIS
AUD/SGE/GAP nº 824/22, de 28/03/2022 PMPR - PREFEITURA PORTO REAL
AUD/SGE/GAP nº 825/22, de 28/03/2022 PMP - PREFEITURA PORCIUNCULA
AUD/SGE/GAP nº 826/22, de 28/03/2022 PMP - PREFEITURA PINHEIRAL
AUD/SGE/GAP nº 827/22, de 28/03/2022 PMRO - PREFEITURA RIO DAS OSTRAS
AUD/SGE/GAP nº 828/22, de 28/03/2022 PMP - PREFEITURA PETROPOLIS
AUD/SGE/GAP nº 829/22, de 28/03/2022 PMPA - PREFEITURA PATY DO ALFERES
AUD/SGE/GAP nº 830/22, de 28/03/2022 PMP - PREFEITURA PARATY
AUD/SGE/GAP nº 831/22, de 28/03/2022 PMPS - PREFEITURA PARAIBA DO SUL
AUD/SGE/GAP nº 832/22, de 28/03/2022 PMP - PREFEITURA PARACAMBI
AUD/SGE/GAP nº 833/22, de 28/03/2022 PMNI - PREFEITURA NOVA IGUAÇU
AUD/SGE/GAP nº 834/22, de 28/03/2022 PMNF - PREFEITURA NOVA FRIBURGO
AUD/SGE/GAP nº 835/22, de 28/03/2022 PMN - PREFEITURA NITEROI
AUD/SGE/GAP nº 836/22, de 28/03/2022 PMP - PREFEITURA PIRAI
AUD/SGE/GAP nº 837/22, de 28/03/2022 PMSMM - PREFEITURA SANTA MARIA MADALENA
AUD/SGE/GAP nº 838/22, de 28/03/2022 PMSF - PREFEITURA SAO FIDÉLIS
AUD/SGE/GAP nº 839/22, de 28/03/2022 PMN - PREFEITURA NATIVIDADE
AUD/SGE/GAP nº 840/22, de 28/03/2022 PMVR - PREFEITURA VOLTA REDONDA
AUD/SGE/GAP nº 841/22, de 28/03/2022 PMV - PREFEITURA VASSOURAS
AUD/SGE/GAP nº 842/22, de 28/03/2022 PMVS - PREFEITURA VARRE-SAI
AUD/SGE/GAP nº 843/22, de 28/03/2022 PMV - PREFEITURA VALENÇA
AUD/SGE/GAP nº 844/22, de 28/03/2022 PMTR - PREFEITURA TRES RIOS
AUD/SGE/GAP nº 845/22, de 28/03/2022 PMTM - PREFEITURA TRAJANO DE MORAES
AUD/SGE/GAP nº 846/22, de 28/03/2022 PMT - PREFEITURA TERESOPOLIS
AUD/SGE/GAP nº 847/22, de 28/03/2022 PMT - PREFEITURA TANGUA

AUD/SGE/GAP nº 848/22, de 28/03/2022 PMSG - PREFEITURA SÃO GONÇALO
AUD/SGE/GAP nº 849/22, de 28/03/2022 PMSAP - PREFEITURA SANTO ANTONIO DE PADUA
AUD/SGE/GAP nº 850/22, de 28/03/2022 PMSJ - PREFEITURA SILVA JARDIM
AUD/SGE/GAP nº 851/22, de 28/03/2022 PMS - PREFEITURA SAQUAREMA
AUD/SGE/GAP nº 852/22, de 28/03/2022 PMS - PREFEITURA SAPUCAIA
AUD/SGE/GAP nº 853/22, de 28/03/2022 PMSSA - PREFEITURA SAO SEBASTIAO DO ALTO
AUD/SGE/GAP nº 854/22, de 28/03/2022 PMSPA - PREFEITURA SAO PEDRO DA ALDEIA
AUD/SGE/GAP nº 855/22, de 28/03/2022 PMSJVRP - PREFEITURA SAO JOSE DO VALE DO RIO PRETO
AUD/SGE/GAP nº 856/22, de 28/03/2022 PMSJU - PREFEITURA SAO JOSE DE UBA
AUD/SGE/GAP nº 857/22, de 28/03/2022 PMSJM – PREFEITURA SAO JOAO DE MERITI
AUD/SGE/GAP nº 858/22, de 28/03/2022 PMSJB - PREFEITURA SAO JOAO DA BARRA
AUD/SGE/GAP nº 859/22, de 28/03/2022 PMSFI - PREFEITURA SAO FRANCISCO DE ITABAPOANA
AUD/SGE/GAP nº 860/22, de 28/03/2022 PMS - PREFEITURA SEROPEDICA
AUD/SGE/GAP nº 861/22, de 28/03/2022 PMS – PREFEITURA MUN SUMIDOURO
AUD/SGE/GAP nº 862/22, de 28/03/2022 PMN - PREFEITURA NILOPOLIS
AUD/SGE/GAP nº 863/22, de 28/03/2022 PMMP - PREFEITURA MIGUEL PEREIRA
AUD/SGE/GAP nº 864/22, de 28/03/2022 PMM - PREFEITURA MIRACEMA
AUD/SGE/GAP nº 865/22, de 28/03/2022 PMC - PREFEITURA CARMO
AUD/SGE/GAP nº 866/22, de 28/03/2022 PMCM - PREFEITURA CARDOSO MOREIRA
AUD/SGE/GAP nº 867/22, de 28/03/2022 PMC - PREFEITURA CARAPEBUS
AUD/SGE/GAP nº 868/22, de 28/03/2022 PMC – PREFEITURA CANTAGALO
AUD/SGE/GAP nº 869/22, de 28/03/2022 PMCG - PREFEITURA CAMPOS DOS GOYTACAZES
AUD/SGE/GAP nº 870/22, de 28/03/2022 PMC - PREFEITURA CAMBUCI
AUD/SGE/GAP nº 871/22, de 28/03/2022 PMCM - PREFEITURA CACHOEIRAS DE MACACU
AUD/SGE/GAP nº 872/22, de 28/03/2022 PMCF - PREFEITURA CABO FRIO
AUD/SGE/GAP nº 873/22, de 28/03/2022 PMCLG – PREFEITURA COMENDADOR LEVY GASPARIAN
AUD/SGE/GAP nº 874/22, de 28/03/2022 PMBJI - PREFEITURA BOM JESUS DO ITABAPOANA
AUD/SGE/GAP nº 875/22, de 28/03/2022 PMBR - PREFEITURA BELFORD ROXO
AUD/SGE/GAP nº 876/22, de 28/03/2022 PMBM - PREFEITURA BARRA MANSA
AUD/SGE/GAP nº 877/22, de 28/03/2022 PMBP - PREFEITURA BARRA DO PIRAI
AUD/SGE/GAP nº 878/22, de 28/03/2022 PMAC - PREFEITURA ARRAIAL DO CABO
AUD/SGE/GAP nº 879/22, de 28/03/2022 PMAB - PREFEITURA ARMAÇÃO DOS BÚZIOS
AUD/SGE/GAP nº 880/22, de 28/03/2022 PMA – PREFEITURA AREAL
AUD/SGE/GAP nº 881/22, de 28/03/2022 PMA - PREFEITURA ARARUAMA
AUD/SGE/GAP nº 882/22, de 28/03/2022 PMA - PREFEITURA APERIBE
AUD/SGE/GAP nº 883/22, de 28/03/2022 PMAR -PREFEITURA ANGRA DOS REIS
AUD/SGE/GAP nº 884/22, de 28/03/2022 PMBJ - PREFEITURA BOM JARDIM
AUD/SGE/GAP nº 885/22, de 28/03/2022 PMCM - PREFEITURA CONCEIÇÃO DE MACABU
AUD/SGE/GAP nº 886/22, de 28/03/2022 PMCA - PREFEITURA CASIMIRO DE ABREU
AUD/SGE/GAP nº 887/22, de 28/03/2022 PMDB - PREFEITURA DUAS BARRAS
AUD/SGE/GAP nº 888/22, de 28/03/2022 PMM - PREFEITURA MESQUITA

AUD/SGE/GAP nº 889/22, de 28/03/2022 PMM - PREFEITURA MENDES
AUD/SGE/GAP nº 890/22, de 28/03/2022 PMM - PREFEITURA MARICA
AUD/SGE/GAP nº 891/22, de 28/03/2022 PMM - PREFEITURA MANGARATIBA
AUD/SGE/GAP nº 892/22, de 28/03/2022 PMM - PREFEITURA MAGE
AUD/SGE/GAP nº 893/22, de 28/03/2022 PMM - PREFEITURA MACUCO
AUD/SGE/GAP nº 894/22, de 28/03/2022 PMC - PREFEITURA CORDEIRO
AUD/SGE/GAP nº 895/22, de 28/03/2022 PMLM - PREFEITURA LAJE DO MURIAE
AUD/SGE/GAP nº 896/22, de 28/03/2022 PMJ - PREFEITURA JAPERI
AUD/SGE/GAP nº 897/22, de 28/03/2022 PMM - PREFEITURA MACAE
AUD/SGE/GAP nº 898/22, de 28/03/2022 PMI - PREFEITURA ITAPERUNA
AUD/SGE/GAP nº 899/22, de 28/03/2022 PMI - PREFEITURA ITATIAIA
AUD/SGE/GAP nº 900/22, de 28/03/2022 PMEPPF - PREFEITURA ENGENHEIRO
PAULO DE FRONTIN
AUD/SGE/GAP nº 901/22, de 28/03/2022 PMG - PREFEITURA GUAPIMIRIM
AUD/SGE/GAP nº 902/22, de 28/03/2022 PMIG - PREFEITURA IGUABA GRANDE
AUD/SGE/GAP nº 903/22, de 28/03/2022 PMDC - PREFEITURA DUQUE DE CAXIAS
AUD/SGE/GAP nº 904/22, de 28/03/2022 PMI - PREFEITURA ITAGUAI
AUD/SGE/GAP nº 905/22, de 28/03/2022 PMI - PREFEITURA ITALVA
AUD/SGE/GAP nº 906/22, de 28/03/2022 PMI - PREFEITURA ITAOCARA
AUD/SGE/GAP nº 907/22, de 28/03/2022 PMI - PREFEITURA ITABORAI

Período abrangido: março/22 a junho/22
Período de execução: 04/04/22 à 27/05/22
Equipe: Augusto César Benvenuto de Almeida, mat. 02/4823
Gabriel de Lemos Silva, mat. 02/4821
Supervisão: Bruno Mattos Souza de Souza Melo, mat. 02/4258

Sumário

1. RESUMO.....	8
2. VISÃO GERAL DO OBJETO	10
2.1. Aplicação da LGPD	11
2.2. Titular, controlador, operador e encarregado	12
2.3. Princípios e hipóteses para tratamento de dados.....	13
2.4. Direitos do titular	14
2.5. Aparente dicotomia entre privacidade e transparência	14
2.6. Privacidade de dados pessoais, um direito fundamental	15
3. VISÃO GERAL DA AUDITORIA	16
3.1. Ato de origem	17
3.2. Objetivo e questões de auditoria	17
3.3. Motivação da auditoria	18
3.4. Metodologia utilizada	18
3.4.1 Análise dos dados	21
3.4.2 Cotejamento junto à esfera federal.....	31
3.5. Limitações.....	34
3.6. Benefícios estimados	35
3.7. Antecedentes	35
4. RESULTADOS DA AUDITORIA.....	37
4.1. Achado 01 - Inexistência de iniciativa para adequação à LGPD	37
4.2. Achado 02 - Ausência de plano de ação, plano de projeto ou documento similar para direcionar a iniciativa de adequação à LGPD	40
4.3. Achado 03 - Contratos firmados com operadores não estabelecem responsabilidades e papéis com relação à proteção de dados pessoais	44
4.4. Achado 04 - Instrumentos convocatórios em elaboração não estabelecem responsabilidades e papéis dos operadores com relação à proteção de dados pessoais.....	47
4.5. Achado 05 - Falta de avaliação de existência de controlador conjunto nos tratamentos de dados pessoais	49
4.6. Achado 06 - Papéis e responsabilidades de cada controlador conjunto identificado não estão definidos em contrato, acordo de cooperação ou instrumento similar.....	52
4.7. Achado 07 - Não identificação de todos os dados pessoais tratados.....	54
4.8. Achado 08 - Ausência de Política de Segurança da Informação.....	56
4.9. Achado 09 - Ausência de Política de Classificação da Informação	61
4.10. Achado 10 - Ausência de nomeação de encarregado de dados	64
4.11. Achado 11 - Informações do encarregado de dados não disponíveis no sítio eletrônico do órgão	67
4.12. Achado 12 - Não identificação das finalidades para as atividades de tratamento de dados	69
4.13. Achado 13 - Falta de avaliação sobre os dados pessoais coletados para identificar se são armazenados apenas os dados estritamente necessários para cumprir com as finalidades de tratamento de dados pessoais realizados.....	72
4.14. Achado 14 - Falta de avaliação para verificar se os dados pessoais são retidos durante o tempo estritamente necessário para cumprir com as finalidades de tratamento de dados pessoais.....	74
4.15. Achado 15 - Ausência de publicação na internet das informações sobre previsão legal, finalidade, procedimentos e práticas utilizadas para o tratamento de dados pessoais	76

4.16. Achado 16 - Não identificação e documentação das bases legais que fundamentam todas as atividades de tratamento de dados pessoais.	79
4.17. Achado 17 - Não elaboração de inventário para consolidar informações relacionadas às características das atividades de tratamento de dados pessoais	82
4.18. Achado 18 - Não elaboração do relatório de impacto à proteção de dados pessoais (RIPD) abrangendo todos os processos de tratamento de dados pessoais que podem gerar riscos aos titulares.	85
4.19. Achado 19 - Ausência de uma política de privacidade para comunicar aos usuários as informações relativas ao tratamento de dados	88
4.20. Achado 20 - Não implementação de mecanismos para atender todos os direitos dos titulares de dados pessoais	92
4.21. Achado 21 - Ausência de identificação de todos os dados pessoais que são compartilhados com terceiros	95
4.22. Achado 22 - Compartilhamentos de dados pessoais em desacordo com os critérios estabelecidos na LGPD... ..	97
4.23. Achado 23 - Ausência de registro de transferência de dados pessoais.....	100
4.24. Achado 24 - Ausência de plano de respostas a incidentes que envolvam violação de dados pessoais	102
4.25. Achado 25 - Falta de procedimentos para comunicar à ANPD e ao titular dos dados pessoais incidentes envolvendo violação de dados pessoais	106
4.26. Achado 26 - Ausência de processo formal para registro, cancelamento e provisionamento de usuários em todos os sistemas que realizam tratamento de dados pessoais.....	108
4.27. Achado 27 - Falta de registro de eventos de atividades de tratamento de dados pessoais	111
4.28. Achado 28 - Ausência de medidas para garantir que todas as soluções tecnológicas sejam projetadas em conformidade com a LGPD desde a concepção.....	114
4.29. Síntese dos achados por dimensão	117
5. CONSIDERAÇÕES FINAIS.....	120
6. PROPOSTA DE ENCAMINHAMENTO	122

LISTA DE ANEXOS

Tabela – ANEXOS	
Documento nº	Descrição
001	Matriz de Planejamento (arquivo digital “001 - Matriz de Planejamento.pdf”)
002	Ofícios de Apresentação aos jurisdicionados (arquivo digital “002 - Ofícios de Apresentação.zip”)
003	Termos de Solicitação de Informações e Documentos nº 01 (arquivo digital “003 - TSID01.zip”)
004	Questionário aplicado aos jurisdicionados (arquivo digital “004 - Questionário LGPD.pdf”)
005	Respostas ao questionário aplicado aos jurisdicionados (arquivo digital “005 - Questionário - Respostas.pdf”)
006	Documentos comprobatórios enviados pelos jurisdicionados no preenchimento ao questionário (arquivo digital “006 - Questionário - Respostas - Anexos.zip”)
007	Termos de Reiteração nº 01 (arquivo digital “007 - Termos de Reiteração - TR01.zip”)
008	Termos de Reiteração nº 02 (arquivo digital “008 - Termos de Reiteração - TR02.zip”)
009	Termos de Reiteração nº 03 (arquivo digital “009 - Termos de Reiteração - TR03.zip”)
010	Matriz de achados (arquivo digital “010 - Matriz de Achados.pdf”)
011	Relação de achados por jurisdicionado (arquivo digital “011 - Relação de achados por jurisdicionado.pdf”)
012	Requisitos mínimos de documentos solicitados (arquivo digital “012 – Requisitos mínimos de documentos solicitados.pdf”)
013	Resultado individualizado (arquivo digital “013 – Resultado individualizado.pdf”)
014	Pontuação das Questões (arquivo digital “014 - Pontuação das Questões.pdf”)
015	Memória de Cálculo (arquivo digital “015 – Memória de cálculo.pdf”)

1. RESUMO

Trata-se de relatório de auditoria de conformidade realizada nas 91 (noventa e uma) prefeituras municipais sob jurisdição desta Corte de Contas no período entre 07/03/2022 e 24/06/2022, que teve como objetivo verificar a adequação das prefeituras municipais à Lei Federal nº 13.709/2018, conhecida como Lei Geral de Proteção de Dados Pessoais – LGPD.

A metodologia adotada foi a autoavaliação de controles internos (do inglês *Control Self-Assessment*), por meio do qual é disponibilizado um questionário eletrônico para que os gestores preencham as respostas que melhor refletem a situação dos órgãos em relação aos controles relacionados à LGPD. Essa técnica vem sendo utilizada com sucesso em outras auditorias executadas pelo TCE-RJ no âmbito da Tecnologia da Informação, conforme levantamentos da Governança e Gestão de TI na esfera estadual e municipal (Processos TCE-RJ 105.096-3/20, 828.786-5/16 e 238.182-1/2013).

Ao longo do trabalho, foram encontrados 28 (vinte e oito) achados de auditoria, que ensejaram determinações e recomendações para os órgãos jurisdicionados se adequarem à LGPD. E, uma vez finalizada a coleta das respostas, foi realizado o cálculo do índice de adequação à norma, denominado **IPD**.

A conclusão desse processo fiscalizatório aponta para um cenário de alto risco à privacidade dos cidadãos que possuem dados pessoais tratados e custodiados pelas prefeituras municipais auditadas, como demonstram as constatações destacadas abaixo:

- 49% das prefeituras jurisdicionadas não tomaram qualquer iniciativa para se adequar à LGPD;
- Aproximadamente 96% ainda não nomeou seu encarregado de dados;
- 94% delas não possuem uma Política de Segurança da Informação;
- Apenas 6% das prefeituras editaram decreto para recepcionar a LGPD;
- 12 prefeituras (13%) zeraram o índice de adequação à LGPD (IPD);
- 75% das prefeituras não atingiram nem 12% da nota máxima do índice IPD;
- Em média, as prefeituras atingiram apenas 9% da pontuação possível no IPD.

Entre os benefícios estimados em decorrência da realização da auditoria, destacam-se:

- Induzir as prefeituras do Estado do Rio de Janeiro a se adequarem a LGPD;
- Permitir acesso dos cidadãos aos direitos estabelecidos na LGPD;
- Obter informações que permitam a esta Corte de Contas selecionar ações que auxiliem os órgãos públicos jurisdicionados a alcançarem maior aderência em relação à LGPD;
- Disponibilizar aos jurisdicionados, não só uma avaliação sobre seus graus de aderência a LGPD, mas também determinações e recomendações que os norteiem a uma maior adequação à lei, incluindo uma análise individual de cada documento enviado por eles, bem como a disponibilização de um anexo¹ contendo os elementos mínimos esperados para cada documentação solicitada nesta auditoria.

Com base nos achados de auditoria, foram efetuadas propostas de encaminhamento ao Plenário desta Corte, tendo sido sugeridas: Comunicação com determinações e recomendações.

As informações veiculadas neste relatório possuem como usuários, além do Ministério Público de Contas, o Corpo Deliberativo deste TCE-RJ, os prefeitos e responsáveis pelo controle interno das prefeituras municipais auditadas e a sociedade em geral.

¹ 012 – Requisitos mínimos de documentos solicitados.pdf

2. VISÃO GERAL DO OBJETO

Inspirada na GDPR (*General Data Protection Regulation*), norma que regulamenta a proteção de dados pessoais dos países-membros da União Europeia, a Lei n.º 13.709/2018, Lei Geral de Proteção de Dados Pessoais (LGPD), tornou-se o marco legal sobre privacidade de dados pessoais no Brasil.

A LGPD dispõe sobre o tratamento de dados pessoais por pessoa natural ou jurídica, seja de direito público ou privado, e visa proteger os direitos fundamentais de liberdade e de privacidade.

A norma define as hipóteses em que é permitido o tratamento de dados pessoais, elenca princípios que devem ser observados nas atividades de tratamento e fixa os direitos dos titulares dos dados. A LGPD dedica, ainda, capítulos exclusivos para o tratamento de dados pessoais pelo poder público, para a criação da ANPD – Autoridade Nacional de Proteção de Dados – e para a criação do Conselho Nacional de Proteção de Dados Pessoais e da Privacidade.

Apesar de ser considerada o marco legal no que se refere à proteção de dados pessoais no Brasil, a LGPD não é a primeira lei que aborda o tema. A Constituição Federal de 1988, o código de defesa do consumidor, a Lei de Acesso à Informação, entre outros normativos, mesmo que de forma fragmentada e superficial, já abordavam este assunto, como pode ser observado na figura abaixo.

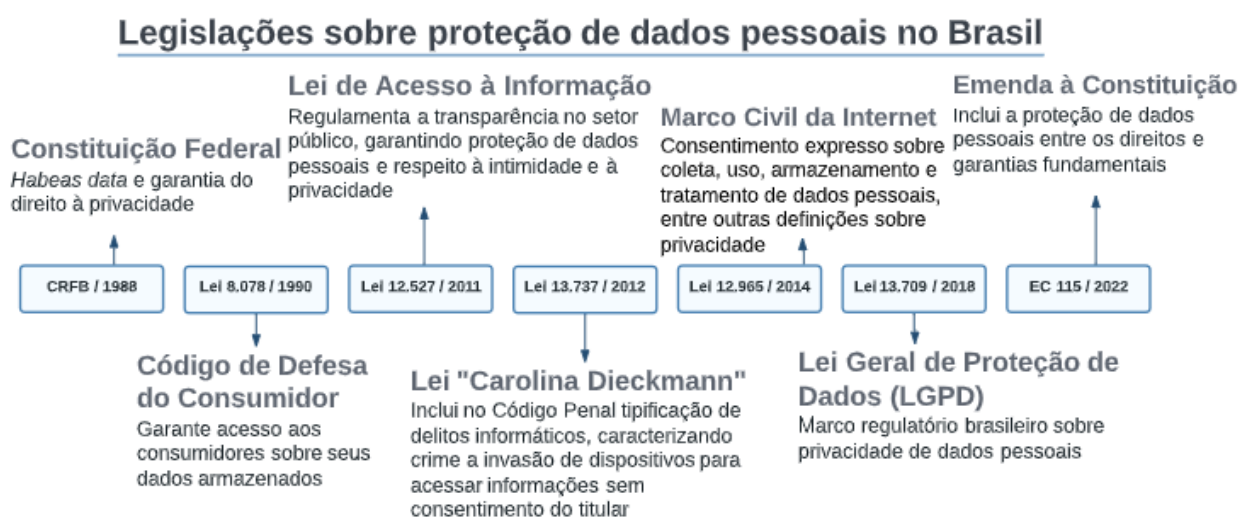


Figura 1: Legislações sobre proteção de dados pessoais no Brasil

A partir da criação da LGPD, o Brasil passou a figurar entre os países que possuem regulamentação sobre a privacidade e proteção de dados pessoais. De acordo

com Conferência das Nações Unidas sobre Comércio e Desenvolvimento², 137 dos 194 dos países-membros (71%) possuem legislação sobre proteção de dados pessoais.

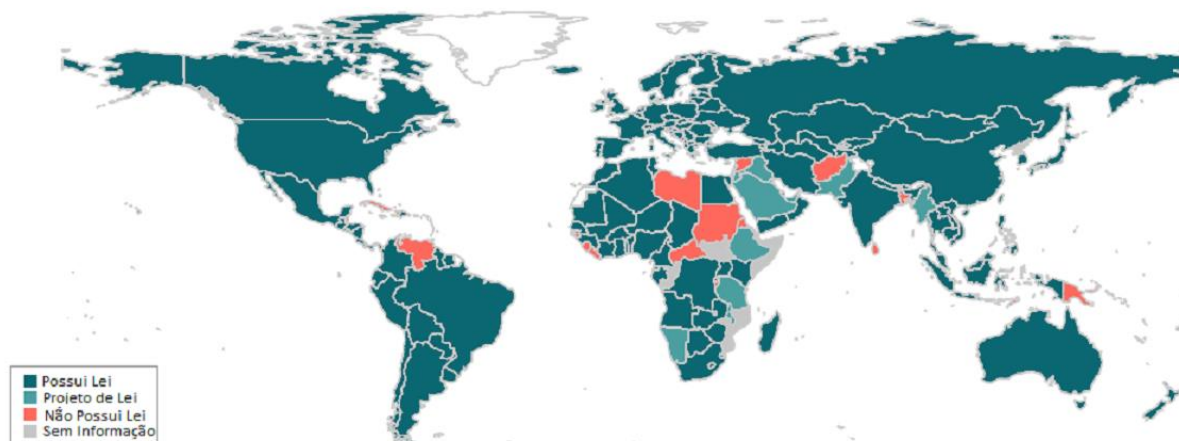


Figura 2: Países no mundo que possuem lei de proteção de dados pessoais

2.1. Aplicação da LGPD

A LGPD se aplica a qualquer um que realize tratamento³ de dados pessoais, seja pessoa natural ou pessoa jurídica (de direito público ou privado). A lei não faz distinção sobre o meio em que o tratamento é realizado. Portanto, a norma é aplicável para operações de dados digitais, bem como em meio físico, realizadas em território nacional, ou mesmo no exterior, desde que os dados tenham sido coletados no Brasil.

A norma não se aplica ao tratamento de dados pessoais realizados por pessoa natural para fins exclusivamente particulares e não econômicos. Também não se aplica quando o tratamento é feito com as seguintes finalidades:

- Jornalística e artística;
- Acadêmica;
- Segurança pública;
- Defesa nacional;
- Segurança do Estado;
- Atividades de investigação e repressão de infrações penais.

² Disponível em <<https://unctad.org/page/data-protection-and-privacy-legislation-worldwide>>. Acesso em 09/06/2022.

³ Art. 5º, X - tratamento: toda operação realizada com dados pessoais, como as que se referem a coleta, produção, recepção, classificação, utilização, acesso, reprodução, transmissão, distribuição, processamento, arquivamento, armazenamento, eliminação, avaliação ou controle da informação, modificação, comunicação, transferência, difusão ou extração;

2.2. Titular, controlador, operador e encarregado

Os principais papéis envolvidos no tratamento de dados pessoais são: o titular dos dados – pessoa natural a quem se referem os dados pessoais tratados – e os agentes de tratamento: controladores e operadores.

Os controladores são os responsáveis pelas decisões a respeito do tratamento de dados, já os operadores são quem realizam o tratamento de dados em nome do controlador.

Os titulares dos dados são sempre pessoas naturais, não há que se falar, então, em pessoa jurídica titular de dados pessoais. Já os agentes de tratamento podem ser pessoas naturais ou jurídicas.

Embora a Lei não se refira explicitamente à figura do controlador conjunto, este papel pode ser identificado no art. 42, inciso II, que define que os controladores diretamente envolvidos em tratamento dos dados pessoais responderão solidariamente em caso de danos ao titular.

O Guia orientativo para definições dos agentes de tratamento de dados pessoais e do encarregado da ANPD⁴ traz diversos exemplos que auxiliam a identificação de casos de controlador conjunto. Segundo o Guia elaborado pela ANPD (p. 13), há controladoria conjunta quando:

1. Mais de um controlador possui poder de decisão sobre o tratamento de dados pessoais;
2. Há interesse mútuo de dois ou mais controladores, com base em finalidades próprias, sobre um mesmo tratamento; e
3. Dois ou mais controladores tomam decisões comuns ou convergentes sobre as finalidades e elementos essenciais do tratamento.

Há ainda um último papel definido na LGPD: o encarregado de dados, pessoa indicada pelos operadores e controladores para atuar como canal de comunicação com os titulares dos dados e com a ANPD. É papel do encarregado garantir a conformidade de uma organização à LGPD.

Trata-se, portanto, de um papel de extrema relevância, pois é ao encarregado que os titulares irão recorrer para garantir seus direitos. Para tanto, sua identidade e as

⁴ Guia Orientativo para Definições dos Agentes de Tratamento de Dados Pessoais e do Encarregado. Disponível em: <https://www.gov.br/anpd/pt-br/documentos-e-publicacoes/Segunda_Versao_do_Guia_de_Agentes_de_Tratamento_retificada.pdf>. Acesso em 21/06/2022>

informações de contato devem ser divulgadas publicamente, preferencialmente no sítio eletrônico do controlador.

Como boa prática⁵, considera-se importante que o encarregado de dados possua independência na execução de suas funções, que tenha acesso à alta administração e que esteja envolvido em todas as questões relacionadas ao tratamento de dados pessoais.

2.3. Princípios e hipóteses para tratamento de dados

Os artigos 6º e 7º da lei definem os princípios e hipóteses para tratamento de dados pessoais. Entre os princípios, destacam-se (i) o da finalidade, que visa assegurar que o tratamento de dados pessoais deve ocorrer para fins específicos e informados explicitamente ao titular dos dados; e (ii) o da necessidade, que define que os controladores e operadores devem coletar somente os dados pessoais estritamente necessários, evitando o tratamento de dados excessivos e incompatíveis com a finalidade informada ao titular dos dados.

A primeira hipótese enumerada na LGPD para a realização de tratamento de dados pessoais é o consentimento do titular dos dados, que deverá ser fornecido por escrito ou alguma outra forma que evidencie a manifestação de vontade do titular. A norma ainda prevê mais 9 (nove) possibilidades para operações de tratamento de dados pessoais, uma delas, pela administração pública, para a execução de políticas públicas previstas em lei ou respaldadas em contratos.

Observa-se, então, que não se faz necessário o consentimento do titular dos dados para a execução de políticas públicas. No entanto, cabe destacar, de acordo com o art. 7º, § 6º, que a dispensa da exigência de consentimento não isenta a administração pública das demais obrigações previstas na LGPD, devendo garantir todos os direitos dos titulares dos dados.

O art. 23, inciso I, vai além: determina que as pessoas jurídicas de direito público devem informar em local de fácil acesso, preferencialmente em seus sítios eletrônicos, de forma clara e atualizada a previsão legal, a finalidade, os procedimentos e as práticas usadas no tratamento de dados pessoais para o exercício de suas competências.

⁵ ABNT NBR ISO/IEC 27.701:2019, item 6.3.1.1 e Guia Orientativo para Definições dos Agentes de Tratamento de Dados Pessoais e do Encarregado (p. 23). Disponível em: https://www.gov.br/anpd/pt-br/documentos-e-publicacoes/Segunda_Versao_do_Guia_de_Agentes_de_Tratamento_retificada.pdf>. Acesso em 13/06/2022.

2.4. Direitos do titular

Os titulares de dados pessoais podem requisitar aos controladores a qualquer momento:



Figura 3: Direitos dos titulares,
Fonte: <https://www.serpro.gov.br/lgpd/cidadao/quais-sao-os-seus-direitos-lgpd>

Todas as solicitações feitas pelo titular devem ser atendidas sem cobrança de custos pelo controlador. E o titular pode, ainda, peticionar em relação aos seus dados pessoais para ANPD contra o controlador.

2.5. Aparente dicotomia entre privacidade e transparência

A lei federal 12.527/2011, conhecida como lei de acesso à informação (LAI), é um marco legal no que se refere à transparência na administração pública. Esta lei regulamenta o inciso XXXIII do art. 5º da Constituição Federal (CF), que garante a todo cidadão o direito de receber dos órgãos públicos informações de seu interesse pessoal ou de interesse coletivo.

A transparência é um dos pilares da governança e permite uma maior efetividade das ações públicas. Trata-se de um mecanismo que estimula a participação e o controle social, bem como melhores ações dos órgãos de controle, garantindo que os gestores públicos cumpram o dever de prestação de contas (*accountability*) e de atuação em conformidade com a legislação (*compliance*).

A ideia de uma lei que visa garantir o direito à privacidade de dados pessoais, pode parecer, a princípio, um empecilho à transparência. No entanto, trata-se de uma falsa dicotomia. Não há nenhum tipo de antagonismo entre a LGPD e a LAI, como se pode observar, por exemplo, no art. 25 da LGPD⁶, que determina que os dados pessoais devem ser mantidos pela administração pública em formato que facilite a disseminação e o acesso das informações pelo público em geral.

A própria LAI já previa em seu art. 6º, inciso III, a obrigação dos órgãos públicos de garantir a proteção da informação pessoal, bem como uma seção inteira dedicada ao tratamento de dados pessoais⁷. A LGPD veio, portanto, complementar a LAI, regulamentando as obrigações de quem custodia informação pessoal de terceiros, e até mesmo definindo o que é considerado dado pessoal sensível⁸, que merece atenção especial, da mesma maneira que dados pessoais de crianças e adolescentes.

A transparência é a regra, ela deve sempre nortear o gestor na administração pública. Não se deve de maneira alguma se apropriar da LGPD para dificultar o acesso dos cidadãos às informações de interesse público. Tanto o direito do acesso à informação pública, quanto o da privacidade de dados são direitos fundamentais, garantidos pela carta magna. Cabe ao gestor público avaliar, no caso concreto, como prezar pela transparência sem violar a privacidade dos titulares dos dados.

2.6. Privacidade de dados pessoais, um direito fundamental

A emenda constitucional 115, de 10/02/2022, incluiu o direito de proteção dos dados pessoais no rol de direitos e garantias fundamentais, demonstrando a

⁶ Art. 25. Os dados deverão ser mantidos em formato interoperável e estruturado para o uso compartilhado, com vistas à execução de políticas públicas, à prestação de serviços públicos, à descentralização da atividade pública e à disseminação e ao acesso das informações pelo público em geral.

⁷ Seção V: Das Informações Pessoais

⁸ Art. 5º, II - dado pessoal sensível: dado pessoal sobre origem racial ou étnica, convicção religiosa, opinião política, filiação a sindicato ou a organização de caráter religioso, filosófico ou político, dado referente à saúde ou à vida sexual, dado genético ou biométrico, quando vinculado a uma pessoa natural.

preocupação do legislador em proteger os direitos fundamentais de liberdade, de privacidade e o livre desenvolvimento da personalidade da pessoa natural.

O uso e compartilhamento indiscriminado de dados pessoais com finalidades ocultas é um risco para o cidadão e até mesmo para a democracia.

Um exemplo disso é o famoso caso da *Cambridge Analytica*, que teve repercussão na mídia mundial, em que ficou constatado⁹ que a empresa *Facebook* compartilhou, sem consentimento, dados de seus usuários, que foram usados para realizar propaganda em massa com o intuito de influenciar no processo eleitoral de diversos países. Por reincidência nesse tipo de prática, a empresa norte-americana foi condenada a pagar multa de 5 bilhões de dólares nos EUA¹⁰.

O escândalo da *Cambridge Analytica* estimulou a criação da GDPR, a lei de proteção de dados europeia, e consequentemente, a LGPD no Brasil.

Outra gigante da tecnologia, a *Google*, foi multada recentemente em 150 milhões de euros pela agência francesa de privacidade de dados¹¹, já com base na GDPR, por dificultar que usuários recusassem o armazenamento de *cookies*¹² em seus dispositivos.

Até o presente momento (junho/22), a ANPD não divulgou nenhuma aplicação de sanção por descumprimento da LGPD. Entretanto, os artigos da lei que tratam das sanções estão em vigor desde agosto de 2021. E, embora a administração pública não seja passível das sanções pecuniárias definidas na lei, a ANPD tem a prerrogativa de sancionar o setor público, com base nas outras sanções administrativas elencadas na LGPD, conforme disposto no art. 52, § 3º.

3. VISÃO GERAL DA AUDITORIA

⁹ Disponível em <<https://g1.globo.com/economia/tecnologia/noticia/2018/12/06/e-mails-revelam-que-mark-zuckerberg-apoiou-compartilhamento-de-dados-de-usuarios-do-facebook.ghtml>>. Acesso em 13/05/2022.

¹⁰ Disponível em <https://brasil.eipais.com/brasil/2019/07/12/economia/1562962870_283549.html>. Acesso em 13/05/2022.

¹¹ Disponível em <<https://www.cnnbrasil.com.br/tecnologia/google-e-multado-em-us169-mi-na-franca-por-infracao-no-uso-de-cookies>>. Acesso em 13/05/2022.

¹² *Cookies* são pequenos fragmentos de dados que ajudam a construir campanhas publicitárias digitais direcionadas, identificar sessões de usuários nos navegadores de internet, entre outras funções.

A presente Auditoria foi conduzida em conformidade com o Manual de Auditoria Governamental do TCE-RJ, baseado nas Normas Brasileiras de Auditoria Aplicadas ao Setor Público.

Buscou-se com esse trabalho avaliar o grau de adequação à LGPD das prefeituras municipais do Estado do Rio de Janeiro em sua totalidade. Dessa forma, foram selecionadas as 91 prefeituras jurisdicionadas do TCE-RJ.

3.1. Ato de origem

A Presente auditoria tem origem no processo TCE-RJ nº 302.295-8/2021, que aprovou o Plano Anual de Auditorias Governamentais para o exercício de 2022.

3.2. Objetivo e questões de auditoria

Este trabalho tem por objetivo verificar a adequação dos municípios fluminenses à Lei 13.709/2018, conhecida como Lei Geral de Proteção aos Dados - LGPD.

A partir do objetivo do trabalho e a fim de avaliar o grau de adequação dos órgãos selecionados, formularam-se as questões de auditoria adiante elencadas:

- a) Os órgãos instituíram comitê e elaboraram plano de ação para se adequar à LGPD?
- b) Foram realizados levantamentos internos e considerados fatores externos no planejamento dos órgãos para implementar a LGPD?
- c) A alta administração dos órgãos está comprometida e incentiva as políticas necessárias para implementação da LGPD?
- d) Os órgãos elaboraram um Plano de Capacitação que abrange treinamento e conscientização dos seus colaboradores em proteção de dados pessoais?
- e) O tratamento de dados pessoais dos órgãos se adequa aos princípios e requisitos da LGPD?
- f) Os órgãos asseguram aos titulares de dados os princípios e direitos garantidos na LGPD?
- g) Os órgãos asseguram que o compartilhamento de dados pessoais com terceiros se adequa aos requisitos e princípios definidos pela LGPD?
- h) Os órgãos gerenciam incidentes de segurança da informação que envolvam violação de dados pessoais?

- i) Os órgãos definiram controles técnicos e administrativos para proteger os dados pessoais?

3.3. Motivação da auditoria

Esta Auditoria de Conformidade encontra-se prevista no Plano Setorial da CAS-TI, decorrente do Plano de Auditoria Governamental do TCE-RJ (PAAG), fiscalização n.º 184/2022, aprovada no processo TCE-RJ n.º 302.295-8/2021.

A escolha do tema considerou os critérios de oportunidade, risco e relevância social, visto que a LGPD é um marco recente na legislação brasileira sobre o direito à privacidade dos dados pessoais, e as prefeituras realizam, necessariamente, tratamento de dados pessoais dos cidadãos ao executarem suas políticas públicas.

Outra razão para a seleção do objeto desta auditoria foi a percepção da necessidade de induzir a administração pública a adotar as melhores práticas para garantir proteção aos dados pessoais, de acordo com o que é estabelecido em lei, tendo em vista que, em levantamento interno realizado no segundo semestre de 2021, não foi possível identificar as medidas adotadas pelos jurisdicionados desta Corte visando adequação à LGPD.

3.4. Metodologia utilizada

A Equipe de Auditoria adotou como metodologia a aplicação de questionário estruturado com intuito de obter informações sobre o grau de adequação dos órgãos à LGPD. A elaboração do questionário eletrônico foi baseada em instrumento utilizado pelo Tribunal de Contas da União em auditoria sobre o mesmo tema, que tem como referência o processo TCU nº 039.606/2020-1.

O questionário aplicado pela Equipe de Auditoria tem por base, prioritariamente, a Lei n.º 13.709/2018 - a LGPD - e as alterações incluídas nela por meio da Lei n.º 13.853/2019. Utilizou-se, também, a norma técnica ABNT NBR ISO/IEC 27.701:2019: Técnicas de segurança - Extensão da ABNT NBR ISO/IEC 27.001 e ABNT NBR ISO/IEC 27.002 para gestão da privacidade da informação - Requisitos e diretrizes.

A ferramenta escolhida para enviar as perguntas aos jurisdicionados foi o *LimeSurvey*, um *software* livre que permite a aplicação de questionários online com

uma gama de funcionalidades, amplamente adotado pelo Tribunal de Contas do Estado do Rio de Janeiro em suas auditorias.

As prefeituras jurisdicionadas receberam o *link* de acesso ao questionário eletrônico, via SICODI¹³, com a descrição do objetivo do trabalho e instruções para acesso e preenchimento (Anexo 003 - TSID01.zip\Anexos). Também foram disponibilizados contatos telefônicos e endereço de correio eletrônico para que os gestores pudessem dirimir eventuais dúvidas. Quanto aos jurisdicionados que não possuíam acesso ao SICODI, as informações acima foram enviadas por e-mail. E cumpre registrar que todas as prefeituras responderam ao questionário.

O questionário contou com 63 questões, divididas em questões de múltipla escolha, campos de texto e outros para envio de arquivos em PDF para evidenciar suas respostas.

As questões foram agrupadas nas 9 (nove) dimensões exibidas abaixo, as mesmas criadas pelo TCU, de forma a permitir o cotejamento dos resultados obtidos pelas prefeituras em relação à esfera federal.

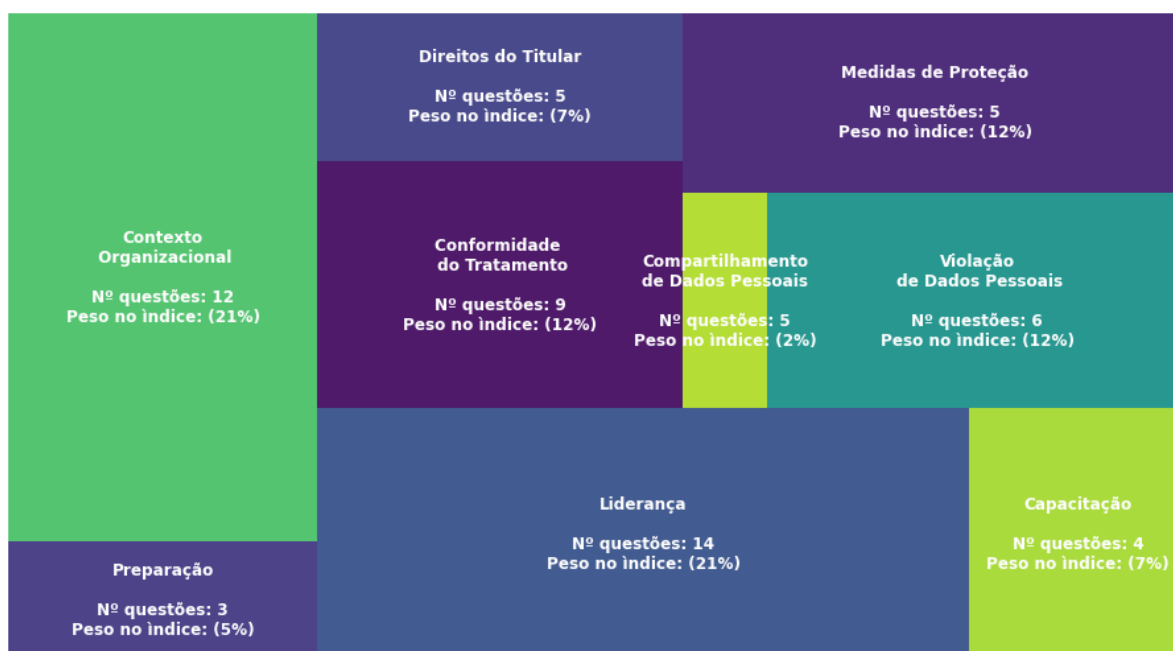


Figura 4: Peso das dimensões no Índice de Adequação à LGPD (IPD)

Foram adicionados mais dois grupos de questões: informações complementares e conclusão, que serão úteis para subsidiar futuras fiscalizações desta Coordenadoria

¹³ Sistema de comunicação digital do Tribunal de Contas do Estado do Rio de Janeiro (TCE/RJ)

de Auditorias em Políticas de Tecnologia da Informação, mas não serão consideradas no índice de adequação à LGPD, denominado **IPD**.

Para permitir a comparação dos índices alcançados pelos órgãos auditados neste trabalho com os índices alcançados pelos órgãos federais na auditoria realizada pelo TCU, optou-se por utilizar o mesmo modelo de pontuação adotado pela Corte de Contas Federal. Destarte, foram selecionadas as mesmas questões para compor o indicador de adequação à LGPD, bem como a pontuação para cada questão, a fórmula de cálculo do índice e as faixas presentes no nível de maturidade.

Pontuação das Questões	
Atendimento ao item	Pontuação
Total	1
Parcial	0,5
Não atendimento	0

Tabela 1: Pontuação das questões

As 42 (quarenta e duas) questões que formam o IPD estão elencadas no anexo “014 - Pontuação das Questões.pdf”, e o cálculo do índice¹⁴ é dado pela razão entre a pontuação obtida e a pontuação máxima possível (42 pontos). Desta forma, o indicador de adequação a LGPD varia de 0 a 1, e os jurisdicionados foram divididos em 4 (quatro) níveis maturidade, de acordo com os resultados obtidos.

NÍVEIS DE MATURIDADE DE ADEQUAÇÃO À LGPD		
Nível	De	Até
Inexpressivo	0,0000	0,1499
Inicial	0,1500	0,4999
Intermediário	0,5000	0,7999
Aprimorado	0,8000	1,0000

Tabela 2: Níveis de Maturidade de Adequação à LGPD

Com base na LGPD e nas melhores práticas para proteção de dados pessoais mundialmente reconhecidas, expostas na norma ABNT NBR ISO/IEC 27.701/2019, a

¹⁴
$$\frac{\sum_{q=1}^{42} \text{notaResposta}(q)}{42}$$

Equipe de Auditoria elaborou um documento¹⁵ contendo elementos mínimos esperados na documentação comprobatória solicitada no questionário.

Este documento, disponível no anexo de nº 12 do relatório de auditoria, criado com o intuito principal de nortear os jurisdicionados no processo de adequação à LGPD, que podem utilizar este anexo como referência, também propiciou uma análise mais objetiva das evidências recebidas.

É importante ressaltar que toda documentação comprobatória enviada pelos jurisdicionados foi analisada pela Equipe de Auditoria, o que resultou em conversão das respostas quando as evidências não atenderam aos critérios mínimos estabelecidos no documento supracitado. Também cabe frisar que a relação de jurisdicionados e seus documentos enviados não aceitos com suas devidas justificativas estão disponíveis no anexo “013 - Resultado individualizado.pdf”, sob o item 2. JUSTIFICATIVAS PARA DESPONTUAÇÃO, considerando-se então que aqueles não constantes foram aceitos ou não enviados pelos órgãos. Para os jurisdicionados que não enviaram os documentos comprobatórios foram demandadas determinações para que sejam produzidos a fim de que os órgãos atuem em conformidade com a legislação.

Além dessas justificativas, o anexo 13 traz o resultado de todos os auditados em cada uma das dimensões, um comparativo do órgão em relação aos demais e uma seção com recomendações individuais, contendo boas práticas para a proteção de dados pessoais. Destaca-se que é prerrogativa do gestor avaliar a pertinência de aplicação destas boas práticas sugeridas.

Por fim, registra-se que as alternativas assinaladas por cada jurisdicionado nas 42 questões que compõem o indicador de adequação à LGPD e as respectivas pontuações estão disponíveis no anexo “015 – Memória de Cálculo.pdf”.

3.4.1 Análise dos dados

A conclusão do envio das respostas por parte dos jurisdicionados ensejou uma análise das informações prestadas a esta Equipe de Auditoria. A análise da documentação comprobatória solicitada, conforme explicitado na seção anterior, foi feita de acordo com os requisitos mínimos elencados no Anexo 012¹⁶.

¹⁵ Anexo: 012 - Requisitos mínimos de documentos solicitados.pdf

¹⁶ Anexo: 012 - Requisitos mínimos de documentos solicitados.pdf

A motivação de criar e anexar essa documentação ao presente trabalho ocorreu após uma constatação feita pela Equipe que dos 819 documentos possíveis de serem recebidos, relativos às seções “A” a “H” do questionário, 9 documentos para cada um dos 91 jurisdicionados, só foram submetidos 38. Destacando-se que dentre esses submetidos, após análise realizada, 9 deles foram considerados com um atendimento parcial e 12 deles foram desconsiderados por não cumprirem os requisitos mínimos esperados.

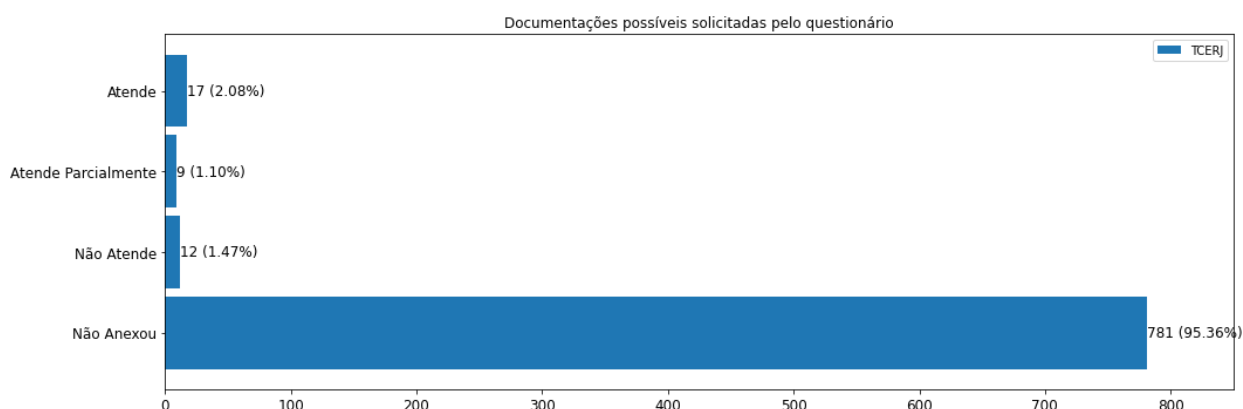


Figura 5: Documentos solicitados nas Seções “A” a “H” do Questionário

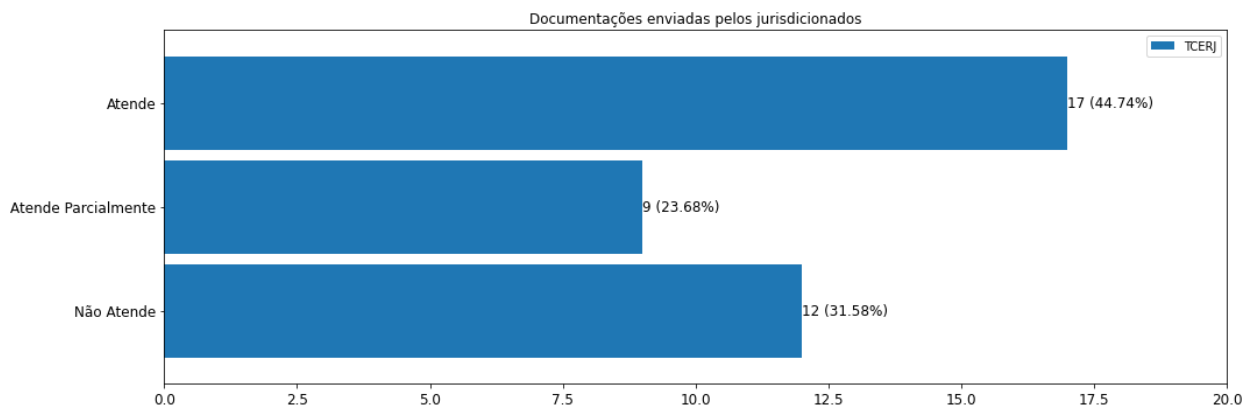


Figura 6: Documentos enviados pelos jurisdicionados

Diante desse cenário insuficiente, que apenas 4.6% dos documentos possíveis foram enviados e cerca de metade deles foram considerados como válidos, exercitando o caráter orientador do presente trabalho, foi elaborado o anexo 12 com o intuito de induzir, nortear e auxiliar os jurisdicionados a elaborarem os regulamentos, políticas e planos solicitados.

Isto posto, surge a necessidade de analisar as respostas objetivas fornecidas para sintetizar o resultado obtido e inferir informações acerca da adequação à LGPD no âmbito da esfera municipal do Estado do Rio de Janeiro.

A síntese do resultado final do IPD pode ser expressa pelo painel:

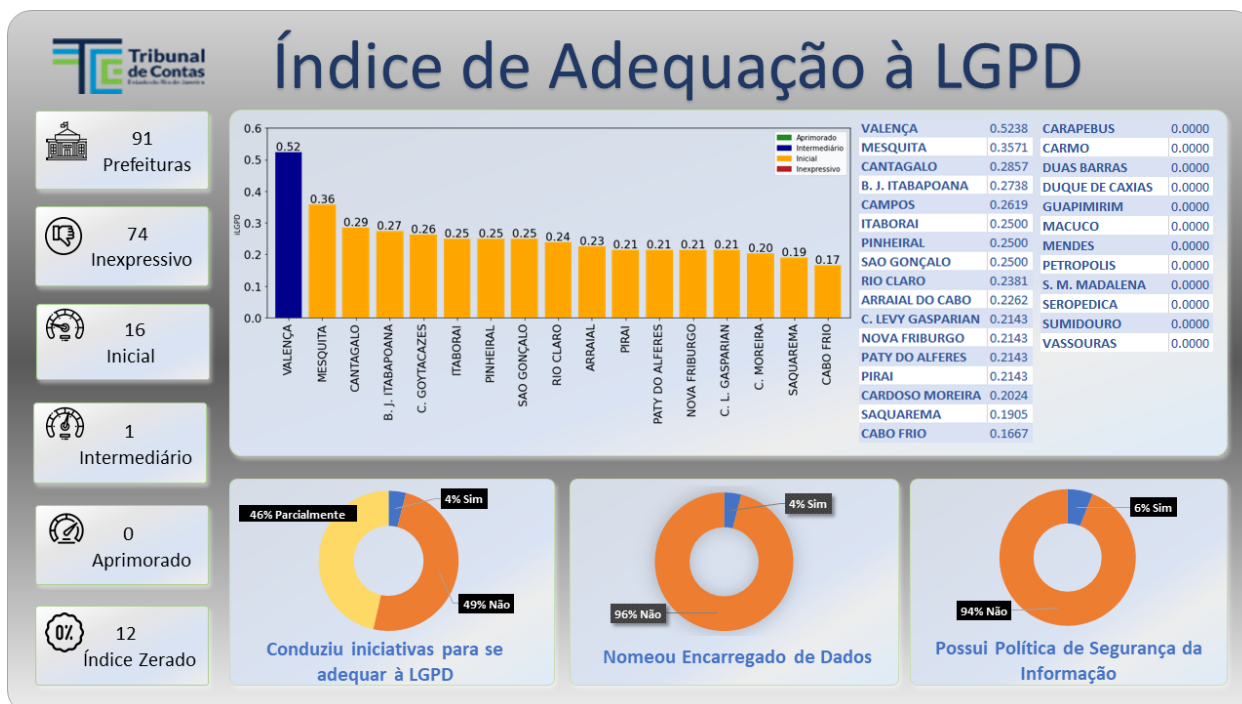


Figura 7: Painel do IPD

O trabalho foi realizado nas 91 prefeituras jurisdicionadas por esta Corte de Contas e constatou-se que 74 prefeituras (81%) apresentaram um nível de maturidade Inexpressivo, 16 prefeituras (17%) apresentaram um nível de maturidade Inicial e apenas a Prefeitura de Valença obteve um nível de maturidade Intermediário. Nenhum jurisdicionado conseguiu atingir o nível Aprimorado, que varia entre nota 0.8 e 1, e evidenciou-se 12 jurisdicionados (13%) com nota 0 no índice.

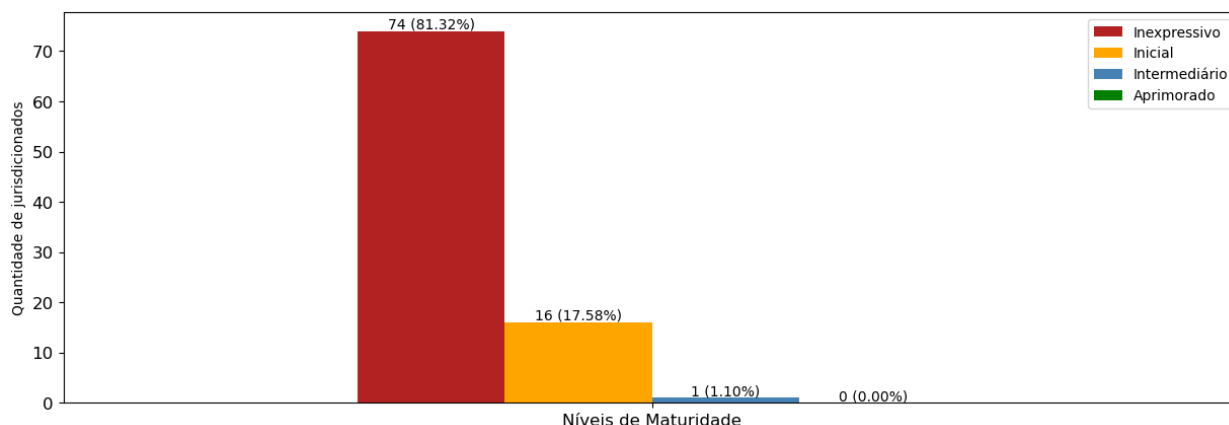


Figura 8: Distribuição de níveis de maturidade entre os jurisdicionados

Foi compilada a lista ordenada dos 17 jurisdicionados que atingiram os níveis de maturidade Inicial ou Intermediário.

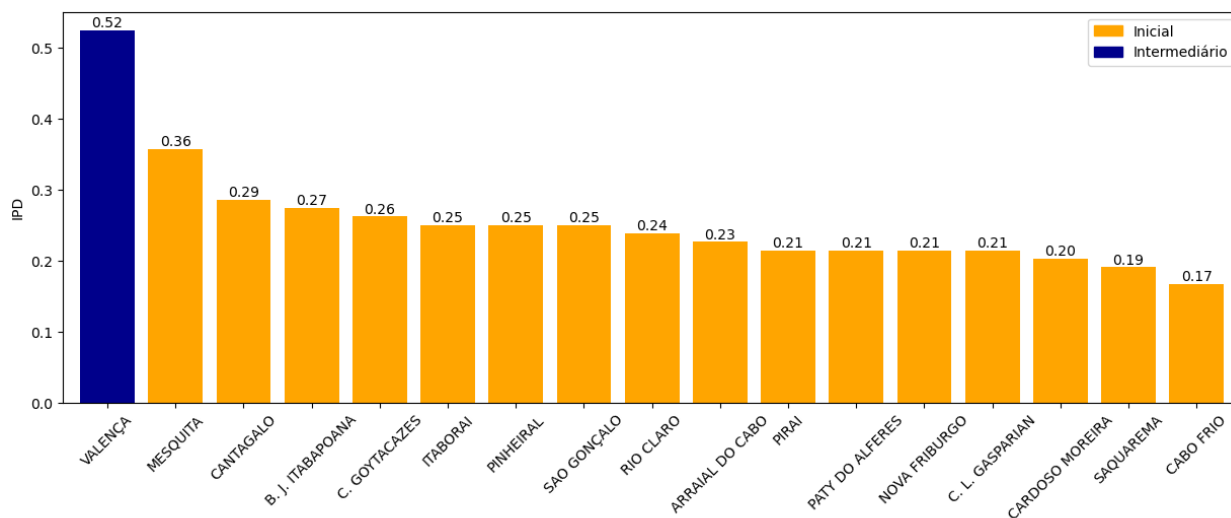


Figura 9: Notas das 17 prefeituras municipais com níveis de maturidade Inicial e Intermediário

Contudo, é imprescindível se obter uma visão macro acerca do resultado e comparar os dados entre os jurisdicionados e entre as dimensões relacionadas. Primeiramente, cabe apresentar as estatísticas do resultado gerado no cômputo do IPD.

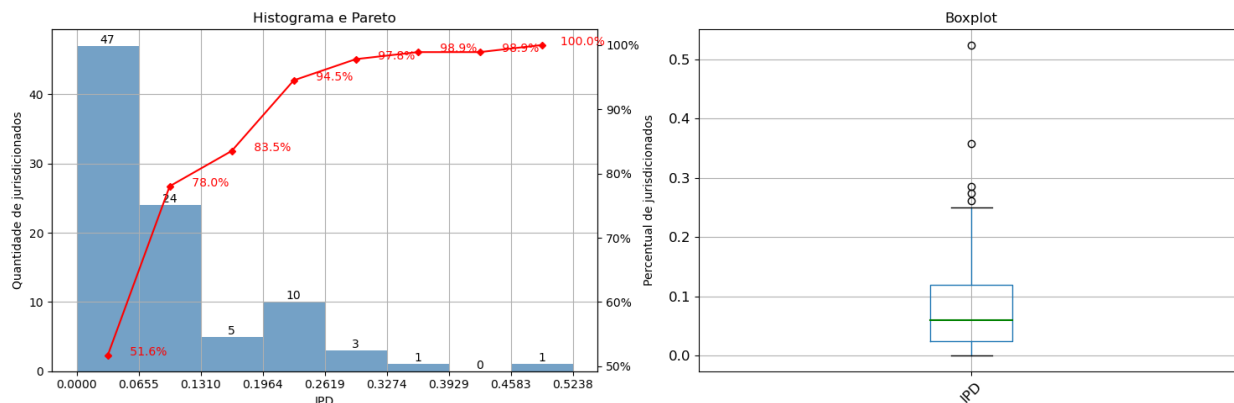


Figura 10: Histograma e boxplot do IPD dos jurisdicionados

Com o histograma, gráfico de Pareto e *boxplot* apresentados acima fica evidente a situação precária de adequação dos municípios à norma, medida pelo IPD. Denota-se que 47 jurisdicionados (51.6%) apresentaram um IPD abaixo de 0.06 e 86 deles (94.5%) atingiram menos de 0.26 de um índice que varia de 0 a 1.

Com as estatísticas arroladas abaixo é possível aferir o nível de pontuação dos municípios nas 9 dimensões e no índice (IPD).

	Preparaçã o	Contexto	Liderança	Capacitaç ão	Conformi dade	Direitos	Compartil hamento	Violação	Medidas	IPD
Mediana	0.2500	0.0556	0.0000	0.0000	0.0000	0.0000	0.0000	0.0000	0.1000	0.0595
Média	0.1593	0.1606	0.0214	0.0458	0.0451	0.0531	0.4066	0.0352	0.1352	0.0890
Desvio Padrão	0.1919	0.2058	0.0635	0.1471	0.1088	0.1701	0.4589	0.0970	0.1722	0.0949
CV	1.2044	1.2817	2.9713	3.2132	2.4147	3.2028	1.1287	2.7595	1.2737	1.0673

Tabela 3: Estatísticas das pontuações dos jurisdicionados por dimensão

Pela mediana, as dimensões com maior pontuação e resultado relevante foram as dimensões de Preparação, Contexto Organizacional e Medidas de Proteção, e foram também as dimensões que apresentaram baixa dispersão, de acordo com o Coeficiente de Variação (CV). Isso denota que foram as seções mais respondidas por todos os jurisdicionados no questionário e que resultaram em pontuação para os mesmos.

A primeira dimensão destacada, Preparação, trata-se de uma introdução ao tema, questionando aspectos relacionados à identificação e ao planejamento das medidas necessárias para a adequação à LGPD. Dessa forma, já se esperava que esta seria a dimensão com maior pontuação.

A segunda, Contexto Organizacional, trata de aspectos relacionados à identificação de normativos correlatos à proteção de dados pessoais, à identificação das partes interessadas e à análise dos dados pessoais tratados pela organização.

Por fim, a última das 3 (três) dimensões apontadas, Medidas de Proteção, que não exigia o envio de nenhuma documentação comprobatória, trata de questões relacionadas à avaliação de impacto sobre a proteção dados pessoais, bem como da implementação de controles para restringir o acesso a estes dados.

Cabe ressaltar que, desconsiderando a dimensão Preparação, por se tratar apenas de seção introdutória, e analisando as médias calculadas de todas as outras, verifica-se que as dimensões com maiores notas médias foram aquelas em que não havia qualquer tipo de solicitação de evidência e documentação comprobatória, quais sejam: Contexto Organizacional, Compartilhamento de Dados Pessoais e Medidas de Proteção. Essa situação pode ensejar um viés nas respostas objetivas enviadas, mas que foi mitigado através da observação 6 do Questionário¹⁷. Este item alertava aos jurisdicionados que as evidências documentais não solicitadas pelo questionário

¹⁷ Anexo: 004 - Questionário LGPD.pdf [fl. 1]

deveriam ser armazenadas e mantidas para verificação em futuros trabalhos desta Corte de Contas.

Pela figura a seguir é possível avaliar a situação dos jurisdicionados em todas as dimensões questionadas. Verifica-se pela mediana (linha verde) que os jurisdicionados necessitam exercer esforços principalmente nas dimensões Liderança, Capacitação, Conformidade do Tratamento, Direitos do Titular, Compartilhamento de Dados Pessoais e Violação de Dados Pessoais.

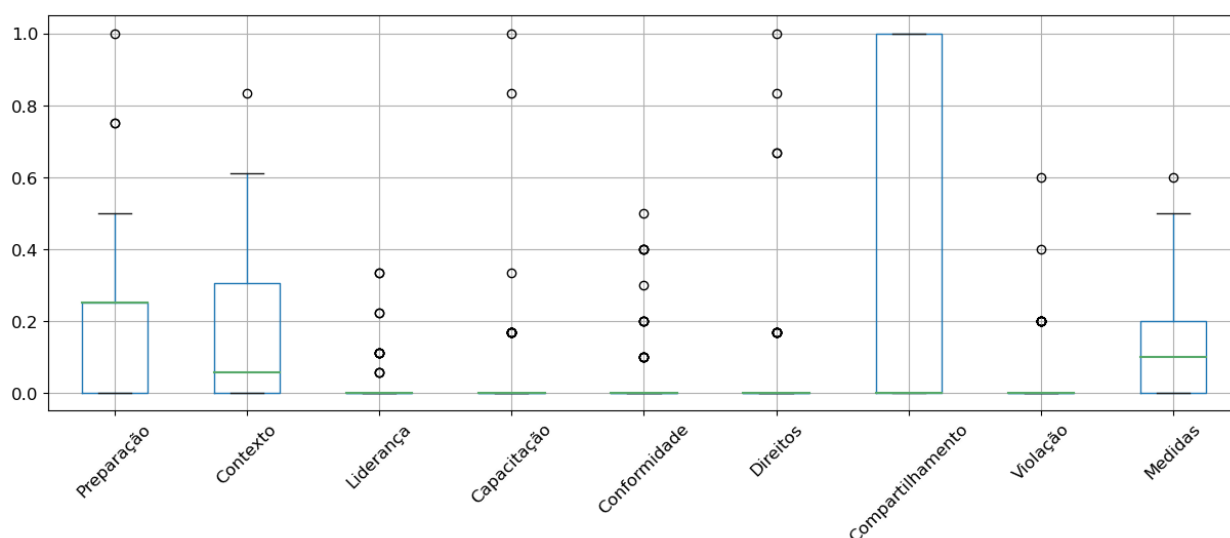


Figura 11: Boxplot da distribuição de pontuação dos jurisdicionados por dimensão

Para explicitar as deficiências entre as diversas dimensões pode ser feita uma visualização em gráfico de radar das médias das notas dos jurisdicionados em cada dimensão.

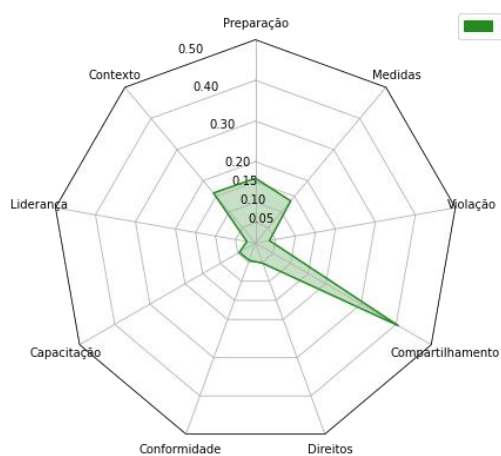


Figura 12: Médias das notas por dimensão

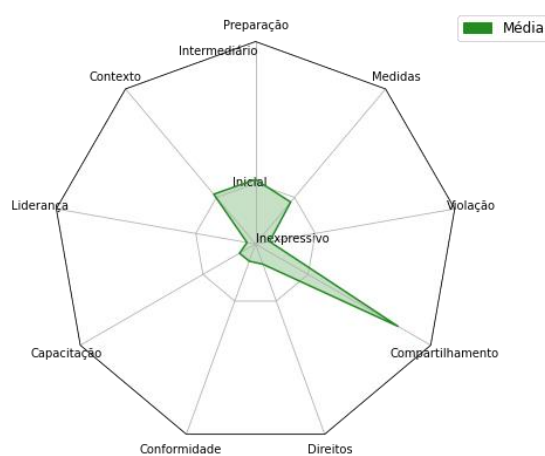


Figura 13: Médias dos níveis de maturidade por dimensão

Essa visão mostra que, na média, os jurisdicionados nem sequer conseguiram atingir o nível de maturidade Inicial (>0.15) nas dimensões propostas. Quando filtrados os 17 jurisdicionados mais bem posicionados e comparados com o quadro geral verifica-se uma melhora na situação encontrada, mas ainda se encontra um nível incipiente de atendimento da norma.

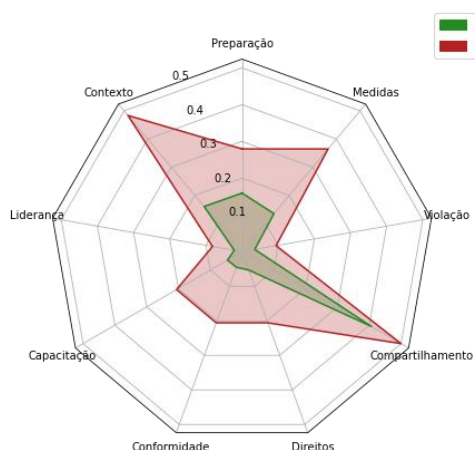


Figura 14: Médias das notas por dimensão

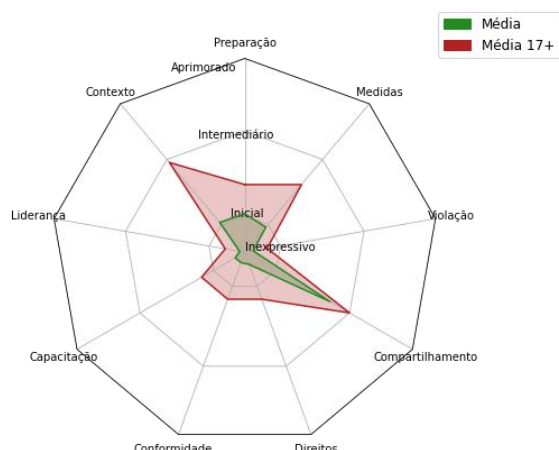


Figura 15: Médias dos níveis de maturidade por dimensão

Importante também apresentar individualmente o nível de atendimento às 2 (duas) dimensões com maior peso no cálculo do índice, quais sejam: Liderança e Contexto Organizacional.

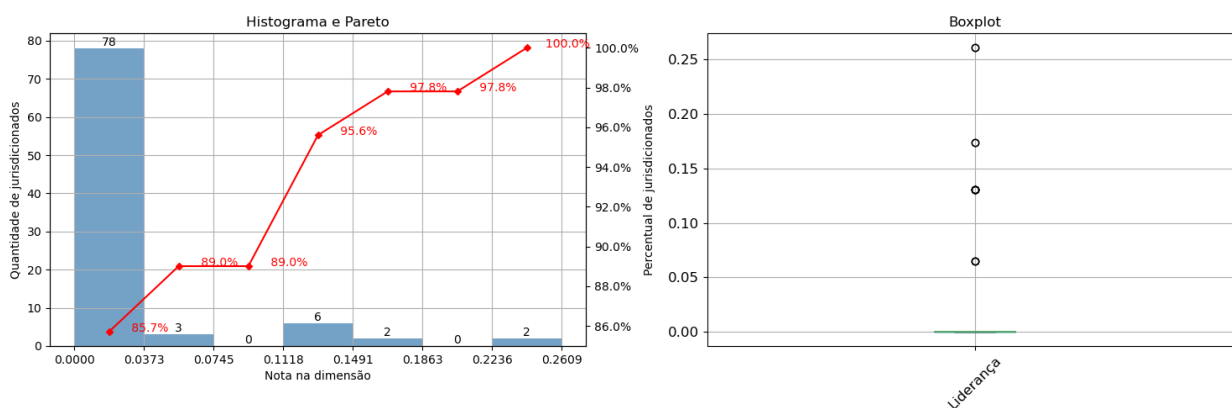


Figura 16: Distribuição da pontuação na dimensão Liderança

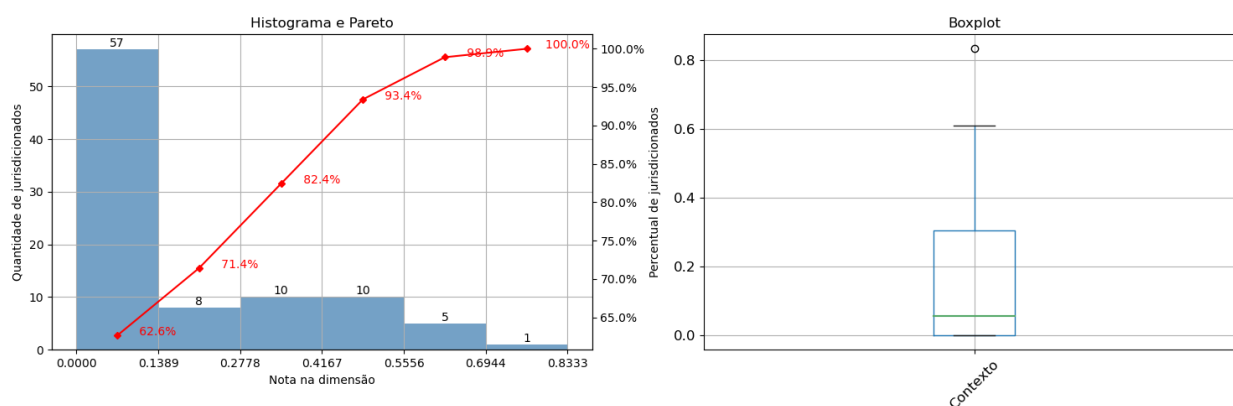


Figura 17: Distribuição da pontuação na dimensão Contexto Organizacional

Infere-se das distribuições que a situação mais gravosa dentre as duas ocorre na dimensão Liderança, uma vez que cerca de 86% dos municípios não atingiram nem 4% da nota máxima prevista. Um esforço para atendimento de tal dimensão poderá ensejar uma grande majoração no cômputo do índice e consequente melhoria no atendimento à norma e às boas práticas de segurança da informação e privacidade.

Na análise de dados procurou-se também relacionar os resultados calculados do índice IPD com outras variáveis em busca da presença de correlações que pudessem consubstanciar trabalhos futuros. Foi calculada a correlação entre o IPD, iGovTI¹⁸, o PIB *per capita*¹⁹ de cada município e a dotação orçamentária municipal²⁰ de 2022 normalizada pela população.

	iGovTI [2017]	PIB <i>per capita</i>	Dotação por habitante
IPD	0.2899	0.0372	0.0839

Tabela 4: Correlações do IPD

Pelos resultados encontrados verifica-se que não existe correlação entre o IPD e as variáveis de PIB *per capita* e Dotação por habitante, por estas apresentarem um valor muito baixo entre si. Com o índice iGovTI encontrou-se uma correlação fraca, porém positiva entre os índices. Esse comportamento pode ser explicado pelo fato de ser esperado dos municípios que tenham uma melhor estrutura de governança uma maior capacidade de implantação e adequação da LGPD em sua municipalidade.

¹⁸ Índice calculado na auditoria do Processo TCE-RJ 828.786-5/16

¹⁹ PIB *per capita* e população municipal. Disponível em: <<https://www.ibge.gov.br/cidades-e-estados/rj.html>>. Acesso em 22/06/2022.

²⁰ Dotação orçamentária dos municípios obtidas em sistemas internos do TCERJ

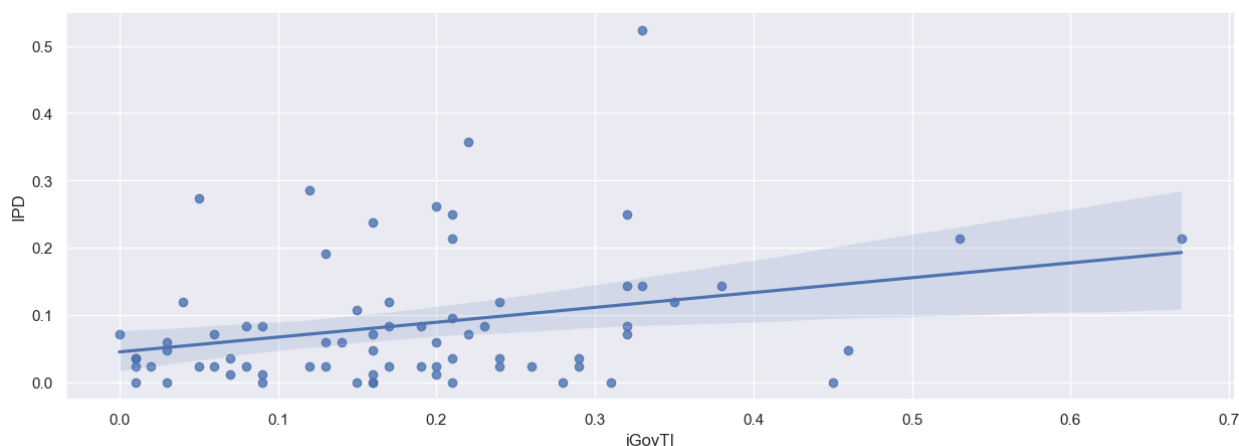


Figura 18: Correlação entre o IPD e o iGovTI de 2017

Por fim, cabe destacar o seguinte conjunto de informações aferidas por meio das respostas do questionário.

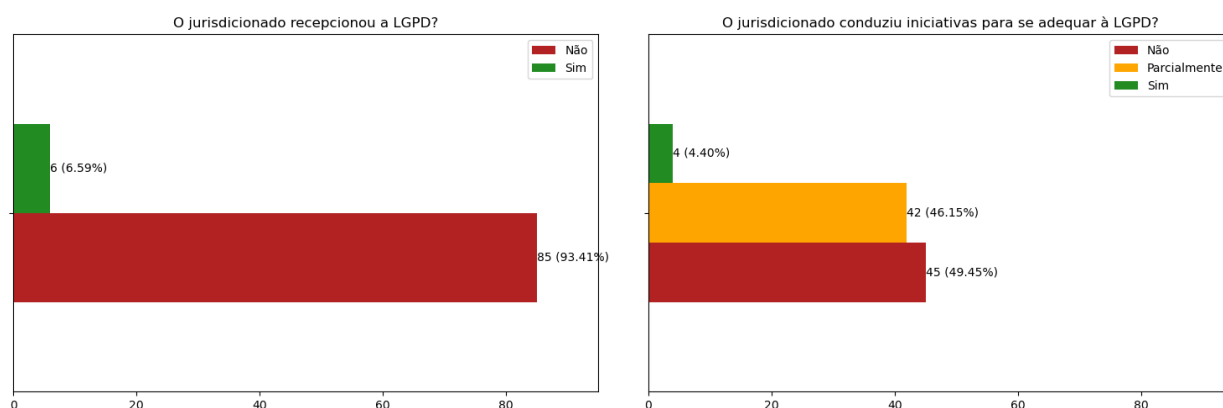


Figura 19: Iniciativas dos jurisdicionados

Apenas 6.5% das prefeituras municipais recepcionaram a LGPD em seu município, seja através de Decretos, Portarias ou outros normativos que indiquem uma ação a fim de se adequar à norma e 4.4% dos jurisdicionados conduziram e concluíram iniciativas para se adequar à LGPD, quantia ínfima e desarrazoada frente ao tempo de vigência da norma. Esse cenário explicita a falta de atenção dos gestores públicos ao tema e a relevância do aspecto indutor deste trabalho de auditoria para sinalizar ao jurisdicionado a importância acerca da privacidade dos dados pessoais.

O panorama relativo aos artefatos característicos de uma boa governança e boas práticas é ainda mais insatisfatório, já que os jurisdicionados praticamente não possuem as políticas que tratam da temática de segurança da informação e privacidade, conforme figura abaixo.

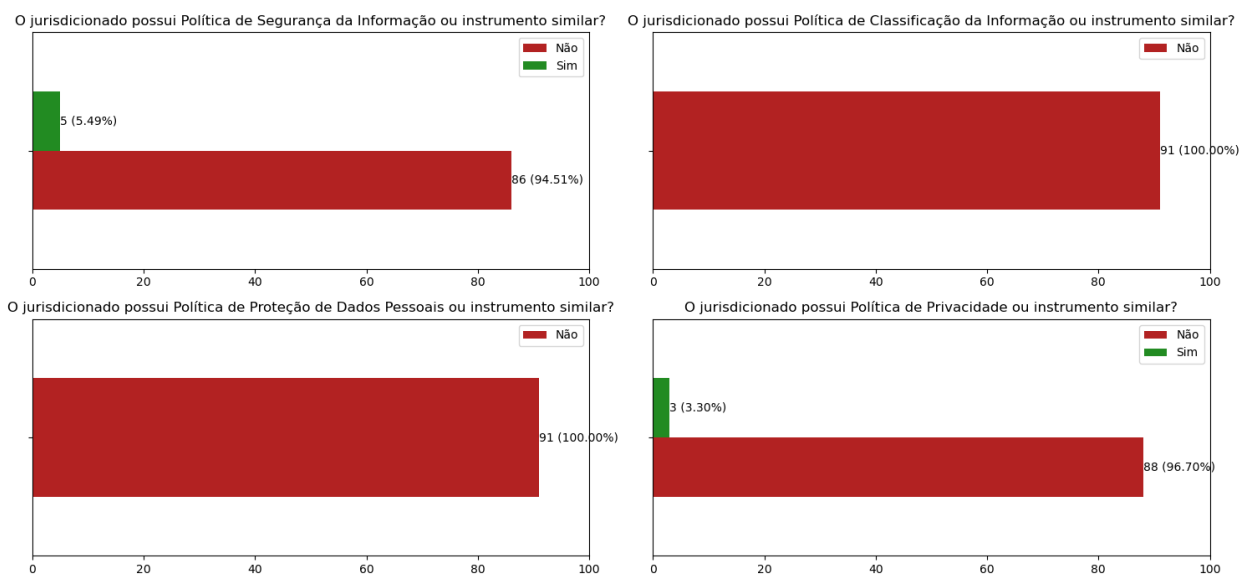


Figura 20: Documentos correlatos ao tema de segurança da informação e privacidade

O mapeamento realizado demonstrou que apenas 4.4% das prefeituras nomearam o encarregado de dados, uma das medidas mais básicas para iniciar a adequação à LGPD. A ausência de um responsável por essa função no órgão pode inviabilizar o acesso dos cidadãos aos direitos estabelecidos na lei, vez que o encarregado é o pilar central para atendimento das reclamações e comunicações dos titulares de dados, responsável, também, pela orientação aos servidores acerca das melhores práticas em relação à proteção de dados pessoais e por atuar como canal de comunicação com a ANPD.

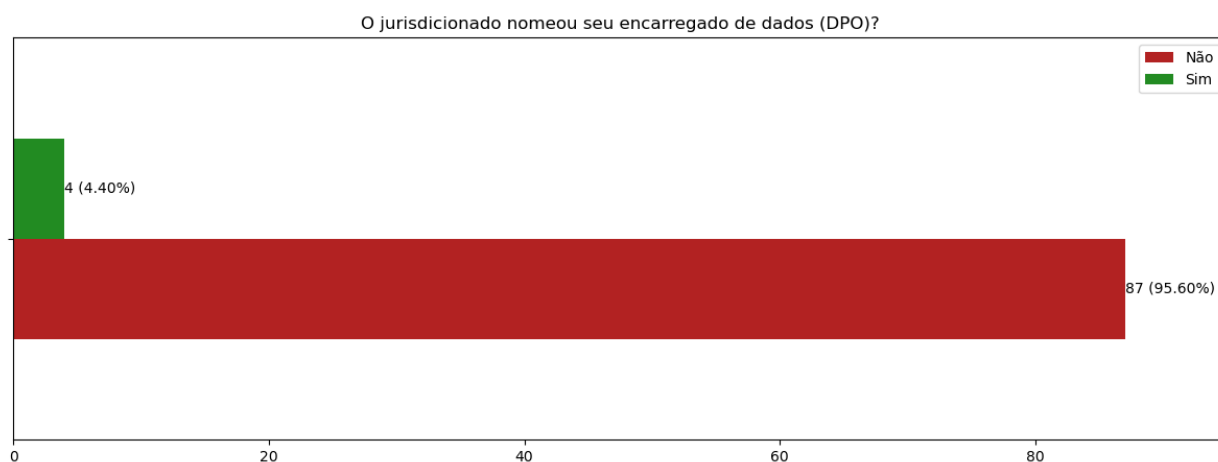


Figura 21: Nomeações do encarregado de dados

3.4.2 Cotejamento junto à esfera federal

Com a conclusão da análise dos dados e consequente compilação das informações geradas buscou-se realizar o cotejamento dos resultados com aqueles encontrados em sede da auditoria feita pelo Tribunal de Contas da União em seu processo TC nº 039.606/2020-1.

Na auditoria do TCU, realizou-se um diagnóstico sobre os controles implementados pelas organizações públicas federais para adequação à LGPD. O trabalho abrangeu 382 órgãos e mapeou diversos achados nas diferentes dimensões propostas. A conclusão do diagnóstico apresentou uma situação de alto risco à privacidade dos cidadãos que têm dados pessoais coletados e tratados pela Administração Pública Federal. Por fim, a Corte de Contas Federal emitiu recomendações e determinações para alguns órgãos a fim de auxiliar o processo de adequação dos jurisdicionados à LGPD.

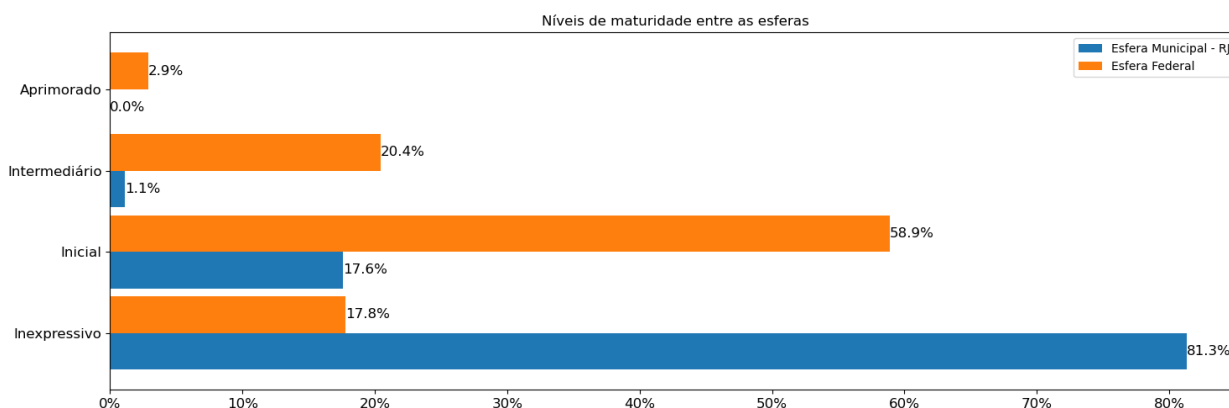


Figura 22: Cotejamento acerca dos níveis de maturidade das esferas

Constata-se na esfera federal um nível de maturidade mais desenvolvido do que no âmbito da esfera municipal. No nível federal encontram-se 18% dos jurisdicionados num nível inexpressivo de atendimento à norma, enquanto no nível municipal a quantidade ultrapassa os 80%, isso representa um valor de diferença relativa de mais de 350%. Destaca-se que o nível federal apresenta 79,3% de seus jurisdicionados em níveis intermediário ou inicial, enquanto no municipal esse valor atinge apenas 18,7%, e que naquele foram encontrados órgãos com nível de maturidade aprimorado, o que não ocorre nos municípios.

Observando as médias calculadas para ambas as esferas é possível evidenciar melhor as disparidades entre os entes, segue:

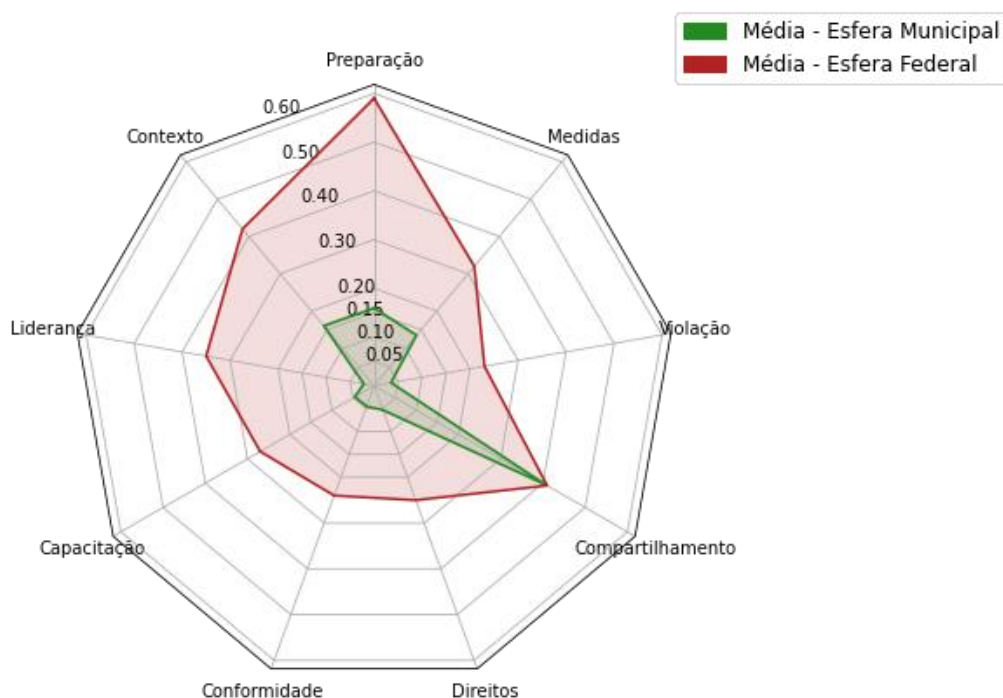


Figura 23: Cotejamento das médias das dimensões entre as esferas

Pela figura anterior fica explícita a diferença de adequação à norma medida pelo IPD entre as duas instâncias. Nas dimensões de Liderança e Violação, a relação entre os entes chega a ser, respectivamente, 16.3 e 6.5 vezes maior no âmbito federal, conforme tabela.

	Preparação	Contexto	Liderança	Capacitação	Conformidade	Direitos	Compartilhamento	Violação	Medidas
Esfera Municipal [I]	0.1593	0.1605	0.0213	0.0457	0.0450	0.0531	0.4065	0.0351	0.1351
Esfera Federal [II]	0.5900	0.4200	0.3500	0.2700	0.2400	0.2500	0.4100	0.2300	0.3200
Proporção [II] / [I]	3.7027	2.6157	16.3800	5.8968	5.3268	4.7068	1.0084	6.5406	2.3675

Tabela 5: Relação das médias das dimensões entre esferas

O cotejamento feito abrangeu também questões importantes ao tema de atendimento à norma e às boas práticas de segurança da informação e privacidade, que apresentaram um baixo valor de notas no âmbito municipal. Procurou-se comparar a

iniciativa de adequação à LGPD, a elaboração de documentos correlatos ao tema e a nomeação do encarregado de dados entre os entes.

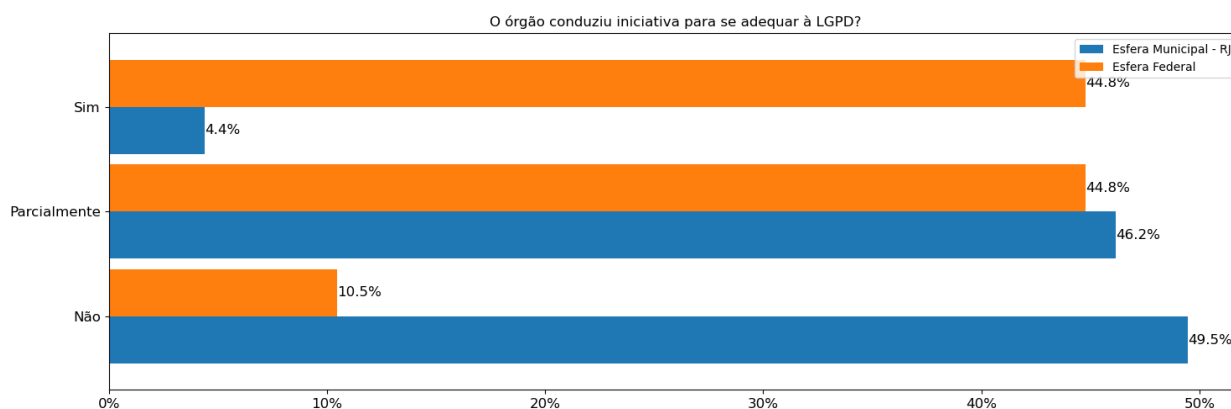


Figura 24: Cotejamento acerca das iniciativas para adequação à LGPD

A figura acima denota a desarmonia de atendimento à LGPD entre os entes. Enquanto na esfera federal quase 90% dos jurisdicionados já conduziram alguma iniciativa para se adequar à lei, na esfera municipal a situação é diametralmente oposta, pois, cerca de 50% não tomou qualquer iniciativa para se adequar à norma e apenas 4.4% responderam que já conduziram iniciativas para se regularizar.

Quanto à produção de documentos e artefatos correlatos às temáticas de LGPD, de segurança da informação e de privacidade, o panorama é mais adverso: somente uma ínfima minoria dos órgãos municipais questionados dispõe de algum tipo de documentação ou normativo sobre os temas.

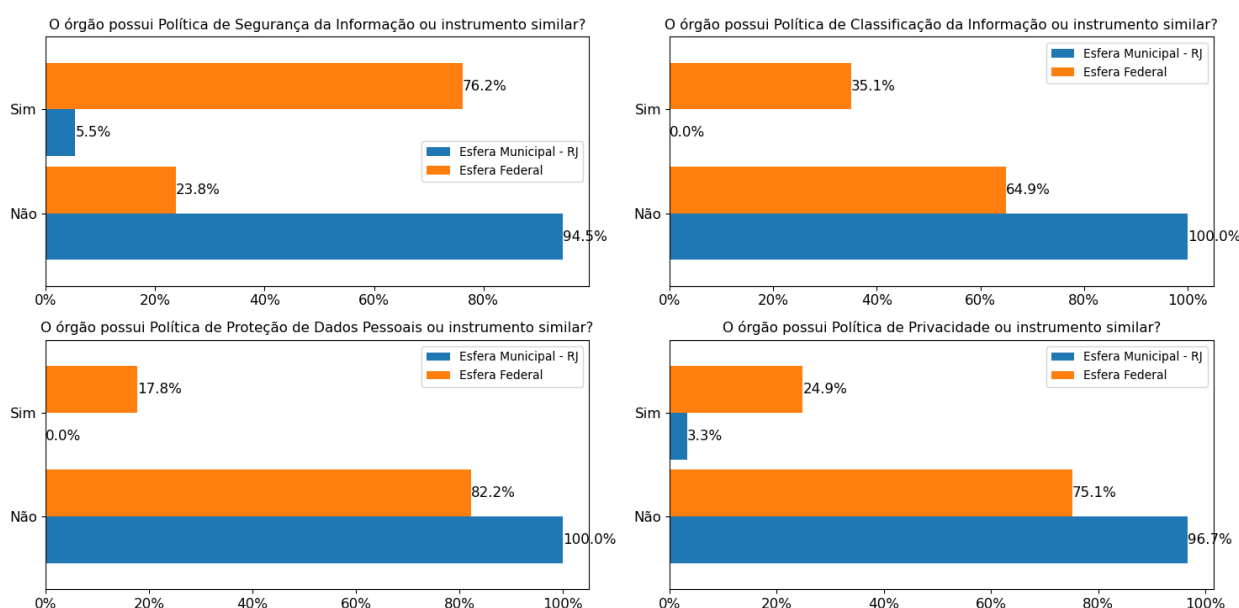


Figura 25: Documentações correlatas à segurança da informação e privacidade

Pelo retrato apresentado nas questões acima, tem-se que o melhor resultado ocorre na Política de Segurança da Informação. Mesmo assim, a quantidade de jurisdicionados que possui o documento se limita a 5.5%, quando no âmbito federal essa quantia estende-se acima dos 75%.

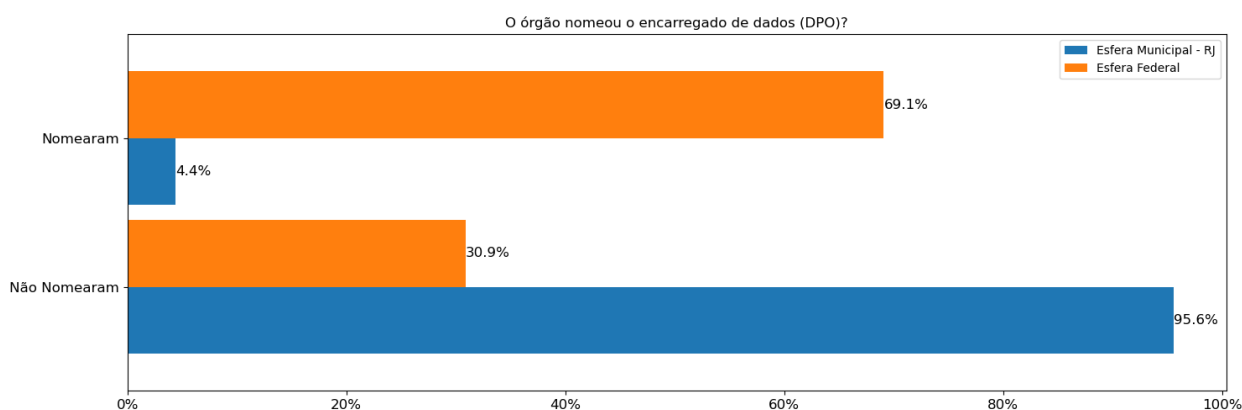


Figura 26: Órgãos que nomearam seu encarregado

Evidenciou-se, ainda, que meros 4.4% das prefeituras municipais do Estado do Rio de Janeiro nomearam os seus encarregados de dados, à medida que no âmbito federal esse valor chegou próximo aos 70%.

Dessa forma, é notório que ambas as esferas se encontram aquém do exigido pela Lei Geral de Proteção de Dados Pessoais e recomendado pelas boas práticas de segurança da informação e privacidade, ensejando, assim, um conjunto de determinações e recomendações para concretizar o pleno atendimento à norma.

3.5. Limitações

As limitações estão relacionadas à metodologia utilizada nessa auditoria, dado que as informações são obtidas através de questionário eletrônico e, portanto, possuem caráter declaratório.

Para mitigar essa limitação, foi solicitado que os jurisdicionados mantivessem as evidências documentais que suportam suas respostas, pois poderão ser solicitadas pelo TCE-RJ em verificação posterior. Além disso, o questionário possui campos exigindo a inclusão de documentos comprobatórios para evidenciar parte das respostas fornecidas.

Cumprе rememorar que tais documentos foram devidamente analisados²¹ pela Equipe de Auditoria para avaliar se cumpriam os requisitos mínimos²² esperados.

Ressalta-se que tal limitação não impediu o pleno atingimento do objetivo proposto deste trabalho. E a baixa média dos resultados alcançados pelo jurisdicionados denota a fidedignidade das respostas apresentadas.

3.6. Benefícios estimados

Os benefícios e efeitos esperados em decorrência deste trabalho são:

- Induzir as prefeituras do Estado do Rio de Janeiro a se adequarem a LGPD;
- Permitir acesso dos cidadãos aos direitos estabelecidos na LGPD;
- Obter informações que permitam a esta Corte de Contas selecionar ações que auxiliem os órgãos públicos jurisdicionados a alcançarem maior aderência em relação à LGPD;
- Disponibilizar aos jurisdicionados, não só uma avaliação sobre seus graus de aderência a LGPD, mas também determinações e recomendações que os norteiem a uma maior adequação à lei, incluindo uma análise individual de cada documento enviado por eles, bem como a disponibilização de um anexo²³ contendo os elementos mínimos esperados para cada documentação solicitada nesta auditoria.

3.7. Antecedentes

A LGPD entrou em vigor em 14 de agosto de 2020, enquanto os artigos que versam sobre sanções administrativas (52, 53 e 54) passaram a vigorar em 1º de agosto de 2021.

Apesar da lei já estar em vigor desde 2020, em levantamento interno, realizado no segundo semestre de 2021, foi observado que poucas prefeituras municipais do Estado do Rio de Janeiro haviam divulgado medidas para se adequar à LGPD. Nenhuma delas disponibilizava as informações sobre os seus encarregados de dados em seus sítios eletrônicos.

Diante do cenário descrito, vislumbrou-se a possibilidade de realização desta auditoria, com o intuito de induzir uma mudança no comportamento dos gestores em

²¹ A análise realizada nos documentos comprobatórios consta no Anexo "013 - Resultado individualizado.pdf"

²² Anexo "012 - Requisitos mínimos de documentos solicitados.pdf"

²³ 012 – Requisitos mínimos de documentos solicitados.pdf

relação à LGPD, para que implementem o quanto antes ações para adequação a esta lei nas prefeituras, propiciando acesso dos cidadãos aos direitos estabelecidos na norma.

4. RESULTADOS DA AUDITORIA

Todos os achados da auditoria, elencados abaixo, estão evidenciados nas respostas ao questionário eletrônico encaminhado às 91 (noventa e uma) prefeituras municipais jurisdicionadas dessa Corte de Contas.

As respostas de todos os participantes ao questionário estão disponíveis no anexo “005 - Questionário - Respostas.pdf”, bem como os documentos comprobatórios das questões evidenciáveis, encaminhados por meio do próprio questionário eletrônico, que estão todos consolidados no anexo “006 - Questionário - Respostas - Anexos.zip”.

Outrossim, o encaminhamento para todos os achados será de comunicação com determinação para correção as irregularidades apuradas, tendo em vista: (i) que a LGPD entrou em vigor em agosto de 2020, no auge do enfrentamento à pandemia da COVID-19; (ii) que este é o primeiro trabalho do TCE-RJ visando aferir a conformidade dos seus jurisdicionados à LGPD, (iii) que a ANPD demorou a se estruturar efetivamente²⁴; e (iv) que o foco do presente trabalho é o de indução dos jurisdicionados a uma maior aderência à LGPD.

Todavia, não é demais reforçar que a implementação de todas as determinações poderá ser avaliada por este Tribunal de Contas em futuras auditorias.

4.1. Achado 01 - Inexistência de iniciativa para adequação à LGPD

4.1.1 Critérios

- Constituição Federal, art. 5º, inciso II, princípio da legalidade.
- Lei Federal nº 13.709/2018, art. 3º, 46 e art. 50, parágrafo 2º, inciso I.
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, item 5.4.

4.1.2 Evidências

- 005 - Questionário - Respostas.pdf: Respostas ao item A1 do Questionário, onde os respondentes afirmam que não foram conduzidas iniciativas para identificar e planejar as medidas necessárias para adequação à LGPD.

4.1.3 Situação Encontrada

²⁴ Disponível em: <<https://www.conjur.com.br/2020-ago-27/dois-anos-atraso-governo-cria-estrutura-anpd>>, <<https://www.in.gov.br/en/web/dou/-/decreto-n-10.474-de-26-de-agosto-de-2020-274389226>>, <<https://www.gov.br/anpd/pt-br/assuntos/noticias/publicado-novo-decreto-que-fortalece-a-estrutura-organizacional-da-anpd>>. Acessos em 09/06/2022.

Entre as 91 prefeituras auditadas, 45 (quarenta e cinco) afirmaram que não iniciaram qualquer iniciativa para alcançar a conformidade com a LGPD. Outras 42 (quarenta e duas) declararam que iniciaram o processo, mas ainda não finalizaram, e somente 4 (quatro) responderam que concluíram iniciativa para identificar e planejar medidas necessárias de adequação à lei.

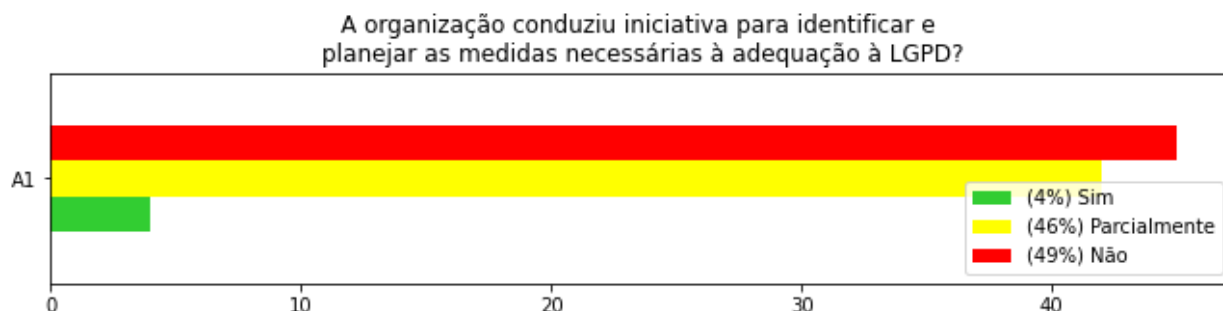


Figura 27: Respostas da questão A1

Como em qualquer projeto, o planejamento é uma fase crucial. Para se adequar à LGPD é importante que o órgão verifique em que estágio se encontra e se já possui mecanismos para proteção dos dados pessoais. É aconselhável a instituição de uma comissão para planejar e identificar as ações necessárias para adequação à LGPD. E o resultado desse planejamento pode ser materializado em um plano de ação, contendo um cronograma com as ações a serem executadas e uma data prevista para início e fim de cada ação.

A LGPD foi aprovada desde 2018 e entrou em vigor em agosto de 2020. No entanto, como se observa pelas respostas dos jurisdicionados, o cenário entre as prefeituras se encontra muito aquém do esperado, mesmo dois anos após a entrada em vigor da lei.

O art. 3º da LGPD define que a lei se aplica a pessoas jurídicas de direito público, já o art. 46 determina que os agentes de tratamento devem adotar medidas de segurança, técnicas e administrativas para resguardar os dados pessoais que custodiam. Portanto, a inércia apresentada pelos órgãos no sentido de implementar iniciativas para se adequar à legislação afronta não apenas a LGPD, como também o princípio da legalidade, expresso na Constituição Federal.

Entretanto, diante das considerações expostas no item 4 deste relatório, será sugerido na proposta de encaminhamento uma **determinação** para que as prefeituras

iniciem ou concluam as ações para identificar as medidas necessárias para adequação à LGPD, de forma a corrigir esta irregularidade apurada.

4.1.4 Causas

- Não investigadas

4.1.5 Efeitos

- Prejuízo na proteção dos dados pessoais dos titulares pela não conformidade à LGPD;
- Impossibilitar os titulares de dados pessoais de exercerem seus direitos estabelecidos na LGPD.

4.1.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados a seguir, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.
 - **DETERMINAÇÃO:** conduzir iniciativas para identificar e planejar as medidas necessárias para adequação à LGPD, sendo essas materializadas, ao menos, através do estabelecimento de um comitê ou grupo de trabalho que conte com o apoio ou participação direta da alta direção da organização.
 - **RESPONDERAM PARCIALMENTE:** Barra do Piraí, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cambuci, Cantagalo, Casimiro de Abreu, Comendador Levy Gasparian, Iguaba Grande, Itaboraí, Itaguaí, Itaocara, Itatiaia, Macaé, Magé, Mangaratiba, Maricá, Mesquita, Miguel Pereira, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paraty, Piraí, Porciúncula, Porto Real, Quatis, Quissamã, Resende, Rio Bonito, Rio das Ostras, Santo Antônio de Pádua, São Gonçalo, São João de Meriti, São José do Vale do Rio Preto, Saquarema, Teresópolis, Trajano de Moraes e Varre-Sai.

- **RESPONDERAM NEGATIVAMENTE:** Angra dos Reis, Aperibé, Araruama, Armação de Búzios, Arraial do Cabo, Cachoeiras de Macacu, Campos dos Goytacazes, Carapebus, Cardoso Moreira, Carmo, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Italva, Itaperuna, Japeri, Laje do Muriaé, Macuco, Mendes, Miracema, Natividade, Paracambi, Paraíba do Sul, Paty do Alferes, Petrópolis, Queimados, Rio Claro, Rio das Flores, Santa Maria Madalena, São Fidélis, São Francisco de Itabapoana, São Joao da Barra, São José de Ubá, São Pedro da Aldeia, São Sebastiao do Alto, Sapucaia, Seropédica, Silva Jardim, Sumidouro, Tanguá, Vassouras e Volta Redonda.

4.2. Achado 02 - Ausência de plano de ação, plano de projeto ou documento similar para direcionar a iniciativa de adequação à LGPD

4.2.1 Critérios

- Lei Federal nº 13.709/2018, art. 46 e art. 50, parágrafo 2º, inciso I
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, item 5.4

4.2.2 Evidências

- Anexo: 005 – Questionário – Respostas.pdf: Respostas negativas ao item A2 do Questionário, onde os respondentes afirmam que não foi elaborado plano de ação, plano de projeto ou documento similar para direcionar a iniciativa de adequação à LGPD.
- 006 - Questionário -Respostas - Anexos.zip\Barra de Pirai\00035_01_processo-administrativo-nº-11.566.2020.pdf: Documento anexado não cumpriu o mínimo esperado para o Plano de Ação.
- 006 - Questionário -Respostas - Anexos.zip\Mangaratiba\00080_01_minuta-de-decreto-lgpd.pdf: Documento anexado não cumpriu o mínimo esperado para o Plano de Ação.
- 006 - Questionário -Respostas - Anexos.zip\Mesquita\00073_01_a21.pdf: Documento anexado não cumpriu o mínimo esperado para o Plano de Ação.
- 006 - Questionário -Respostas - Anexos.zip\Niterói\00063_01_14.09.21-2.pdf: Documento anexado não cumpriu o mínimo esperado para o Plano de Ação.

- 006 - Questionário -Respostas - Anexos.zip\Piraí\00029_01_pstic-pol-tica-de-segurança-detecnologia-informação-e-comunicação-versão-1.1-11-02-2022.pdf: Documento anexado não cumpriu o mínimo esperado para o Plano de Ação.
- 006 - Questionário -Respostas - Anexos.zip\Rio das Ostras\00077_01_memo-circular-001-protocolo-de-entrega-ascomti-ti.pdf: Documento anexado não cumpriu o mínimo esperado para o Plano de Ação.
- 006 - Questionário -Respostas - Anexos.zip\Valença\00087_01_decreto-119-2021-regulamentalgpd.pdf: Documento anexado não cumpriu o mínimo esperado para o Plano de Ação.

4.2.3 Situação Encontrada

Conforme exposto na situação encontrada do achado anterior, a fase de planejamento é de extrema importância e pode ser materializada por meio de um plano de ação. No planejamento para adequação à LGPD devem ser levantadas as medidas necessárias, as unidades responsáveis e os prazos estimados para execução das ações. Essas informações, entre outras, podem ser consolidadas em um documento usado para direcionar e acompanhar a implementação da LGPD.

O item A2 do questionário buscou verificar se os órgãos elaboraram um plano de ação para adequação à LGPD. Para este item era obrigatório o envio de arquivo para comprovar a existência do documento.

Apenas 10 (dez) respondentes declararam possuir plano de ação. E mesmo assim, após análise efetuada pela Equipe de Auditoria nos documentos comprobatórios enviados pelos jurisdicionados, foi verificado que somente as Prefeituras de Pinheiral, Rio Claro e São João de Meriti conseguiram comprovar a existência do documento contendo os elementos mínimos esperados: as ações identificadas, os responsáveis e os prazos estimados.

Um bom exemplo de plano de ação foi o enviado pela Prefeitura de Pinheiral²⁵, que, além dos itens mínimos já citados, também possui outras informações, como prioridade, categoria e situação das ações.

Diante da análise empreendida, ficou constatado que os documentos enviados pelas Prefeituras de Barra do Piraí, Mangaratiba, Mesquita, Niterói e Piraí não se

²⁵ Anexo: 006 - Questionário - Respostas - Anexos.zip\Pinheiral\00002_01_plano-de-ação-lgpd-pinheiral.pdf

tratavam de um plano de ação, desta forma foi considerada como “negativa” a resposta desses jurisdicionados ao item.

Já os documentos enviados pelas prefeituras de Rio das Ostras e Valença atenderam parcialmente ao que se espera de plano de ação, portanto, as respostas afirmativas desses jurisdicionados ao item A2 foram convertidas para “parcialmente”.

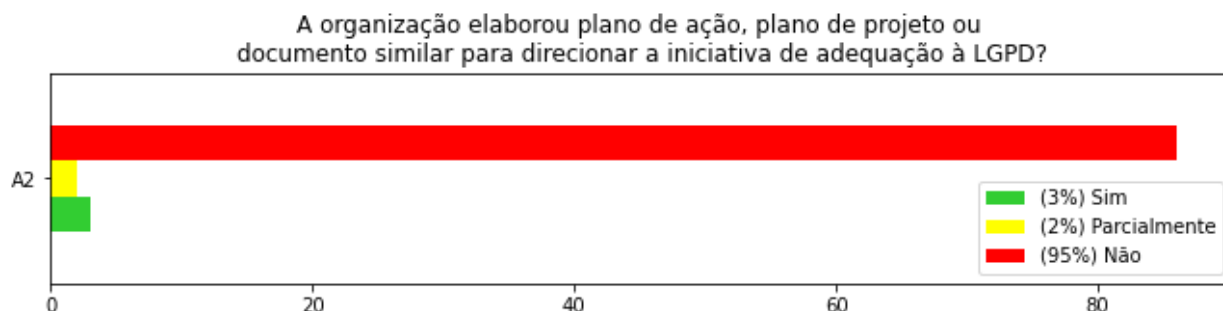


Figura 28: Respostas da questão A2

As análises individuais de cada documento não aceito podem ser encontradas no anexo “013 - Resultado individualizado.pdf”, já a descrição do mínimo esperado para cada um dos documentos solicitados está disponível no anexo²⁶ de n.º 12 deste relatório.

A elaboração de um plano de ação se enquadra nas medidas administrativas de implementação obrigatória por parte dos agentes de tratamento de dados pessoais, citadas no art. 46 da LGPD. Assim, a falta de um documento para nortear as medidas necessárias para se adequar à Lei Geral de Proteção de Dados Pessoais é uma violação à norma, que pode acarretar em diversos prejuízos, como a impossibilidade de identificar as ações prioritárias ou a dificuldade de implantação de uma cultura de proteção dos dados pessoais, por exemplo.

Diante do exposto, o encaminhamento será com sugestão de **determinação** para que os órgãos criem um plano de ação ou documento similar para direcionar o trabalho de adequação à legislação sobre tratamento de dados pessoais, de forma que seja possível a verificação do cumprimento das determinações decorrentes dessa auditoria em futuros monitoramentos.

4.2.4 Causas

²⁶ Anexo: 012 - Requisitos mínimos de documentos solicitados.pdf

- Não investigadas

4.2.5 Efeitos

- Dificuldade em definir ações prioritárias para se adequar à LGPD;
- Dificuldade de avaliar o atingimento de metas e marcos alcançados no processo de conformidade à LGPD.

4.2.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.
 - **DETERMINAÇÃO:** elaborar plano de ação ou documento similar para direcionar a iniciativa de adequação à LGPD que elenque, ao menos, uma série de metas e objetivos, atividades que serão realizadas, seus prazos e os responsáveis por executá-las.
 - **RESPONDERAM NEGATIVAMENTE:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Maricá, Mendes, Miguel Pereira, Miracema, Natividade, Nilópolis, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio das Flores, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São João da Barra, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastião do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim,

Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Varre-Sai, Vassouras e Volta Redonda.

- **RESPONDERAM POSITIVAMENTE, MAS FORAM CONSIDERADOS NEGATIVOS:** Barra do Piraí, Mangaratiba, Mesquita, Niterói e Piraí.
- **RESPONDERAM POSITIVAMENTE, MAS FORAM CONSIDERADOS PARCIAIS:** Rio das Ostras e Valença.

4.3. Achado 03 - Contratos firmados com operadores não estabelecem responsabilidades e papéis com relação à proteção de dados pessoais

4.3.1 Critérios

- Lei Federal nº 13.709/2018, art. 39 e arts. 42-47;
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, item 7.2.6.

4.3.2 Evidências

- Anexo: 005 - Questionário - Respostas.pdf: Respostas ao item B31 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 - LGPD, onde os respondentes afirmam que não houve adequação ou somente adequação parcial dos contratos firmados com os operadores de forma a estabelecer suas responsabilidades e papéis em relação à proteção de dados pessoais.

4.3.3 Situação Encontrada

Para as 25 (vinte e cinco) prefeituras que responderam “sim” ou “parcialmente” à questão B3 (A organização conduziu iniciativa para identificar os operadores que realizam tratamento de dados pessoais em seu nome?), foi realizado o questionamento presente no item B31 (figura 29).

Apenas os Municípios de Mesquita e Cardoso Moreira afirmaram que adequaram todos os contratos firmados com seus operadores. Entre os demais respondentes, 14 (quatorze) afirmaram que não atualizaram nenhum contrato e 9 (nove) informaram que adequaram contratos com alguns dos seus operadores.

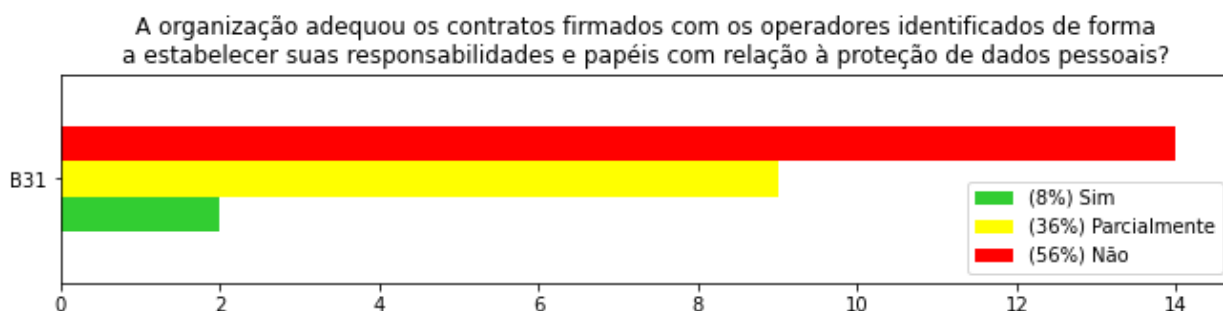


Figura 29: Respostas da questão B31

O artigo 39 da LGPD fixa que o operador deve tratar os dados pessoais de acordo com as instruções fornecidas pelo controlador. Desta forma, se mostra necessário que as responsabilidades do operador de dados pessoais sejam definidas de forma clara e expressa no instrumento contratual que ajusta a obrigação de cada um dos agentes de tratamento envolvidos no acordo. A Norma Técnica ABNT NBR ISO/IEC 27.701/2019, em seu item 7.2.6, sugere:

Convém que a organização tenha um contrato por escrito com qualquer operador de dados pessoais (DP) que ela utilize, e convém assegurar que os seus contratos com os operadores de DP contemplem a implementação de controles apropriados, levando em conta o processo de avaliação de riscos de segurança da informação e o escopo do tratamento de DP realizado pelo operador.

A importância da definição dos papéis e responsabilidades dos operadores pode ser verificada na Seção III da LGPD, que trata da responsabilidade e do ressarcimento de danos, onde o legislador definiu a obrigação de reparação por parte de controladores e operadores em caso de tratamento de dados pessoais que desencadeiem em danos de ordem moral, patrimonial, individual ou coletiva.

O art. 42 reforça a relevância da pactuação das responsabilidades com o operador, o dispositivo estabelece que o tratamento de dados pelo operador sem observar as instruções do controlador é a única hipótese em que o operador responde isoladamente do controlador por danos causados aos titulares dos dados.

Para esse achado o encaminhamento será por **determinação** para que as prefeituras ajustem todos os contratos com os operadores identificados, estabelecendo as responsabilidades sobre proteção de dados pessoais.

4.3.4 Causas

- Não investigadas

4.3.5 Efeitos

- Prejuízo na responsabilização do operador de dados pessoais em caso de violação dos dados.

4.3.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.
 - **DETERMINAÇÃO:** Incluir cláusulas estabelecendo responsabilidades e papéis com relação à proteção de dados pessoais nos próximos contratos firmados com os operadores, contendo, ao menos, as responsabilidades do operador de dados pessoais de forma clara e expressa. Bem como assegurar que os seus contratos com os operadores de dados pessoais contemplem a implementação de controles apropriados, levando em conta o processo de avaliação de riscos de segurança da informação e o escopo do tratamento de dados pessoais realizado pelo operador e também definir a obrigação de reparação por parte de controladores e operadores em caso de tratamento de dados pessoais que desencadeiem em danos de ordem moral, patrimonial, individual ou coletiva. Assim como avaliar a possibilidade de ajustes para inclusão de tais cláusulas nos contratos em vigor.
 - **RESPONDERAM PARCIALMENTE:** Barra do Pirai, Bom Jardim, Bom Jesus do Itabapoana, Cantagalo, Comendador Levy Gasparian, Mangaratiba, Saquarema, Teresópolis e Valença.
 - **RESPONDERAM NEGATIVAMENTE:** Cabo Frio, Campos dos Goytacazes, Casimiro de Abreu, Itaboraí, Maricá, Nova Friburgo, Nova Iguaçu, Pirai,

Quissamã, Rio Claro, Santo Antônio de Pádua, São Gonçalo, São João de Meriti e São José do Vale do Rio Preto.

4.4. Achado 04 - Instrumentos convocatórios em elaboração não estabelecem responsabilidades e papéis dos operadores com relação à proteção de dados pessoais

4.4.1 Critérios

- Lei Federal nº 13.709/2018, art. 39 e arts. 42-47;
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, item 7.2.6.

4.4.2 Evidências

- Anexo: 005 - Questionário - Respostas.pdf: Respostas negativas ao item B32 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 - LGPD, onde os respondentes confirmam que não houve adequação dos instrumentos convocatórios em elaboração, visando estabelecer responsabilidades e papéis dos operadores em relação à proteção de dados pessoais.

4.4.3 Situação Encontrada

Diferente do achado anterior, que identificou os jurisdicionados que não ajustaram os contratos existentes com os operadores de dados, esse achado da auditoria demonstra as prefeituras que ainda não definem, em seus instrumentos convocatórios para futuros contratos com operadores, as responsabilidades e papéis sobre proteção de dados pessoais.

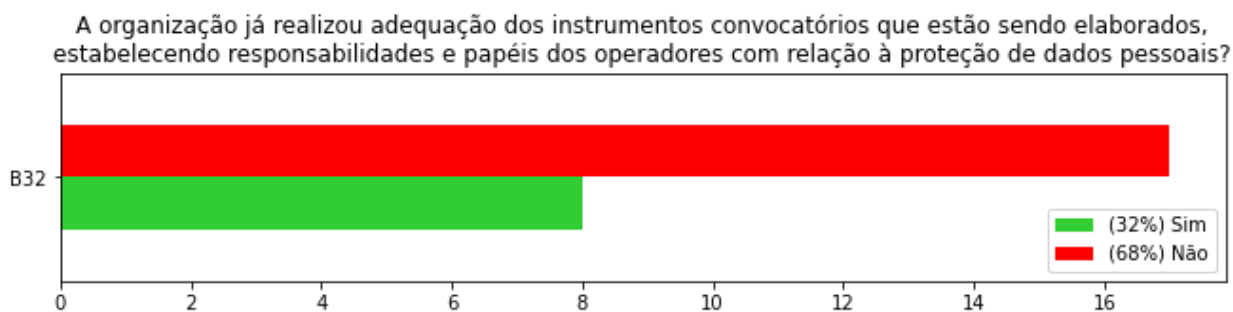


Figura 30: Respostas da questão B32

Conforme as respostas obtidas na questão exibida na figura acima, 8 (oito) prefeituras afirmam que já adequaram seus instrumentos convocatórios para estabelecer responsabilidades e papéis dos operadores em relação à LGPD. Já as outras 17 (dezessete) prefeituras que responderam a essa pergunta, declararam que ainda não ajustaram os instrumentos convocatórios em elaboração.

Percebe-se, portanto, um cenário ligeiramente melhor em relação ao achado anterior, onde apenas 2 (duas) prefeituras afirmaram ter adequado seus contratos em relação às responsabilidades quanto à proteção de dados pessoais.

Diante de todos os motivos já expostos no achado anterior, esse achado da auditoria ensejará em **determinação** para que os entes auditados estabeleçam, em todos os seus instrumentos, os papéis e responsabilidades dos operadores em relação à proteção de dados pessoais, quando couber.

4.4.4 Causas

- Não investigadas

4.4.5 Efeitos

- Execução contratual sem observância aos dispositivos da LGPD;
- Prejuízo na responsabilização do operador de dados pessoais em caso de violação dos dados.

4.4.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.
 - **DETERMINAÇÃO**: adequar os instrumentos convocatórios que estão sendo elaborados e os futuros, estabelecendo responsabilidades e papéis

com relação à proteção de dados pessoais, contendo, ao menos, as responsabilidades do operador de dados pessoais de forma clara e expressa. Bem como assegurar que os instrumentos convocatórios contemplem a implementação de controles apropriados, levando em conta o processo de avaliação de riscos de segurança da informação e o escopo do tratamento de dados pessoais realizado pelo operador e também definir a obrigação de reparação por parte de controladores e operadores em caso de tratamento de dados pessoais que desencadeiem em danos de ordem moral, patrimonial, individual ou coletiva.

- **RESPONDERAM NEGATIVAMENTE:** Barra do Piraí, Cabo Frio, Cantagalo, Casimiro de Abreu, Itaboraí, Mangaratiba, Maricá, Nova Friburgo, Nova Iguaçu, Piraí, Quissamã, Rio Claro, Santo Antônio de Pádua, São Gonçalo, São João de Meriti, São José do Vale do Rio Preto e Valença.

4.5. Achado 05 - Falta de avaliação de existência de controlador conjunto nos tratamentos de dados pessoais

4.5.1 Critérios

- Lei Federal nº 13.709/2018, art. 5º, inciso VI; art. 7º, § 5º; art. 42, inciso II
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, itens 5.2.2 e 7.2.7.

4.5.2 Evidências

- Anexo: 005 - Questionário - Respostas.pdf: Respostas negativas ao item B4 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 - LGPD, onde os respondentes confirmam que não avaliam se há tratamento de dados que envolva controlador conjunto.

4.5.3 Situação Encontrada

Embora a LGPD não conceitue explicitamente a controladoria conjunta, esta forma de composição de controladores de dados pessoais pode ser identificada no art. 42, inciso II, que define que os controladores diretamente envolvidos em tratamento de dados pessoais responderão solidariamente em caso de danos ao titular. Entendimento

também compartilhado pela ANPD, conforme a seção 3 (Controladoria conjunta e singular) do seu Guia orientativo para definições dos agentes de tratamento de dados pessoais e do encarregado²⁷.

Diante da possibilidade de responder solidariamente a danos causados aos titulares dos dados pessoais tratados, é fundamental que órgãos e entidades públicas avaliem se há alguma situação de tratamento de dados envolvendo controlador conjunto. Pois nessas situações, os papéis e responsabilidades de cada controlador devem estar definidas em contrato, seja para respaldar o órgão, ou para assegurar que os demais controladores empenhem os mesmos esforços e controles necessários visando proteção à privacidade dos titulares dos dados.

Para avaliar o grau de adequação dos jurisdicionados a este tema, foi elaborada a questão abaixo, onde ficou constatado que apenas 7 (sete) das 91 (noventa e uma) prefeituras municipais auditadas realizaram alguma iniciativa para verificar se possuem controlador conjunto.

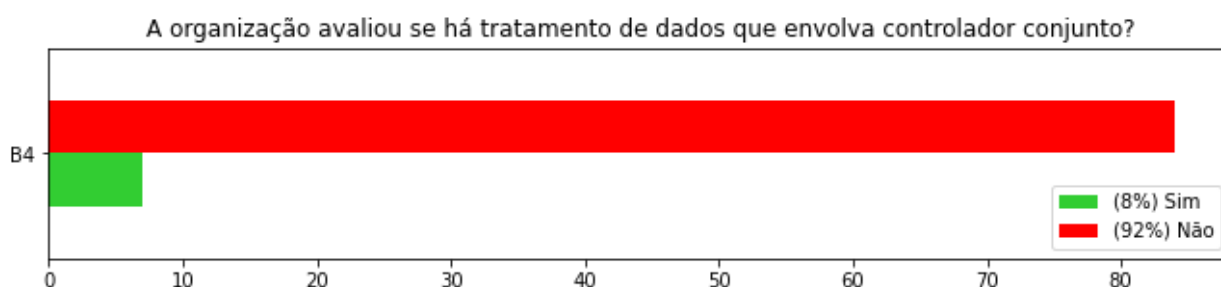


Figura 31: Respostas da questão B4

Em razão da falta de avaliação da existência de controlador conjunto evidenciada acima, haverá sugestão de **determinação** para que os jurisdicionados efetuem essa verificação, de forma a evitar que respondam solidariamente a dano causado a terceiros por algum controlador conjunto.

4.5.4 Causas

- Não investigadas

4.5.5 Efeitos

²⁷ Disponível em: <https://www.gov.br/anpd/pt-br/documentos-e-publicacoes/Segunda_Versao_do_Guia_de_Agentes_de_Tratamento_retificada.pdf>. Acesso em 13/06/2022.

- Prejuízo na identificação dos responsáveis pelo tratamento de dados pessoais e a sua consequente responsabilização em caso de violação dos dados.

4.5.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.
 - **DETERMINAÇÃO:** avaliar se há tratamento de dados que envolva controlador conjunto e caso exista, definir os papéis e responsabilidades de cada controlador conjunto identificado em contrato, acordo de cooperação ou instrumento similar.
 - **RESPONDERAM NEGATIVAMENTE:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra do Pirai, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Carapebus, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Mesquita, Miguel Pereira, Miracema, Natividade, Niterói, Nova Friburgo, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pinheiral, Piraí, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São João da Barra, São João de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastião do Alto, Sapucaia, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Varre-Sai, Vassouras e Volta Redonda.

4.6. Achado 06 - Papéis e responsabilidades de cada controlador conjunto identificado não estão definidos em contrato, acordo de cooperação ou instrumento similar

4.6.1 Critérios

- Lei Federal nº 13.709/2018, arts. 42-45;
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, item 7.2.7.

4.6.2 Evidências

- Anexo: 005 - Questionário - Respostas.pdf: Respostas ao item B41 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 - LGPD, onde os respondentes afirmam que os papéis e responsabilidades de cada um dos controladores não estão definidos em contrato, acordo de cooperação ou instrumento similar.

4.6.3 Situação Encontrada

Para as 7 (sete) prefeituras que já avaliaram a existência de tratamento de dados pessoais com controlador conjunto, foi feito um questionamento (figura 32) para verificar se a avaliação confirmou a presença de controlador conjunto em suas operações de dados pessoais, e se estas operações estão respaldadas por instrumento contratual, estabelecendo os papéis e responsabilidades de cada um dos controladores.

A prefeitura de Cantagalo informou que não possui tratamento de dados pessoais que envolva controlador conjunto. Das 6 (seis) que confirmaram a existência de controlador conjunto, apenas a Prefeitura de Cardoso Moreira afirma ter definido em contrato as responsabilidades e papéis entre ela e os controladores conjuntos.

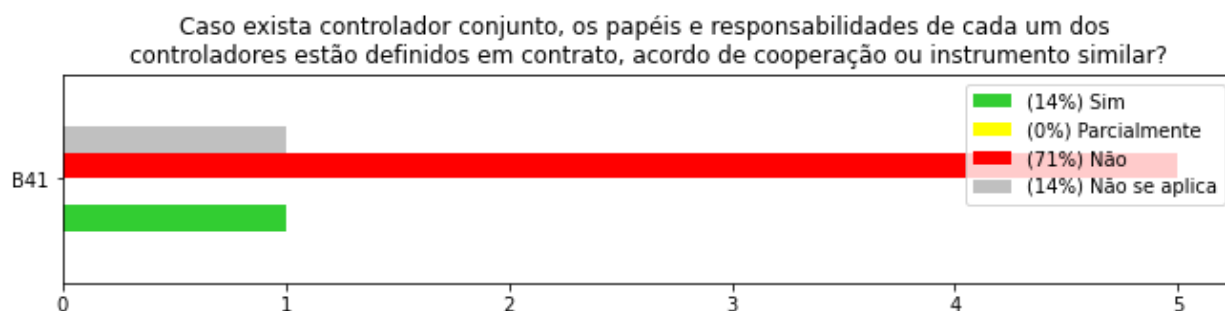


Figura 32: Respostas da questão B41

A definição, em contrato, de papéis e responsabilidades dos controladores conjuntos é de suma importância diante do que já foi exposto na situação encontrada do achado 03. Ressalta-se que, segundo o art. 39 da LGPD, o tratamento de dados deve ser realizado de acordo com instruções fornecidas pelos controladores, e a ausência dessa pactuação em instrumento contratual configura violação à norma.

Destarte, o encaminhamento será por **determinação** para que as 5 (cinco) prefeituras que ainda não definiram as responsabilidades dos controladores conjuntos, o façam por intermédio de instrumento contratual.

4.6.4 Causas

- Não investigadas

4.6.5 Efeitos

- Prejuízo na responsabilização de cada controlador conjunto em caso de violação dos dados.

4.6.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.

- **DETERMINAÇÃO:** definir os papéis e responsabilidades de cada controlador conjunto identificado em contrato, acordo de cooperação ou instrumento similar.
- **RESPONDERAM NEGATIVAMENTE:** Nova Iguaçu, Nilópolis, São Gonçalo, Saquarema e Valença.

4.7. Achado 07 - Não identificação de todos os dados pessoais tratados

4.7.1 Critérios

- Lei Federal nº 13.709/2018, arts. 37 e 5º, inciso I;
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, itens 6.5.2 e 7.2.8.

4.7.2 Evidências

- Anexo: 005 - Questionário - Respostas.pdf: Respostas ao item B6 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 - LGPD, onde os respondentes confirmam que não foi realizada identificação ou só foi feita identificação parcial dos dados pessoais tratados.

4.7.3 Situação Encontrada

O artigo 37 da LGPD determina que todas as operações envolvendo tratamento de dados pessoais devem ser registradas e mantidas por controladores e operadores. Para isso, o primeiro passo é a identificação de quais dados pessoais são tratados pelo órgão. Somente com o um mapeamento completo e pormenorizado dos dados pessoais custodiados será possível verificar e armazenar as ocorrências de manipulação destes dados.

A ABNT NBR ISO/IEC 27.701/2019 (item 7.2.8), apresenta diretrizes para auxiliar a cumprir essa obrigação legal:

Uma maneira de manter os registros de tratamento do DP é ter um inventário ou uma lista das atividades de tratamento do DP que a organização realiza. Esta lista de inventário pode incluir:

- tipo de tratamento;
- propósitos para o tratamento;

- uma descrição das categorias de DP e dos titulares de DP (por exemplo, crianças);
- as categorias de destinatário para quem o DP tem sido ou será divulgado, incluindo os destinatários em outros países ou organizações internacionais;
- uma descrição geral das medidas de segurança técnica e organizacional;
- um relatório de Avaliação de Impacto de Privacidade.

A questão B6 avaliou se os órgãos auditados estão aderentes ao art. 37 da LGPD, tendo em vista que a ausência de identificação total dos dados pessoais tratados constitui violação do dispositivo supracitado.

Conforme pode ser observado na figura abaixo, somente 4 (quatro) prefeituras já identificaram todos os dados pessoais em que realizam tratamento, 27 (vinte e sete) informaram que alguns dados foram identificados e 60 (sessenta) declararam que não realizaram esse levantamento.

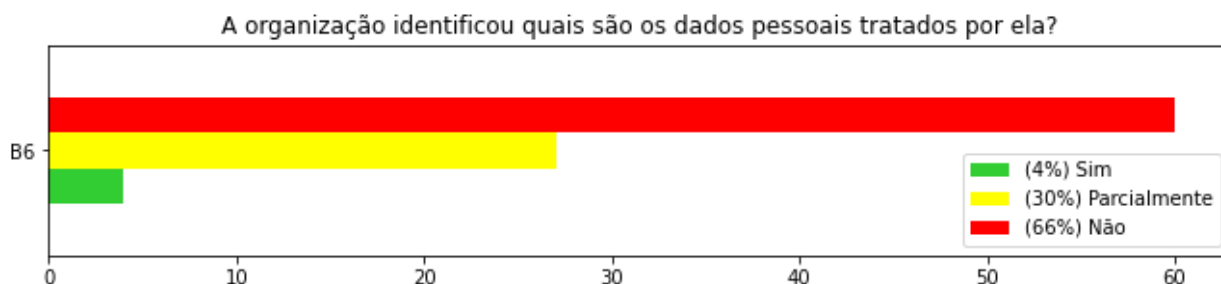


Figura 33: Respostas à questão B6

O encaminhamento desse achado será também uma **determinação**, desta vez, para que os órgãos identifiquem todos os dados pessoais tratados.

4.7.4 Causas

- Não investigadas

4.7.5 Efeitos

- Impossibilidade de atendimento de direitos dos titulares em virtude da não identificação de dados pessoais;
- Prejuízo na proteção da privacidade no tratamento dos dados pessoais que não foram identificados.

4.7.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.
 - **DETERMINAÇÃO:** identificar todos os dados pessoais tratados pela organização, efetuando um mapeamento completo e pormenorizado dos dados pessoais custodiados para verificar e armazenar as ocorrências de manipulação destes dados, além de mantê-los registrados por meio de inventário.
 - **RESPONDERAM PARCIALMENTE:** Angra dos Reis, Belford Roxo, Bom Jesus do Itabapoana, Cabo Frio, Campos dos Goytacazes, Cantagalo, Casimiro de Abreu, Comendador Levy Gasparian, Iguaba Grande, Itaboraí, Macaé, Mangaratiba, Nova Friburgo, Nova Iguaçu, Pinheiral, Pirai, Quissamã, Rio Bonito, Rio Claro, São Fidélis, São Gonçalo, São João de Meriti, São José do Vale do Rio Preto, Valença, Saquarema, Tanguá e Teresópolis.
 - **RESPONDERAM NEGATIVAMENTE:** Aperibé, Araruama, Areal, Armação de Búzios, Barra do Piraí, Barra Mansa, Bom Jardim, Cachoeiras de Macacu, Cambuci, Carapebus, Carmo, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macuco, Magé, Maricá, Mendes, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Porciúncula, Porto Real, Quatis, Resende, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Francisco de Itabapoana, São João da Barra, São José de Ubá, São Pedro da Aldeia, São Sebastiao do Alto, Sapucaia, Seropédica, Silva Jardim, Sumidouro, Trajano de Moraes, Três Rios, Varre-Sai, Vassouras e Volta Redonda.

4.8. Achado 08 - Ausência de Política de Segurança da Informação

4.8.1 Critérios

- Lei Federal nº 13.709/2018, arts. 46-49; art. 50, § 2º, inciso I, alíneas “a” e “d”.
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, itens 5.3.2 e 6.2;
- Acórdão 14.109/2021 do Tribunal de Contas do Estado do Rio de Janeiro, Decisão Plenária de 08/05/2018.

4.8.2 Evidências

- Anexo: 005 - Questionário - Respostas.pdf: Respostas negativas ao item C1 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 - LGPD, onde os respondentes afirmam que não há uma Política de Segurança da Informação ou Instrumento similar do órgão;
- Anexo: 006 - Questionário - Respostas - Anexos.zip\Duque de Caxias\00033_01_cartilha-de-seguranca-da-informacao.pdf: Documento anexado que não cumpriu o mínimo esperado para a Política de Segurança da Informação;
- Anexo: 006 - Questionário - Respostas - Anexos.zip\Itaboraí\00082_01_decreto-municipal-15-2020.pdf: Documento anexado que não cumpriu o mínimo esperado para a Política de Segurança da Informação;
- Anexo: 006 - Questionário - Respostas - Anexos.zip\Saquarema\00054_01_arquivo-resposta-c11-1.pdf: Documento anexado que não cumpriu o mínimo esperado para a Política de Segurança da Informação;
- Anexo: 006 - Questionário - Respostas - Anexos.zip\Valença\00087_02_decreto-088-2021-regulamenta-lgpd.pdf: Documento anexado que não cumpriu o mínimo esperado para a Política de Segurança da Informação.

4.8.3 Situação Encontrada

A Política de Segurança da Informação (PSI) é de grande relevância para as prefeituras, uma vez que tem a finalidade de nortear os órgãos em relação aos seus objetivos de segurança da informação. Para isso, convém que a PSI contemple os requisitos oriundos (i) da estratégia do negócio; (ii) de regulamentações, legislação e contratos; (iii) do ambiente de ameaça da segurança da informação, atual e futuro.

É esperado também que a PSI contenha declarações relativas (i) a definição da segurança da informação, objetivos e princípios para orientar todas as atividades

relativas à segurança da informação; (ii) a atribuição de responsabilidades, gerais e específicas, para o gerenciamento da segurança da informação para os papéis definidos; (iii) aos processos para o tratamento dos desvios e exceções.

A Norma Técnica ABNT NBR ISO/IEC 27.701/2019, em sua seção 6.2 – políticas de segurança da informação, recomenda para qualquer organização que trate dados pessoais, seja controlador ou operador, que seja considerada a regulamentação e/ou legislação de proteção de dados pessoais aplicável, durante o desenvolvimento e a manutenção de políticas de segurança da informação.

O item C1 do questionário buscou verificar se os órgãos elaboraram uma Política de Segurança da Informação ou instrumento similar. Para este item era obrigatório o envio de arquivo para comprovar a existência do documento.

Apenas 9 (nove) prefeituras informaram que possuíam PSI ou instrumento similar. E mesmo assim, após análise, pela Equipe de Auditoria, dos documentos enviados, foi verificado que somente as Prefeituras de Miguel Pereira, Paracambi, Piraí, Rio das Ostras e Volta Redonda conseguiram comprovar a existência do documento contendo pelo menos um subconjunto das seguintes características listadas: uma orientação e apoio da direção do órgão sobre a segurança da informação, alinhando-se de acordo com os requisitos de negócio e com as leis e regulamentações relevantes; declarações acerca dos objetivos e princípios a serem usados para orientar todas as atividades relativas à segurança da informação, possuindo a atribuição de papéis e responsabilidades e um processo para tratamento dos desvios e exceções; abordagem de tópicos específicos como controle de acesso aos sistemas, classificação e tratamento da informação, segurança física e lógica do ambiente, *backup* de dados, controles criptográficos etc.

Um bom exemplo de Política de Segurança da Informação foi o enviado pela Prefeitura de Piraí²⁸, que abrange boa parte das características requisitadas.

Diante da análise empreendida, ficou constatado que os documentos enviados pelas Prefeituras de Duque de Caxias, Itaboraí e Valença não se tratavam de uma Política de Segurança da Informação, desta forma foi considerada como negativa a resposta desses jurisdicionados ao item.

²⁸ Anexo: 006 - Questionário - Respostas - Anexos.zip\Piraí\ 00029_02_pstic-pol-tica-de-segurança-de-tecnologia-informação-e-comunicação-versão-1.1-11-02-2022.pdf

Já o documento enviado pela Prefeitura de Saquarema atendeu parcialmente ao que se espera da Política de Segurança da Informação, portanto, a resposta afirmativa desse jurisdicionado ao item C1 foi convertida para “parcialmente”.

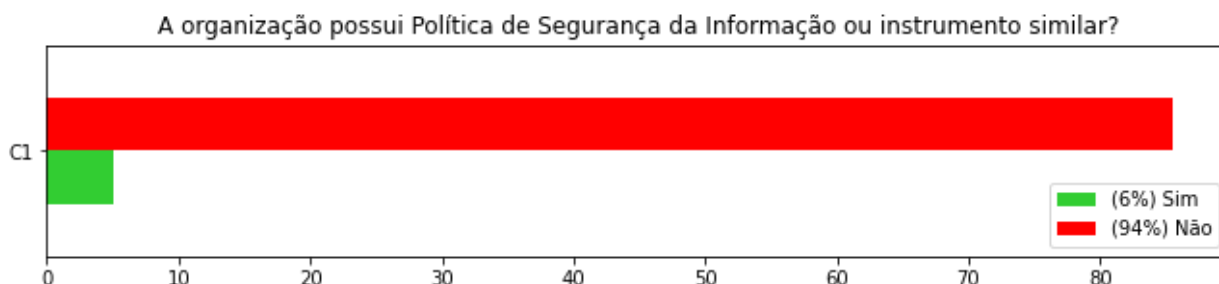


Figura 34: Respostas da questão C1

Ao não criar a Política de Segurança da Informação, os órgãos contrariam o que foi decidido em Decisão Plenária do dia 08/05/2018 desta Corte de Contas (Processo TCE-RJ nº 212.981-7/2017), *in verbis*:

VOTO:

(...)

VII – pela COMUNICAÇÃO, nos termos do § 1º do art. 6º da Deliberação TCE-RJ nº 204/96, ao atual Prefeito Municipal de Nova Friburgo, a fim de que:

a) cumpra as DETERMINAÇÕES a seguir, comprovando as medidas adotadas junto a este Tribunal:

(...)

2 - **Elaborar e divulgar a Política de Segurança da Informação** da administração municipal, consoante o previsto no item 5.1.1 da Norma NBR ISO/IEC 27002:2005 (achado 2).

(grifos e negritos nossos)

Diante do exposto, o encaminhamento será com sugestão de **determinação** para que os órgãos criem uma Política de Segurança da Informação, de forma que seja possível que esta Corte de Contas verifique, em futuros monitoramentos, o cumprimento de suas determinações decorrentes dessa auditoria.

4.8.4 Causas

- Não investigadas

4.8.5 Efeitos

- Prejuízo na segurança da informação da organização podendo causar danos financeiros e de imagem;
- Dificuldade de implantação de uma cultura organizacional de segurança da informação.

4.8.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.
 - **DETERMINAÇÃO:** elaborar a Política de Segurança da Informação contendo, ao menos, um subconjunto das seguintes características: orientação e apoio da direção do órgão sobre a segurança da informação, alinhando-se de acordo com os requisitos de negócio e com as leis e regulamentações relevantes; declarações acerca dos objetivos e princípios a serem usados para orientar todas as atividades relativas à segurança da informação; atribuição de papéis e responsabilidades e um processo para tratamento dos desvios e exceções; tópicos específicos como controle de acesso aos sistemas, classificação e tratamento da informação, segurança física e lógica do ambiente, backup de dados e controles criptográficos.
 - **RESPONDERAM NEGATIVAMENTE:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra do Piraí, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Mesquita, Miracema, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paraíba do Sul, Paraty, Paty do

Alferes, Petrópolis, Pinheiral, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São João da Barra, São João de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastião do Alto, Sapucaia, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Varre-sai e Vassouras.

- **RESPONDERAM POSITIVAMENTE, MAS FORAM CONSIDERADAS NEGATIVAS:** Duque de Caxias, Itaboraí e Valença.
- **RESPONDEU POSITIVAMENTE, MAS FOI CONSIDERADA PARCIAL:** Saquarema.

4.9. Achado 09 - Ausência de Política de Classificação da Informação

4.9.1 Critérios

- Lei Federal nº 13.709/2018, art. 14; arts. 46-49; art. 50, parágrafo 2º, inciso I, alíneas “a” e “d”;
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, itens 6.5.2 e 6.5.2.2.

4.9.2 Evidências

- Anexo: 005 - Questionário - Respostas.pdf: Respostas negativas ao item C2 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 - LGPD, onde os respondentes afirmam que não há Política de Classificação da Informação ou instrumento similar do órgão;
- Anexo: 006 - Questionário - Respostas - Anexos.zip\Itaboraí\00082_02_decreto-municipal-15-2020.pdf: Documento anexado que não cumpriu o mínimo esperado para a Política de Classificação da Informação;
- Anexo: 006 - Questionário - Respostas - Anexos.zip\Natividade\00088_01_decreto-098-2017-regulamenta-a-lai.pdf: Documento anexado que não cumpriu o mínimo esperado para a Política de Classificação da Informação;
- Anexo: 006 - Questionário - Respostas - Anexos.zip\Nova Iguaçu\00023_01_lei-4413-2014-ealterações.pdf: Documento anexado que não cumpriu o mínimo esperado para a Política de Classificação da Informação.

4.9.3 Situação Encontrada

A Política de Classificação da Informação é bastante relevante para os jurisdicionados, uma vez que tem o objetivo de assegurar que a informação receba um nível adequado de proteção, de acordo com a sua importância para o órgão. Espera-se que a informação seja classificada em termos do seu valor, requisitos legais, sensibilidade e criticidade para evitar modificação ou divulgação não autorizada.

O item C2 do questionário buscou verificar se os órgãos elaboraram uma Política de Classificação da Informação ou instrumento similar. Para este item era obrigatório o envio de arquivo para comprovar a existência do documento.

Apenas 3 (três) prefeituras informaram que possuíam uma Política de Classificação da Informação ou instrumento similar. E mesmo assim, após análise pela Equipe de Auditoria dos documentos enviados pelos jurisdicionados, foi verificado que nenhuma prefeitura conseguiu comprovar a existência do documento contendo pelo menos um conjunto de papéis, responsabilidades, critérios e rótulos para a classificação da informação do órgão.

Diante da análise empreendida, ficou constatado que os documentos enviados pelas Prefeituras de Itaboraí, Natividade e Nova Iguaçu atenderam parcialmente ao que se espera da Política de Classificação da Informação, portanto, as respostas afirmativas desses jurisdicionados ao item C2 foram convertidas para “parcialmente”.

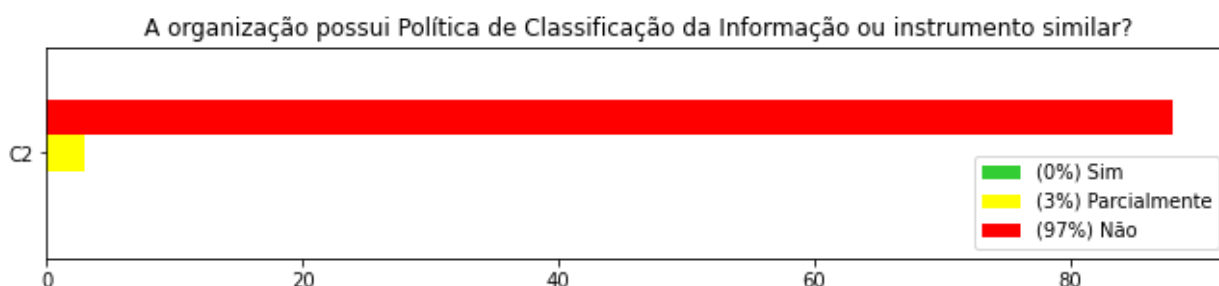


Figura 35: Respostas da questão C2

Ao não criar a Política de Classificação da Informação, o jurisdicionado desconsidera uma boa prática prevista na Norma Técnica ABNT NBR ISO/IEC 27.701/2019, item 6.5.2 – classificação da informação, que recomenda que o sistema de classificação da informação deve considerar explicitamente dados pessoais como parte do esquema que ela implementa. E que considerar o dado pessoal dentro de todo o

sistema de classificação é importante para entender qual dado pessoal a organização trata, onde tal dado pessoal é armazenado e os sistemas pelos quais ele pode fluir.

Diante do exposto, o encaminhamento será com sugestão de **determinação** para que os órgãos criem uma Política de Classificação da Informação.

4.9.4 Causas

- Não investigadas

4.9.5 Efeitos

- Prejuízo na escolha de qual informação terá maior prioridade de proteção e de investimento de recursos.

4.9.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.
 - **DETERMINAÇÃO:** elaborar a Política de Classificação da Informação incluindo diretrizes acerca de dados pessoais, dados pessoais sensíveis e dados pessoais de crianças e adolescentes, quando couber, contendo, ao menos, um conjunto de papéis, responsabilidades, critérios e rótulos para a classificação da informação do órgão.
 - **RESPONDERAM NEGATIVAMENTE:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra do Piraí, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Mesquita,

Miguel Pereira, Miracema, Nilópolis, Niterói, Nova Friburgo, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pinheiral, Piraí, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São João da Barra, São João de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastião do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Valença, Varre-sai, Vassouras e Volta Redonda.

- **RESPONDERAM POSITIVAMENTE, MAS FORAM CONSIDERADAS PARCIAIS:** Itaboraí, Natividade e Nova Iguaçu.

4.10. Achado 10 - Ausência de nomeação de encarregado de dados

4.10.1 Critérios

- Lei Federal nº 13.709/2018, art. 5º, inciso VIII; art. 23, inciso III; art. 41;
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, item 6.3.1.

4.10.2 Evidências

- Anexo: 005 - Questionário - Respostas.pdf: Respostas negativas ao item C4 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 - LGPD, onde os respondentes confirmam que não há nomeação de encarregado de dados.

4.10.3 Situação Encontrada

De acordo com artigo 41, parágrafo 2º, da LGPD o encarregado de dados tem o importante papel de fomentar e disseminar a cultura da proteção de dados pessoais na organização, como, por exemplo, ao orientar funcionários e contratados a respeito das práticas a serem tomadas em relação à proteção de dados pessoais. Outra responsabilidade de destaque atribuída ao encarregado de dados é a recepção de solicitações de titulares e da autoridade nacional de proteção de dados e posterior adoção das devidas providências. Ele ainda possui a obrigação de executar as demais

atribuições determinadas pelo controlador ou estabelecidas em normas complementares.

O item C4 do questionário buscou verificar se os órgãos nomearam o encarregado pelo tratamento de dados pessoais. Apenas as Prefeituras de Mesquita, Nova Friburgo, Pinheiral e Valença nomearam o encarregado de dados.

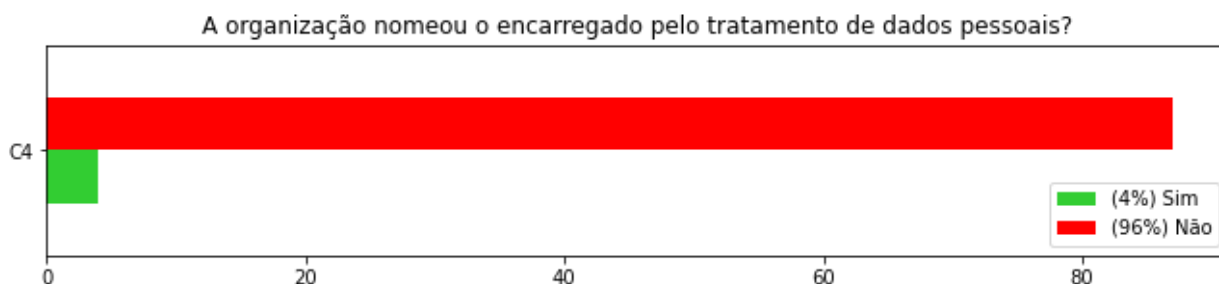


Figura 36: Respostas da questão C4

A LGPD em seu artigo 23, inciso III cita que:

Art.23. O tratamento de dados pessoais pelas pessoas jurídicas de direito público referidas no parágrafo único do artigo 1º da Lei nº 12527/2011 (Lei de Acesso à Informação), deverá ser realizado para o atendimento de sua finalidade pública, na persecução do interesse público, com o objetivo de executar as competências legais ou cumprir as atribuições legais do serviço público, desde que:

III - seja indicado um encarregado quando realizarem operações de tratamento de dados pessoais

Além disso, a LGPD em seu artigo 41 menciona que “O controlador deverá indicar encarregado pelo tratamento de dados pessoais”. Ou seja, é cristalino que a legislação exige que os órgãos façam a nomeação do encarregado de dados. Além disso, a Autoridade Nacional de Proteção de Dados (ANPD) por meio de seu Guia Orientativo²⁹ afirma que:

Ao contrário de outras legislações de proteção de dados estrangeiras, a LGPD não determinou em que circunstâncias uma organização deve indicar um encarregado. Assim, deve-se assumir, como regra geral, que toda organização deverá indicar uma pessoa para assumir esse papel.

²⁹ Guia Orientativo para Definições dos Agentes de Tratamento de Dados Pessoais e do Encarregado, Página 23, Item 71. Disponível em:

<https://www.gov.br/anpd/pt-br/documentos-e-publicacoes/Segunda_Versao_do_Guia_de_Agentes_de_Tratamento_retificada.pdf>
Acesso em 13/06/2022.

Diante do exposto, o encaminhamento será de **determinação** para que os órgãos que responderam negativamente ao item C4 do questionário nomeiem o encarregado de dados e publiquem as informações na internet, de forma que seja possível que esta Corte de Contas verifique, em futuros monitoramentos, o cumprimento de suas determinações decorrentes dessa auditoria.

4.10.4 Causas

- Não investigadas

4.10.5 Efeitos

- Impossibilidade de os titulares de dados exercerem os direitos assegurados pela LGPD;
- Prejuízo no fomento e disseminação da cultura de proteção de dados pessoais na organização;
- Prejuízo no recebimento de solicitações de titulares de dados e na comunicação com a ANPD.

4.10.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.
 - **DETERMINAÇÃO:** nomear o encarregado de dados pessoais da organização, publicar a nomeação em veículo oficial e divulgar as informações de contato do encarregado em local de fácil acesso no sítio eletrônico da organização.
 - **RESPONDERAM NEGATIVAMENTE:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra do Piraí, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu,

Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Piraí, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São João da Barra, São João de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastião do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Varre-sai, Vassouras e Volta Redonda.

4.11. Achado 11 - Informações do encarregado de dados não disponíveis no sítio eletrônico do órgão

4.11.1 Critérios

- Lei Federal nº 13.709/2018, artigo 5º, inciso VIII; artigo 6º, inciso VI; artigo 41, parágrafo 1º;
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, item 6.3.1;
- Constituição Federal, artigo 37, princípio da publicidade.

4.11.2 Evidências

- Anexo: 005 - Questionário - Respostas.pdf: Respostas negativas ao item C43 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 - LGPD, onde os respondentes confirmam que não há a divulgação da identidade e das informações de contato do encarregado de dados na internet.

4.11.3 Situação Encontrada

Para as 4 (quatro) prefeituras que responderam “sim” à questão C4 (A organização nomeou o encarregado pelo tratamento de dados pessoais?), foi realizado

o seguinte questionamento na questão C43: A identidade e as informações de contato do encarregado foram divulgadas na internet?

Apenas os Municípios de Mesquita e Valença afirmaram que divulgaram a identidade e as informações de contato do encarregado de dados na internet. Já as Prefeituras de Pinheiral e Nova Friburgo afirmaram que não houve divulgação.

O artigo 41, parágrafo 1º da LGPD diz que “A identidade e as informações de contato do encarregado deverão ser divulgadas publicamente, de forma clara e objetiva, preferencialmente no sítio eletrônico do controlador.” Além disso, a Constituição Federal traz no artigo 37 que a Administração Pública deve seguir o princípio da Publicidade.

Pelos motivos supracitados, o encaminhamento será de **determinação** para que as Prefeituras de Pinheiral e Nova Friburgo publiquem a identidade e as informações de contato do encarregado de dados na internet, de forma que seja possível que esta Corte de Contas verifique, em futuros monitoramentos, o cumprimento de suas determinações decorrentes dessa auditoria.

4.11.4 Causas

- Não investigadas

4.11.5 Efeitos

- Impossibilidade de acesso ao encarregado caso seja necessário entrar em contato com o mesmo.

4.11.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.

- **DETERMINAÇÃO:** divulgar no sítio eletrônico da organização, em local de fácil acesso, a identidade e as informações de contato do encarregado de dados.
- **RESPONDERAM NEGATIVAMENTE:** Nova Friburgo e Pinheiral.

4.12. Achado 12 - Não identificação das finalidades para as atividades de tratamento de dados

4.12.1 Critérios

- Lei Federal nº 13.709/2018, art. 6º, inciso I, art. 9º, inciso I, art. 23, inciso I;
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, item 7.2.1.

4.12.2 Evidências

- Anexo: 005 – Questionário – Respostas.pdf: Respostas ao item E1 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 – LGPD, onde os respondentes afirmam que não houve identificação ou somente identificaram parcialmente as finalidades das atividades de tratamento de dados pessoais.

4.12.3 Situação Encontrada

A questão E1 buscava verificar se os jurisdicionados identificaram e documentaram as finalidades das atividades de tratamento de dados pessoais. Nenhuma prefeitura respondeu que identificou e documentou todas as finalidades das atividades, 13 (treze) prefeituras responderam que identificaram e documentaram parcialmente as finalidades e 78 (setenta e oito) prefeituras responderam que ainda não identificaram e documentaram as finalidades.

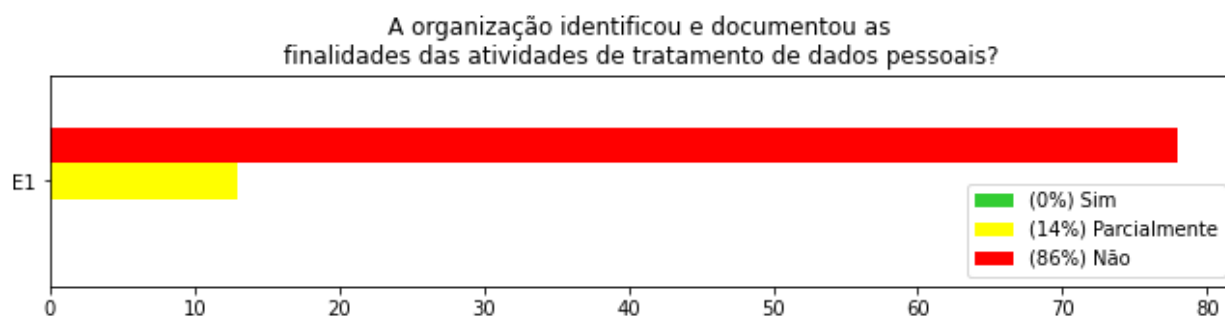


Figura 37: Respostas da questão E1

A identificação e documentação das finalidades das atividades de tratamento de dados pessoais é de suma importância, conforme artigo 9º, inciso I, da LGPD:

O titular tem direito ao acesso facilitado às informações sobre o tratamento de seus dados, que deverão ser disponibilizadas de forma clara, adequada e ostensiva acerca de, entre outras características previstas em regulamentação para o atendimento do princípio do livre acesso: I - finalidade específica do tratamento.

O artigo 23, inciso I, da LGPD também preconiza que:

Sejam informadas as hipóteses em que se realiza o tratamento de dados pessoais, fornecendo informações claras e atualizadas sobre a previsão legal, a finalidade, os procedimentos e as práticas utilizadas para a execução dessas atividades, em veículos de fácil acesso, preferencialmente em seus sítios eletrônicos.

Pelos motivos supracitados, as respostas negativas ou parciais à questão E1 serão objeto de **determinação** na proposta de encaminhamento deste relatório.

4.12.4 Causas

- Não investigadas

4.12.5 Efeitos

- Tratamento de dados para finalidade diversa da esperada pelo titular dos dados;
- Prejuízo na identificação da melhor estratégia para o tratamento dos dados.

4.12.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a

DETERMINAÇÃO a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.

- **DETERMINAÇÃO:** documentar e divulgar, no sítio eletrônico do órgão, preferencialmente, na mesma página de divulgação do contato do encarregado de dados, as finalidades de todas as atividades de tratamento de dados pessoais realizadas pelo órgão, bem como coletar e reter os dados estritamente necessários e pelo tempo necessário para cumprir com as finalidades.
- **RESPONDERAM PARCIALMENTE:** Barra do Piraí, Belford Roxo, Bom Jesus do Itabapoana, Cabo Frio, Campos dos Goytacazes, Cantagalo, Itaboraí, Mangaratiba, Nova Friburgo, Paty do Alferes, Piraí, São Gonçalo e Valença.
- **RESPONDERAM NEGATIVAMENTE:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra Mansa, Bom Jardim, Cachoeiras de Macacu, Cambuci, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Maricá, Mendes, Mesquita, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Petrópolis, Pinheiral, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São João da Barra, São João de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastião do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Varre-sai, Vassouras e Volta Redonda.

4.13. Achado 13 - Falta de avaliação sobre os dados pessoais coletados para identificar se são armazenados apenas os dados estritamente necessários para cumprir com as finalidades de tratamento de dados pessoais realizados

4.13.1 Critérios

- Lei Federal nº 13.709/2018, art. 6º, incisos II e III, art. 10, parágrafo 1º, art. 26;
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, item 7.4.1.

4.13.2 Evidências

- Anexo: 005 – Questionário – Respostas.pdf: Respostas negativas ao item E11 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 – LGPD, onde os respondentes afirmam que não avaliam se são coletados os dados estritamente necessários para cumprir com as finalidades de tratamento de dados pessoais.

4.13.3 Situação Encontrada

Para as 13 (treze) prefeituras que responderam “parcialmente” à questão E1 (A organização identificou e documentou as finalidades das atividades de tratamento de dados pessoais?), foi realizado o seguinte questionamento na questão E11: A organização avaliou se coleta apenas os dados estritamente necessários para cumprir com as finalidades de tratamento de dados pessoais que foram identificadas?

Dessas 13 (treze) prefeituras, 5 (cinco) responderam que avaliaram se coletam apenas os dados estritamente necessários para cumprir com as finalidades de tratamento de dados pessoais identificados e 8 (oito) responderam que não avaliaram.

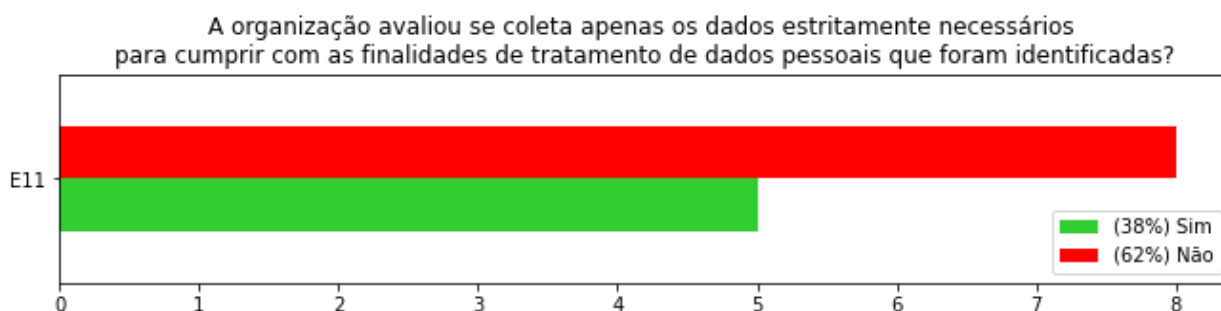


Figura 38: Respostas da questão E11

A coleta dos dados estritamente necessários é de suma importância, tal fato é corroborado pelo artigo 10, parágrafo 1º da LGPD: “Quando o tratamento for baseado no legítimo interesse do controlador, somente os dados pessoais estritamente necessários para a finalidade pretendida poderão ser tratados”.

Além disso, conforme art. 7º, § 6º, da LGPD a dispensa da exigência de consentimento pela administração pública para tratamento de dados pessoais necessários para a execução de políticas públicas não isenta a administração das demais obrigações previstas na LGPD, devendo garantir todos os direitos dos titulares dos dados.

Pelos motivos expostos, as respostas negativas à questão E11 serão objeto de **determinação** na proposta de encaminhamento deste relatório.

4.13.4 Causas

- Não investigadas

4.13.5 Efeitos

- Coleta e armazenamento de dados pessoais excessivos e desnecessários ao tratamento de dados.

4.13.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou

esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.

- **DETERMINAÇÃO:** verificar se coleta apenas os dados estritamente necessários para cumprir com as finalidades de tratamento de dados pessoais realizados pela organização.
- **RESPONDERAM NEGATIVAMENTE:** Barra do Piraí, Belford Roxo, Cabo Frio, Cantagalo, Mangaratiba, Nova Friburgo, Piraí e São Gonçalo.

4.14. Achado 14 - Falta de avaliação para verificar se os dados pessoais são retidos durante o tempo estritamente necessário para cumprir com as finalidades de tratamento de dados pessoais

4.14.1 Critérios

- Lei Federal nº 13.709/2018, art. 16 e 40;
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, item 7.4.7.

4.14.2 Evidências

- Anexo: 005 – Questionário – Respostas.pdf: Respostas negativas ao item E12 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 – LGPD, onde os respondentes afirmam que não avaliam se os dados pessoais são retidos durante o tempo estritamente necessário para cumprir com as finalidades de tratamento de dados pessoais.

4.14.3 Situação Encontrada

Para as 13 (treze) prefeituras que responderam “parcialmente” à questão E1 (A organização identificou e documentou as finalidades das atividades de tratamento de dados pessoais?), foi realizado o seguinte questionamento na questão E12: A organização avaliou se os dados pessoais são retidos (armazenados) durante o tempo estritamente necessário para cumprir com as finalidades de tratamento de dados pessoais que foram identificadas?

Dessas 13 (treze), apenas as prefeituras de Campos dos Goytacazes e Cantagalo responderam que avaliaram se os dados pessoais são retidos durante o tempo estritamente necessário e 11 (onze) responderam que não avaliaram.

A organização avaliou se os dados pessoais são retidos (armazenados) durante o tempo estritamente necessário para cumprir com as finalidades de tratamento de dados pessoais que foram identificadas?

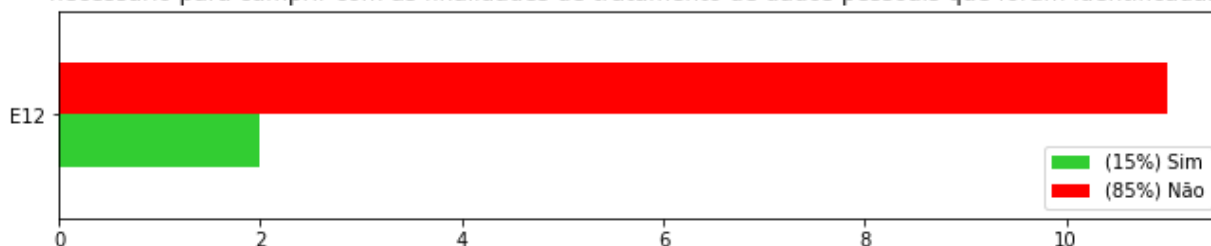


Figura 39: Respostas da questão E12

A retenção e armazenamento dos dados pessoais durante o tempo estritamente necessário é fundamental, tal fato é ratificado pelo artigo 16 da LGPD que menciona o seguinte: “Os dados pessoais serão eliminados após o término de seu tratamento, no âmbito e nos limites técnicos das atividades.”

Pelo motivo supracitado, as respostas negativas à questão E12 serão objeto de **determinação** na proposta de encaminhamento deste relatório.

4.14.4 Causas

- Não investigadas

4.14.5 Efeitos

- Armazenamento de dados pessoais por tempo além do necessário ao tratamento de dados.

4.14.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.

- **DETERMINAÇÃO:** avaliar se os dados pessoais são retidos, e caso seja, reter durante o tempo estritamente necessário para cumprir com as finalidades de tratamento de dados.
- **RESPONDERAM NEGATIVAMENTE:** Barra do Piraí, Belford Roxo, Bom Jesus do Itabapoana, Cabo Frio, Itaboraí, Mangaratiba, Nova Friburgo, Paty do Alferes, Piraí, São Gonçalo e Valença.

4.15. Achado 15 - Ausência de publicação na internet das informações sobre previsão legal, finalidade, procedimentos e práticas utilizadas para o tratamento de dados pessoais

4.15.1 Critérios

- Lei Federal nº 13.709/2018, art. 6º, incisos I, IV e VI, art. 23, inciso I.

4.15.2 Evidências

- Respostas negativas ao item E13 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 – LGPD [Anexo: 005 – Questionário – Respostas.pdf], onde os respondentes afirmam que não publicam na internet as informações sobre a previsão legal, a finalidade, os procedimentos e as práticas utilizadas para o tratamento de dados pessoais.

4.15.3 Situação Encontrada

A publicidade, como disposto no art. 37 da Carta Magna de 1988, é um dos princípios basilares da Administração Pública, tratando-se de um dos pilares da cidadania moderna, uma vez que permite o controle social do Poder Público pelos cidadãos. No tempo presente, para a maior efetividade e maior alcance desta importante ferramenta de vigilância, observa-se imprescindível que a publicação da informação seja feita na rede mundial de computadores, como consignado no art. 8º da Lei de Acesso à Informação³⁰.

³⁰ Lei 12.527/11. Art. 8º É dever dos órgãos e entidades públicas promover, independentemente de requerimentos, a divulgação em local de fácil acesso, no âmbito de suas competências, de informações de interesse coletivo ou geral por eles produzidas ou custodiadas.

§ 2º Para cumprimento do disposto no caput, os órgãos e entidades públicas deverão utilizar todos os meios e instrumentos legítimos de que dispuserem, sendo obrigatória a divulgação em sítios oficiais da rede mundial de computadores (internet).

O TCU vem reforçando esse entendimento acerca da publicidade das informações e atos³¹. Não se julga mais cabível em tempos modernos limitar a publicidade de atos ou informações a instrumentos de pequeno ou minúsculo alcance, como jornais físicos, documentos expostos em painéis e afins³².

Nessa vereda, os princípios do livre acesso e da transparência, estabelecidos no art. 6º, IV e VI, da LGPD versam sobre a garantia dada aos titulares de dados para realizarem consulta facilitada e gratuita a respeito da forma e duração do tratamento dos seus dados pessoais, além de informações gerais referentes aos agentes de tratamento.

Para avaliar se esses preceitos estão sendo seguidos pelos jurisdicionados foi realizado o seguinte questionamento para os 13 (treze) jurisdicionados que responderam “parcialmente” à questão E1: “A organização publica na internet as informações sobre a previsão legal, a finalidade, os procedimentos e as práticas utilizadas para o tratamento de dados pessoais?”.

Desses 13 (treze), apenas as Prefeituras de São Gonçalo e Valença responderam que publicaram na internet as informações sobre a previsão legal, a finalidade, os procedimentos e as práticas utilizadas para o tratamento de dados pessoais, enquanto os 11 (onze) restantes responderam que não publicaram.

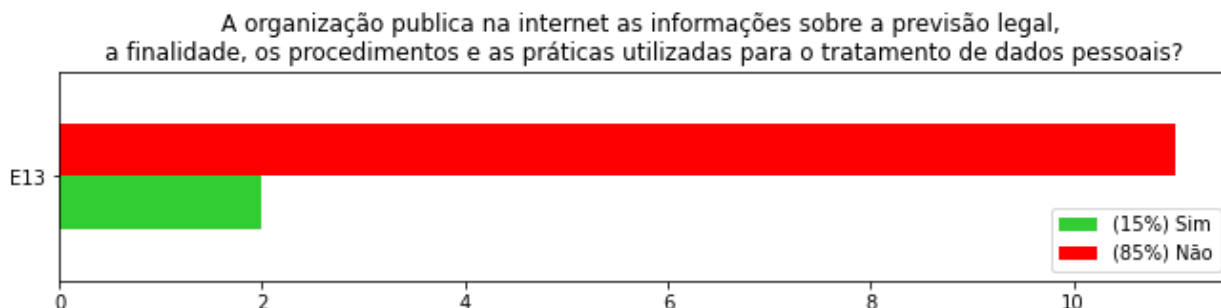


Figura 40: Respostas da questão E13

³¹ [Acórdão 1855/2018-Plenário](#) – “Os órgãos e entidades da Administração Pública Federal devem promover a publicação do inteiro teor de todos os seus contratos administrativos, inclusive anexos e aditivos, em seus sítios oficiais na Internet, em atendimento ao art. 8º, § 1º, inciso IV, da Lei 12.527/2011 (LAI), preferencialmente em formato aberto (art. 8º, § 3º, inciso III, da mesma lei) e que permita a pesquisa de texto”

³² DIAS, Wladimir Rodrigues. Princípio da publicidade e comunicação estatal. Revista Jus Navigandi, ISSN 1518-4862, Teresina, ano 18, n. 3698, 16 ago. 2013. Disponível em: <<https://jus.com.br/artigos/25145>> Acesso em: 14/06/2022.

O questionamento foi criado para verificar se os jurisdicionados estão em conformidade com princípios dispostos na LGPD e Constituição Federal, e com o dispositivo do art. 23, inciso I, da LGPD.

A LGPD elenca princípios sob os quais devem ser observados em todas as atividades de tratamento de dados pessoais, dentre eles verificam-se o princípio da finalidade, do livre acesso e da transparência, contidos respectivamente nos incisos I, IV e VI da Lei nº 13.709/18. Enquanto a Carta Magna de 1988, em seu art. 37, eleva a publicidade como princípio basilar a ser seguido por toda Administração Pública.

O art. 23, inciso I, da LGPD vincula as pessoas jurídicas de direito público a informar as hipóteses em que realizam o tratamento de dados pessoais, fornecendo informações claras e atualizadas, em veículos de fácil acesso, preferencialmente em seus sítios eletrônicos.

A garantia da publicação dessas informações na internet, veículo de amplo e fácil acesso, é uma maneira efetiva de assegurar o controle social por parte do titular de dados e assim permitir que este verifique se o tratamento de dados feito está em acordo com o disposto pelo órgão e em conformidade à LGPD. Dessa forma, entende-se que a publicação das informações citadas no questionamento é essencial para assegurar o efetivo cumprimento da norma e dos direitos do titular de dados.

Por não cumprirem com uma ampla transparência e efetiva disponibilização em veículos de fácil acesso, como seu sítio eletrônico, das informações referentes à previsão legal, finalidade, procedimentos e práticas utilizadas para o tratamento de dados pessoais, será incluída **determinação** na proposta de encaminhamento deste relatório para os jurisdicionados cujas respostas foram negativas à questão E13.

4.15.4 Causas

- Não investigadas

4.15.5 Efeitos

- Prejuízo na ciência por parte dos titulares de dados e da ANPD da estratégia para o tratamento dos dados;
- Falta de transparência para os titulares dos dados acerca da finalidade do tratamento de dados.

4.15.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.
 - **DETERMINAÇÃO:** divulgar, no sítio eletrônico da organização, preferencialmente, na mesma página de divulgação do contato do encarregado de dados, a previsão legal, a finalidade, os procedimentos e práticas utilizadas para todas as atividades de tratamento de dados pessoais realizadas pela organização.
 - **RESPONDERAM NEGATIVAMENTE:** Barra do Pirai, Belford Roxo, Bom Jesus do Itabapoana, Cabo Frio, Campos dos Goytacazes, Cantagalo, Itaboraí, Mangaratiba, Nova Friburgo, Paty do Alferes e Pirai.

4.16. Achado 16 - Não identificação e documentação das bases legais que fundamentam todas as atividades de tratamento de dados pessoais.

4.16.1 Critérios

- Lei Federal nº 13.709/2018, art. 7º e art. 23, inciso I;
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, item 7.2.2.

4.16.2 Evidências

- Respostas ao item E2 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 – LGPD [Anexo: 005 – Questionário – Respostas.pdf], onde os respondentes afirmam que não identificaram ou há somente identificação parcial das bases legais que fundamentam as atividades de tratamento de dados pessoais.

4.16.3 Situação Encontrada

A base legal ou hipótese de tratamento é a fundamentação normativa que assegura que o agente de tratamento possa realizar o tratamento no dado pessoal sob sua responsabilidade. As bases legais encontram-se elencadas nos arts. 7º, 11 e 14 da LGPD, sendo esses dois últimos referentes a, respectivamente, dados pessoais sensíveis e dados pessoais de crianças e adolescentes.

Assim, para cada atividade de tratamento deve ser especificada qual a hipótese para ocorrer esse tratamento. Uma operação feita sem a vinculação da sua devida base legal ou com base legal diversa à permitida configura descumprimento da norma.

Para avaliar se os jurisdicionados identificaram e documentaram as bases legais que fundamentam suas atividades de tratamento de dados pessoais foi realizado o seguinte questionamento para todos os jurisdicionados na questão E2: “A organização identificou e documentou as bases legais que fundamentam as atividades de tratamento de dados pessoais?”.

Nenhum dos jurisdicionados afirmou que identificou e documentou todas as bases legais relacionadas às atividades de tratamento de dados pessoais, 14 (quatorze) afirmaram que já identificaram parcialmente e a ampla maioria, 77 (setenta e sete) jurisdicionados afirmaram que não realizaram qualquer trabalho de identificação e documentação de suas bases legais.

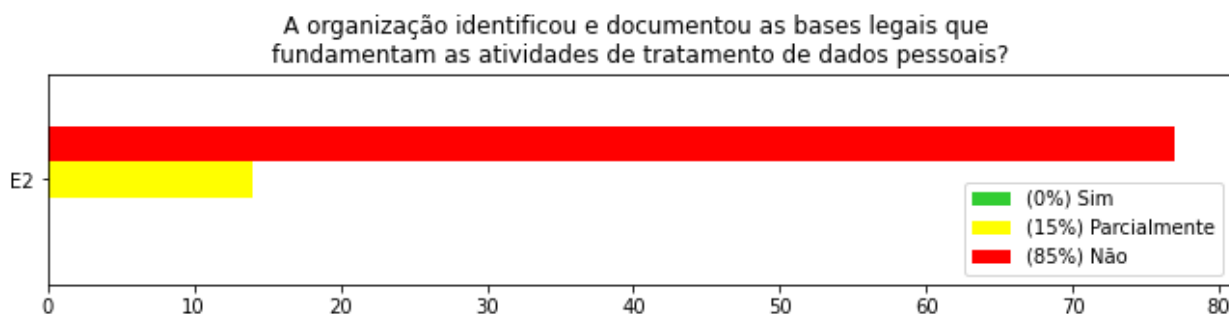


Figura 41: Respostas da questão E2

O questionamento foi criado para verificar se os jurisdicionados estão em conformidade com o disposto no art. 23, inciso I, da LGPD, onde postula-se que as pessoas jurídicas de direito público devem informar as hipóteses em que, no exercício de suas competências, realizam o tratamento de dados pessoais. As hipóteses de tratamento supracitadas para os dados pessoais são elencadas no art. 7º da LGPD.

A Norma Técnica ABNT NBR ISO/IEC 27701/19 em seu item 7.7.2 elenca como boa prática de segurança da informação e privacidade a identificação das bases legais.

Este item recomenda que a organização determine, documente e esteja em *compliance* com a base legal pertinente para o tratamento de dados pessoais, para os propósitos identificados. Como o art. 46 da LGPD afirma que os agentes de tratamento devem adotar medidas de segurança técnicas e administrativas aptas a protegerem os dados pessoais, entende-se que seja cabível a aplicação desta Norma Técnica.

Por não efetuarem a identificação e documentação das bases legais que fundamentam as atividades de tratamento de dados, em desacordo à legislação vigente, os jurisdicionados cujas respostas foram negativas ou parciais à questão E2 serão objeto de **determinação** na proposta de encaminhamento deste relatório.

4.16.4 Causas

- Não investigadas

4.16.5 Efeitos

- Realização de tratamento de dados em hipótese não prevista na LGPD.

4.16.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.
 - **DETERMINAÇÃO:** identificar e documentar as bases legais que fundamentam todas as atividades de tratamento de dados pessoais.
 - **RESPONDERAM PARCIALMENTE:** Arraial do Cabo, Bom Jesus do Itabapoana, Cabo Frio, Cantagalo, Itaboraí, Mangaratiba, Maricá, Mesquita, Nova Friburgo, Nova Iguaçu, Pinheiral, Pirai, São Gonçalo e Valença.
 - **RESPONDERAM NEGATIVAMENTE:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Barra do Piraí, Barra Mansa, Belford Roxo, Bom Jardim, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de

Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mendes, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São João da Barra, São João de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastião do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Varre-Sai, Vassouras e Volta Redonda.

4.17. Achado 17 - Não elaboração de inventário para consolidar informações relacionadas às características das atividades de tratamento de dados pessoais

4.17.1 Critérios

- Lei Federal nº 13.709/2018, art. 37;
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, item 7.2.8.

4.17.2 Evidências

- Respostas negativas ao item E3 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 – LGPD [Anexo: 005 – Questionário – Respostas.pdf], onde os respondentes confirmam que não foi elaborado um inventário para consolidar informações relacionadas às características das atividades de dados pessoais.

4.17.3 Situação Encontrada

O inventário (ou registro) de dados pessoais é um artefato muito importante no âmbito da LGPD, uma vez que consolida as informações relativas ao tratamento de dados pessoais no órgão num documento centralizado e de fácil acesso a todos que necessitarem durante o processo de adequação à norma. Consiste num registro do que

o órgão faz com os dados pessoais, identificando quais dados pessoais são tratados, onde estão armazenados e que atividades de tratamento são realizadas sobre eles.

O Guia de Elaboração do Inventário de Dados Pessoais³³ elaborado pelo Ministério da Economia do Governo Federal lista uma série de itens relacionados ao tratamento de dados pessoais que podem constar no inventário, sejam:

- atores envolvidos (agentes de tratamento e o encarregado);
- finalidade (o que a instituição faz com o dado pessoal);
- hipótese (arts. 7º e 11 da LGPD);
- previsão legal;
- dados pessoais tratados pela instituição;
- categoria dos titulares dos dados pessoais;
- tempo de retenção dos dados pessoais, etc.

Diante da importância desse documento, foi realizado o seguinte questionamento para todos os jurisdicionados na questão E3: Há um registro (inventário) instituído para consolidar informações relacionadas às características das atividades de tratamento de dados pessoais?

Nenhum dos jurisdicionados afirmou que apresenta um inventário que consolide informações sobre as atividades de tratamento de dados pessoais.

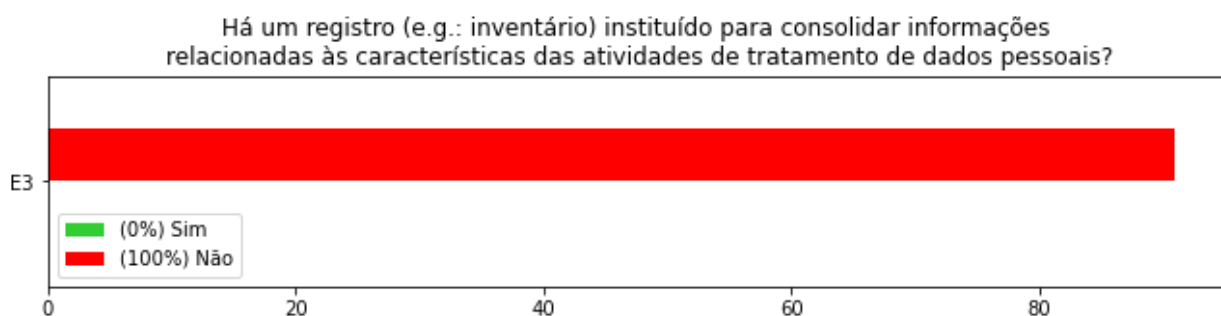


Figura 42: Respostas da questão E3

O questionamento foi criado para verificar se os jurisdicionados estão em conformidade com o disposto no art. 37 da LGPD, dispositivo que expressamente vincula os agentes de tratamento de dados pessoais a registrarem as operações de tratamento

³³ Disponível em <https://www.gov.br/governodigital/pt-br/seguranca-e-protecao-de-dados/guias/guia_inventario_dados_pessoais.pdf>. Acesso em 13/06/2022.

de dados pessoais que realizarem. Este registro deve ser feito num documento, planilha ou banco de dados que consolide as informações das atividades de tratamento executadas nos dados pessoais identificados da organização. Portanto, configura violação a este dispositivo a falta de registro das operações de tratamento de dados.

A Norma Técnica ABNT NBR ISO/IEC 27701/19, em seu item 7.2.8, elenca como boa prática de segurança da informação e privacidade os registros relativos ao tratamento de dados pessoais. Este item recomenda que a organização mantenha de maneira segura os registros necessários ao suporte das suas obrigações para o tratamento de dados pessoais. E como o art. 46 da LGPD afirma que os agentes de tratamento devem adotar medidas de segurança técnicas e administrativas aptas a protegerem os dados pessoais, entende-se que seja cabível a aplicação desta Norma Técnica.

Por não efetuarem o registro das atividades de tratamento de dados pessoais que realizam, em desacordo à legislação vigente, haverá sugestão de **determinação** na proposta de encaminhamento deste relatório para os jurisdicionados cujas respostas foram negativas à questão E3.

4.17.4 Causas

- Não investigadas.

4.17.5 Efeitos

- Prejuízo na documentação e controle das atividades relacionadas ao tratamento de dados pessoais.

4.17.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.

- **DETERMINAÇÃO:** elaborar um inventário ou lista de atividades de tratamento de dados pessoais contendo, ao menos, um subconjunto das seguintes características: registros necessários ao suporte às obrigações para o tratamento de dados pessoais; o tipo de tratamento; os propósitos para o tratamento; uma descrição das categorias de dados pessoais e dos titulares de dados pessoais (por exemplo, crianças); as categorias de destinatário para quem o dado pessoal tem sido ou será divulgado, incluindo os destinatários em outros países ou organizações internacionais; uma descrição geral das medidas de segurança técnica e organizacional e um relatório de avaliação de impacto de privacidade.
- **RESPONDERAM NEGATIVAMENTE:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra do Pirai, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Mesquita, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pinheiral, Pirai, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São João da Barra, São João de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastião do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Valença, Varre-Sai, Vassouras e Volta Redonda.

4.18. Achado 18 - Não elaboração do relatório de impacto à proteção de dados pessoais (RIPD) abrangendo todos os processos de tratamento de dados pessoais que podem gerar riscos aos titulares.

4.18.1 Critérios

- Lei Federal nº 13.709/2018, art. 4º, parágrafo 3º, art. 5º, inciso XVII, art. 10, parágrafo 3º e arts. 32, 38 e 46;
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, item 7.2.5.

4.18.2 Evidências

- Respostas negativas ao item E4 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 – LGPD [Anexo: 005 – Questionário – Respostas.pdf], onde os respondentes afirmam que o Relatório de Impacto à Proteção de Dados Pessoais não foi elaborado.

4.18.3 Situação Encontrada

O Relatório de Impacto à Proteção de Dados Pessoais (RIPD), como bem descrito no art. 5º, XVII, da LGPD, é um documento produzido pelo controlador de dados pessoais que contém a descrição dos processos de tratamento de dados pessoais que podem gerar riscos às liberdades civis e aos direitos fundamentais, garantia assegurada no art. 5º da Constituição Federal de 1988. Ressalta-se que além de conter a descrição dos processos, tal documento deve, também, elencar uma série de controles e mecanismos necessários para mitigar os riscos de violação de dados pessoais.

Para verificar a existência desse documento foi realizado o seguinte questionamento para todos os jurisdicionados na questão E4: A organização elaborou Relatório de Impacto à Proteção de Dados Pessoais?

Nenhum dos jurisdicionados afirmou que havia elaborado o RIPD, assim 73 (setenta e três) jurisdicionados responderam que não elaboraram e 18 (dezoito) julgaram que tal documento não seria aplicável.

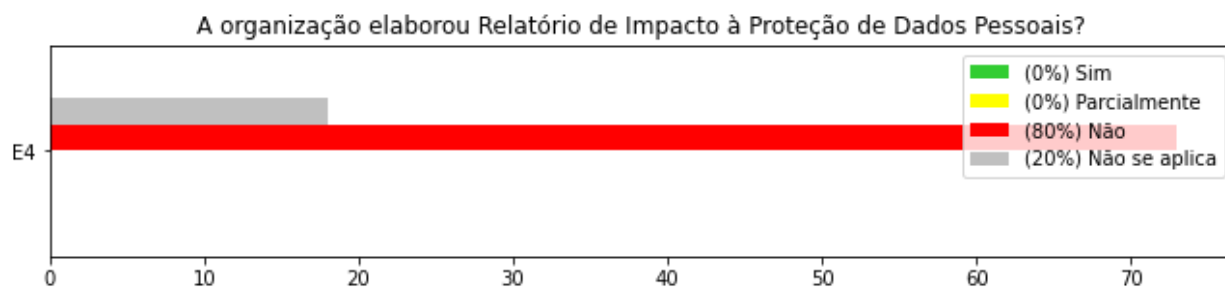


Figura 43: Respostas da questão E4

A questão foi criada para verificar se os jurisdicionados estão aptos a responder tempestivamente as solicitações da ANPD, presentes nos dispositivos apostados no art. 4º, § 3º, art. 10, § 3º, e art. 32, da LGPD. Uma vez que a solicitação do relatório ocorre *a posteriori* de algum evento ou marco relevante, julga-se necessário que tal documento já esteja pronto e disponível *a priori*.

Mesmo entendimento da Norma Técnica ABNT NBR ISO/IEC 27701/19, que em seu item 7.2.5 elenca como boa prática de segurança a avaliação de impacto da privacidade. Este item recomenda que se realize uma avaliação de impacto de privacidade ao planejar criação ou mudança de tratamentos de dados pessoais. E como o art. 46 da LGPD afirma que os agentes de tratamento devem adotar medidas de segurança técnicas e administrativas aptas a protegerem os dados pessoais, entende-se que seja cabível a aplicação desta Norma Técnica.

Pela criticidade do item em discussão, instrumento que gerencia riscos capazes de violar direitos fundamentais do titular de dados, será sugerida determinação àqueles jurisdicionados que responderam que tal documento não seria aplicável, para que estes realizem uma nova avaliação sobre a possibilidade de elaboração do RIPD.

Dessa forma, por não elaborarem um Relatório de Impacto à Proteção de Dados Pessoais - RIPD, os jurisdicionados cujas respostas foram negativas ou “não se aplica” à questão E4 serão objeto de **determinação** na proposta de encaminhamento deste relatório.

4.18.4 Causas

- Não investigadas

4.18.5 Efeitos

- Prejuízo no mapeamento dos riscos aos titulares de dados, podendo gerar dificuldade de ação no caso de violação de dados;
- Dificuldade de atendimento tempestivo à ANPD em caso de solicitação do RIPD.

4.18.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado

os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.

- **DETERMINAÇÃO:** elaborar Relatório de Impacto à Proteção de Dados Pessoais abrangendo todos os processos de tratamento de dados pessoais que podem gerar risco aos titulares e para implementar controles para mitigar todos os riscos identificados no Relatório de Impacto de Proteção de Dados Pessoais.
- **RESPONDERAM NEGATIVAMENTE:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra do Piraí, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Itaocara, Itaperuna, Macuco, Mangaratiba, Maricá, Mendes, Mesquita, Miguel Pereira, Miracema, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pinheiral, Pirai, Quatis, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São João de Meriti, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastiao do Alto, Saquarema, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Três Rios, Valença, Varre-Sai, Vassouras e Volta Redonda.
- **RESPONDERAM NÃO SE APLICA:** Carmo, Engenheiro Paulo de Frontin, Italva, Itatiaia, Japeri, Laje do Muriaé, Macaé, Magé, Natividade, Porciúncula, Porto Real, Queimados, Rio das Flores, São João da Barra, São José de Ubá, Sapucaia, Seropédica e Trajano de Moraes.

4.19. Achado 19 - Ausência de uma política de privacidade para comunicar aos usuários as informações relativas ao tratamento de dados

4.19.1 Critérios

- Lei Federal nº 13.709/2018, art. 6º, incisos IV, V e VI, art. 9º, art. 23, inciso I, art. 50, parágrafo 2º, inciso I, alíneas “a”, “d” e “e”;

- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, itens 7.3.2 e 7.3.3.

4.19.2 Evidências

- Respostas negativas ao item F1 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 – LGPD [Anexo: 005 – Questionário – Respostas.pdf], onde os respondentes confirmam a inexistência da Política de Privacidade ou Instrumento similar.

4.19.3 Situação Encontrada

A Política de Privacidade é o documento voltado ao público externo do órgão que comunica aos titulares de dados pessoais, de maneira clara e concisa, informações relativas ao tratamento de seus dados pessoais. A Lei Geral de Proteção de Dados Pessoais – Lei Federal nº 13.709/18 – exemplifica as informações que devem constar no documento, sejam elas: as finalidades dos tratamentos, as formas e durações dos tratamentos, a identificação e os dados de contato do controlador, informações acerca do uso compartilhado de dados, as responsabilidades dos agentes que realizam os tratamentos e os direitos do titular.

Para verificar a existência desse documento foi realizado o seguinte questionamento para todos os jurisdicionados na questão F1: A organização possui Política de Privacidade (ou instrumento similar)?

Apenas 4 (quatro) dos jurisdicionados afirmaram que possuíam uma política de privacidade e enviaram uma documentação comprobatória. Desses, foi minorado para “atendimento parcial” o documento enviado pela Prefeitura de Valença, mantendo-se como totalmente válidos os documentos fornecidos pelas Prefeituras de Armação de Búzios, Mesquita e São Gonçalo.

Cabe reforçar que os requisitos mínimos esperados para uma Política de Privacidade constam no anexo “012 - Requisitos mínimos de documentos solicitados.pdf” e a análise efetuada nos artefatos enviados discorrendo sobre o não atendimento ou atendimento parcial encontra-se na seção pertinente a cada jurisdicionado no anexo “013 - Resultado individualizado.pdf”.

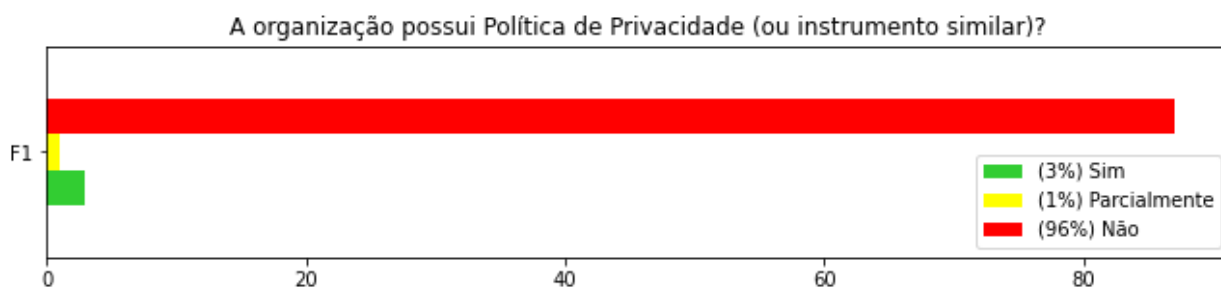


Figura 44: Respostas da questão F1

O questionamento foi criado para verificar se os jurisdicionados estão atendendo aos princípios do livre acesso, qualidade dos dados e transparência elencados no art. 6º, incisos IV, V e VI, da LGPD, assim como se estão em conformidade com o disposto no art. 9º da norma, uma vez que este dispositivo especifica um conjunto de informações as quais o titular dos dados pessoais tem o direito de acesso facilitado, de forma clara, adequada e ostensiva.

O artigo 23, inciso I, da LGPD atribui o dever ao órgão público de informar as hipóteses em que realiza tratamento de dados pessoais, fornecendo informações claras e atualizadas sobre a previsão legal, a finalidade, os procedimentos e as práticas utilizadas no tratamento. Informações correlatas àquelas listadas no artigo 9º e consideradas nos requisitos mínimos de uma Política de Privacidade. Por fim, o art. 50, § 2º, inciso I, apresenta a possibilidade do controlador implementar um programa de governança em privacidade que demonstre seu comprometimento em adotar processos e políticas internas que assegurem o cumprimento de normas e boas práticas relativas à proteção de dados pessoais.

Nessa toada, a Norma Técnica ABNT NBR ISO/IEC 27701/19, em sua seção 7.3 – Obrigações dos titulares de dados pessoais – apresenta uma série de boas práticas relativas à segurança da informação e privacidade que se relacionam a este achado em questão. O item 7.3.2 recomenda que a organização determine e documente a informação a ser fornecida aos titulares de dados pessoais relativa ao tratamento de seus dados pessoais e o tempo de tal disponibilização. O item 7.3.3 recomenda que a organização forneça aos titulares de dados pessoais, de forma clara e facilmente acessível, informações que identifiquem o controlador de dados pessoais e descrevam o tratamento de seus dados pessoais. Assim, verifica-se necessário ao controlador compilar essas informações e fornecê-las aos titulares de dados num documento uno, público e disponível.

Diante do exposto, será sugerida na proposta de encaminhamento deste relatório uma **determinação** aos jurisdicionados cujas respostas foram negativas à questão F1 para que elaborem sua Política de Privacidade.

4.19.4 Causas

- Não investigadas

4.19.5 Efeitos

- Prejuízo na ciência por parte dos usuários das informações relativas ao tratamento dos dados pessoais, podendo gerar no usuário um desconhecimento sobre o uso de seus dados.

4.19.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.
 - **DETERMINAÇÃO:** elaborar Política de Privacidade que elenque, ao menos, informações acerca da finalidade e sobre como será feito o tratamento de dados pessoais, e divulgar em local de fácil acesso no sítio eletrônico da organização.
 - **RESPONDERAM NEGATIVAMENTE:** Angra dos Reis, Aperibé, Araruama, Areal, Arraial do Cabo, Barra do Pirai, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do

Sul, Paraty, Paty do Alferes, Petrópolis, Pinheiral, Pirai, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São João da Barra, São João de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastiao do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Valença, Varre-Sai, Vassouras e Volta Redonda.

4.20. Achado 20 - Não implementação de mecanismos para atender todos os direitos dos titulares de dados pessoais

4.20.1 Critérios

- Lei Federal nº 13.709/2018, arts. 17-22;
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, item 7.3.

4.20.2 Evidências

- Respostas ao item F2 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 – LGPD [Anexo: 005 – Questionário – Respostas.pdf], onde os respondentes confirmam que não foram implementados ou foram implementados parcialmente os mecanismos para atender os direitos dos titulares elencados no artigo 18 da LGPD e aplicáveis.

4.20.3 Situação Encontrada

Os direitos dos titulares de dados pessoais estão elencados no Capítulo III da LGPD e abrangem uma série de garantias dadas aos titulares para assegurar seus direitos fundamentais de liberdade, intimidade e privacidade, conforme disposto no art. 17 da LGPD e art. 5º, X e LXXIX da Carta Magna de 1988.

O artigo 18 da LGPD dispõe que o titular de dados pessoais tem o direito de obter junto ao controlador, em relação a seus dados, a qualquer momento e mediante requisição:

- Confirmação da existência de tratamento;
- Acesso aos dados;

- Correção de dados incompletos, inexatos ou desatualizados;
- Anonimização, bloqueio ou eliminação de dados desnecessários, excessivos ou em desconformidade com a Lei;
- Eliminação dos dados pessoais tratados com o consentimento do titular

Para verificar se os direitos dos titulares podem ser plenamente exercidos foi realizado o seguinte questionamento para todos os jurisdicionados na questão F2: Foram implementados mecanismos para atender os direitos dos titulares elencados no art. 18 da LGPD e aplicáveis à organização?

Apenas as Prefeituras de Mesquita e Valença afirmaram que implementaram mecanismos a fim de garantir os direitos dos titulares de dados dispostos nos art. 18 da norma, 10 (dez) responderam que implementaram parcialmente os mecanismos, e 79 (setenta e nove) informaram que não implementaram os mecanismos a fim de garantir tais direitos.

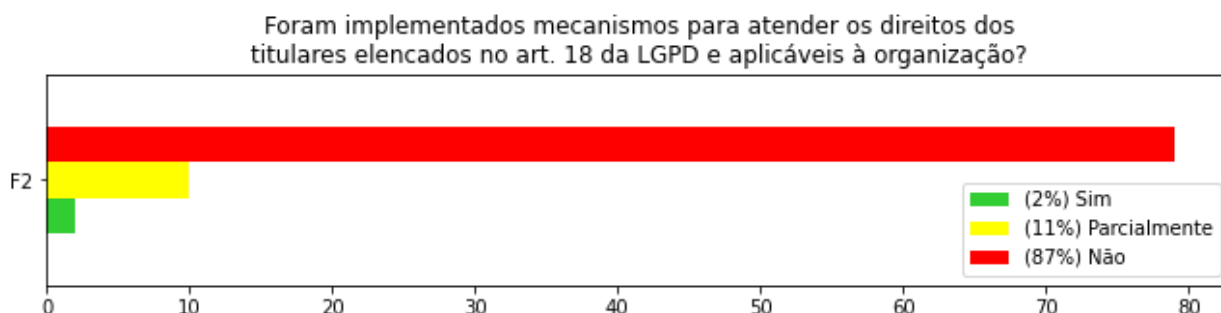


Figura 45: Respostas da questão F2

O questionamento foi criado para verificar se os jurisdicionados criaram ou definiram mecanismos que possibilitassem os titulares de dados pessoais a exercerem seus direitos garantidos pela LGPD.

A Norma Técnica ABNT NBR ISO/IEC 27701/19, em sua seção 7.3 – Obrigações dos titulares de dados pessoais – apresenta uma série de boas práticas relativas à segurança da informação e privacidade que se relacionam a este achado em questão. O item 7.3.1 recomenda que a organização determine e documente suas obrigações regulatórias, legais e de negócios para os titulares de dados. Assim, verifica-se necessário aos controladores fornecerem mecanismos suficientes aos titulares de dados para exercerem seus direitos elencados no art. 18 da LGPD.

Por não implementarem mecanismos necessários a garantir os direitos dos titulares dos dados pessoais, os jurisdicionados cujas respostas foram negativas ou parciais à questão F2 serão alvo de **determinação** na proposta de encaminhamento deste relatório.

4.20.4 Causas

- Não investigadas

4.20.5 Efeitos

- Prejuízo aos titulares de dados pessoais, podendo gerar falha no atendimento dos seus direitos.

4.20.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.
 - **DETERMINAÇÃO:** implementar mecanismos para atender todos os direitos dos titulares elencados nos artigos 17-22 da LGPD e aplicáveis à organização.
 - **RESPONDERAM PARCIALMENTE:** Arraial do Cabo, Bom Jardim, Bom Jesus do Itabapoana, Comendador Levy Gasparian, Cordeiro, Paty do Alferes, Pirai, Quatis, Resende e Rio Claro.
 - **RESPONDERAM NEGATIVAMENTE:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Barra do Pirai, Barra Mansa, Belford Roxo, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Conceição de Macabu, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Miguel Pereira,

Miracema, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Petrópolis, Pinheiral, Porciúncula, Porto Real, Queimados, Quissamã, Rio Bonito, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São João da Barra, São João de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastiao do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Varre-Sai, Vassouras e Volta Redonda.

4.21. Achado 21 - Ausência de identificação de todos os dados pessoais que são compartilhados com terceiros

4.21.1 Critérios

- Lei Federal nº 13.709/2018, art. 5º, inciso XVI, arts. 26, 27 e 39;
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, itens 7.5.3 e 7.5.4.

4.21.2 Evidências

- Respostas ao item G1 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 – LGPD [Anexo: 005 – Questionário – Respostas.pdf], onde os respondentes afirmam que não houve identificação ou apenas identificação parcial dos dados pessoais que são compartilhados com terceiros.

4.21.3 Situação Encontrada

Uma das principais garantias concedidas aos titulares dos dados pela LGPD é a possibilidade de obter informações acerca do uso compartilhado de dados pelo controlador e a finalidade, conforme o art. 9º, inciso V. Para estar apto a atender a uma possível solicitação do titular é imprescindível que o órgão já tenha identificado quais dados trata e compartilha.

A identificação de quais dados pessoais são compartilhados com terceiros é imprescindível na garantia do direito fundamental de privacidade dos dados, consubstanciado no art. 5º, LXXIX, da Carta Magna de 1988, posto que o compartilhamento não controlado de dados pessoais é um evidente risco de segurança

e pode acarretar em violação na privacidade dos dados pessoais sob responsabilidade do controlador.

O art. 5º, XVI, da LGPD define o uso compartilhado de dados como toda comunicação, difusão, transferência internacional, interconexão ou tratamento compartilhado de banco de dados pessoais por órgãos no cumprimento de suas competências legais.

Para verificar se estes dados pessoais compartilhados com terceiros foram devidamente identificados foi realizado o seguinte questionamento para todos os jurisdicionados na questão G1: A organização identificou os dados pessoais que são compartilhados com terceiros?

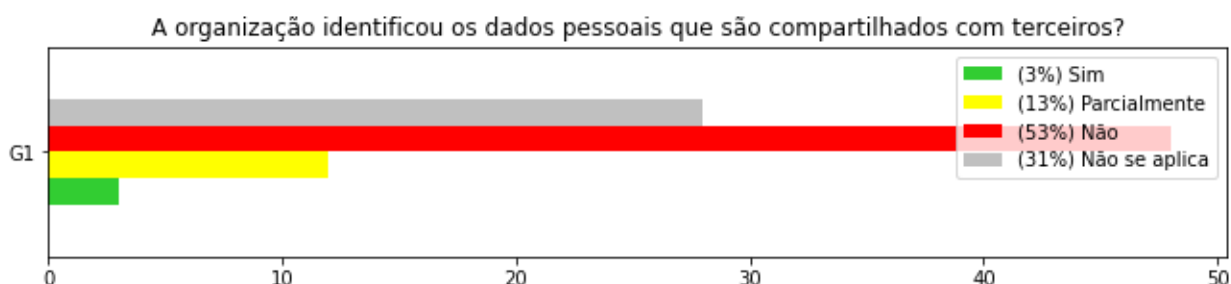


Figura 46: Respostas da questão G1

Apenas as Prefeituras de Arraial do Cabo, Cardoso Moreira e Mesquita afirmaram que haviam identificados os dados pessoais compartilhados com terceiros, 12 (doze) jurisdicionados identificaram parcialmente, 48 (quarenta e oito) jurisdicionados responderam que ainda não identificam seus dados pessoais compartilhados com terceiros e 28 (vinte e oito) jurisdicionados julgaram que este questionamento não se aplica, uma vez que eles não realizam compartilhamento de dados com terceiros.

Por não identificarem os dados pessoais compartilhados com terceiros, os jurisdicionados cujas respostas foram negativas ou parciais à questão G1 serão alvo de **determinação** na proposta de encaminhamento deste relatório.

4.21.4 Causas

- Não investigadas

4.21.5 Efeitos

- Possível ocorrência de compartilhamento indevido ou que prejudique o titular dos dados.

4.21.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.
 - **DETERMINAÇÃO:** identificar todos os dados pessoais que são compartilhados com terceiros e adequar todos os compartilhamentos aos critérios estabelecidos na LGPD, bem como registrar toda ocorrência de transferência de dados pessoais.
 - **RESPONDERAM PARCIALMENTE:** Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cantagalo, Casimiro de Abreu, Comendador Levy Gasparian, Paty do Alferes, Pinheiral, São Gonçalo, Valença, Saquarema e Teresópolis.
 - **RESPONDERAM NEGATIVAMENTE:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Barra do Piraí, Barra Mansa, Belford Roxo, Cachoeiras de Macacu, Carapebus, Carmo, Conceição de Macabu, Duas Barras, Duque de Caxias, Guapimirim, Itaboraí, Itaguaí, Itaocara, Macuco, Mangaratiba, Maricá, Mendes, Miguel Pereira, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Petrópolis, Piraí, Quatis, Resende, Rio Claro, Santa Maria Madalena, São Fidélis, São João de Meriti, São José do Vale do Rio Preto, São Pedro da Aldeia, Sapucaia, Seropédica, Sumidouro, Tanguá, Três Rios, Vassouras e Volta Redonda.

4.22. Achado 22 - Compartilhamentos de dados pessoais em desacordo com os critérios estabelecidos na LGPD

4.22.1 Critérios

- Lei Federal nº 13.709/2018, art. 5º, inciso XVI e arts. 26, 27 e 39.

- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, item 7.5.3 e 7.5.4

4.22.2 Evidências

- Respostas negativas ao item G11 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 - LGPD [Anexo: 005 - Questionário - Respostas.pdf], onde os respondentes confirmam que os compartilhamentos de dados pessoais identificados não estão em conformidade com os critérios estabelecidos nos artigos 26, 27 e 39 da LGPD.

4.22.3 Situação Encontrada

A necessidade da identificação dos dados pessoais compartilhados com terceiros é de imperiosa relevância aos órgãos controladores, como já demonstrado no achado anterior (Achado 21). Uma vez que o jurisdicionado identificou quais de seus dados pessoais estão sob uso compartilhado, tentou-se verificar se este processo estaria sendo feito à luz da LGPD.

Para as 15 (quinze) prefeituras que responderam “sim” ou “parcialmente” à questão G1 (A organização identificou os dados pessoais que são compartilhados com terceiros?), foi realizado o seguinte questionamento na questão G11: Os compartilhamentos de dados pessoais identificados estão em conformidade com os critérios estabelecidos na LGPD?

Dessas 15 (quinze) prefeituras, Bom Jesus do Itabapoana e Mesquita responderam que os dados pessoais identificados estão em conformidade com os critérios estabelecidos na LGPD, 8 (oito) prefeituras responderam que os dados estão parcialmente em conformidade e as outras 5 (cinco) prefeituras responderam que os dados não estão em conformidade.

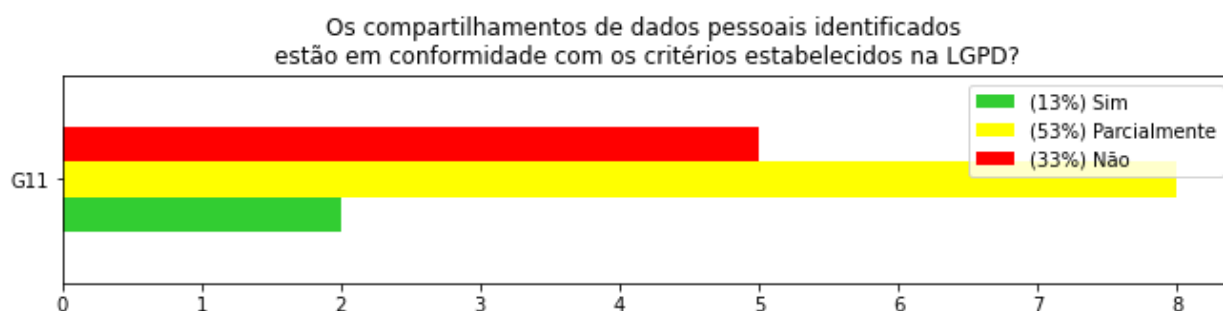


Figura 47: Respostas da questão G11

A conformidade do compartilhamento de dados pessoais identificados com os critérios estabelecidos na LGPD é de sumária importância, tal fato é reforçado pelo artigo 26 da LGPD:

Art. 26. O uso compartilhado de dados pessoais pelo Poder Público deve atender a finalidades específicas de execução de políticas públicas e atribuição legal pelos órgãos e pelas entidades públicas, respeitados os princípios de proteção de dados pessoais elencados no art. 6º desta Lei.

Em seu artigo 27, a LGPD ressalta mais uma vez a necessidade da conformidade do compartilhamento de dados pessoais:

Art. 27. A comunicação ou o uso compartilhado de dados pessoais de pessoa jurídica de direito público a pessoa de direito privado será informada à autoridade nacional e dependerá de consentimento do titular.

Por haver um compartilhamento de dados pessoais com terceiros em desacordo com a LGPD, os jurisdicionados cujas respostas foram negativas ou parciais à questão G11 serão alvo de **determinação** na proposta de encaminhamento deste relatório.

4.22.4 Causas

- Não investigadas

4.22.5 Efeitos

- Possibilidade de vazamento de dados pessoais.
- Possível ocorrência de compartilhamento indevido ou que prejudique o titular dos dados.
- Falta de responsabilização em caso de violação de dados pessoais.

4.22.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº

63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.

- **DETERMINAÇÃO:** adequar todos os compartilhamentos de dados pessoais aos critérios estabelecidos na LGPD, isto é, atendendo a finalidades de execução de políticas públicas e atribuição legal, respeitados os princípios de proteção de dados pessoais.
- **RESPONDERAM PARCIALMENTE:** Arraial do Cabo, Bom Jardim, Cantagalo, Comendador Levy Gasparian, Paty do Alferes, São Gonçalo, Teresópolis e Valença.
- **RESPONDERAM NEGATIVAMENTE:** Cabo Frio, Cardoso Moreira, Casimiro de Abreu, Pinheiral e Saquarema.

4.23. Achado 23 - Ausência de registro de transferência de dados pessoais

4.23.1 Critérios

- Lei Federal nº 13.709/2018, art. 5º, inciso XVI e arts. 26, 27 e 37 e 39.
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, item 7.5.4

4.23.2 Evidências

- Respostas ao item G12 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 - LGPD [Anexo: 005 - Questionário - Respostas.pdf], onde os respondentes afirmam que não registram ou registram parcialmente os eventos relacionados à transferência dos dados pessoais.

4.23.3 Situação Encontrada

Para as 15 (quinze) prefeituras que responderam “sim” ou “parcialmente” à questão G1 (A organização identificou os dados pessoais que são compartilhados com terceiros?), foi realizado o seguinte questionamento na questão G12: A organização registra eventos relacionados à transferência dos dados pessoais que são compartilhados com terceiros e que foram identificados?

Dessas 15 (quinze) prefeituras, Arraial do Cabo e Mesquita responderam que registram os eventos relacionados à transferência dos dados pessoais que são

compartilhados com terceiros, 6 (seis) prefeituras responderam que registram parcialmente e as outras 7 (sete) prefeituras responderam que não registram.

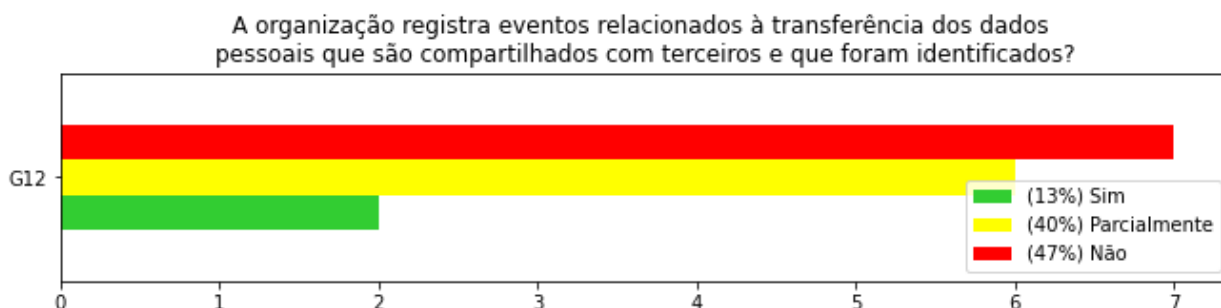


Figura 48: Respostas da questão G12

A LGPD impõe aos controladores e operadores de dados a necessidade de manter o registro das operações de tratamento de dados pessoais, conforme constatado no artigo 37 da referida Lei:

Art. 37. O controlador e o operador devem manter registro das operações de tratamento de dados pessoais que realizem, especialmente quando baseado no legítimo interesse.

A Norma Técnica ABNT NBR ISO/IEC 27701/19 em sua seção 7.5 – compartilhamento, transferência e divulgação de dados pessoais – norteia os agentes de tratamento a determinarem e documentarem quando o dado pessoal é compartilhado, transferido para outras jurisdições ou terceiros e/ou divulgado de acordo com as obrigações aplicáveis. O item 7.5.4 recomenda que a organização registre a divulgação de dados pessoais para terceiros, incluindo qual dado pessoal foi divulgado, para quem e quando. Assim, verifica-se necessário aos controladores e operadores de dados pessoais registrarem os eventos relacionados à transferência dos dados pessoais que foram identificados e que são compartilhados com terceiros.

Portanto, devido às razões supracitadas, as respostas negativas ou parciais à questão G12 serão alvo de **determinação** na proposta de encaminhamento deste relatório.

4.23.4 Causas

- Não investigadas

4.23.5 Efeitos

- Impossibilidade de rastreamento e identificação do evento que causou violação de privacidade ou vazamento de dados pessoais.
- Prejuízo no mapeamento da localização dos dados e dos agentes responsáveis pelo tratamento.

4.23.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.
 - **DETERMINAÇÃO:** registrar toda ocorrência de transferência de dados pessoais.
 - **RESPONDERAM PARCIALMENTE:** Bom Jesus do Itabapoana, Cantagalo, Comendador Levy Gasparian, Paty do Alferes, Saquarema e Valença.
 - **RESPONDERAM NEGATIVAMENTE:** Bom Jardim, Cabo Frio, Cardoso Moreira, Casimiro de Abreu, Pinheiral, São Gonçalo e Teresópolis.

4.24. Achado 24 - Ausência de plano de respostas a incidentes que envolvam violação de dados pessoais

4.24.1 Critérios

- Lei Federal nº 13.709/2018, art. 48 e art. 50, parágrafo 2º, inciso I, alínea “g”
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, item 6.13 e 6.13.1.1

4.24.2 Evidências

- Respostas negativas ao item H1 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 - LGPD [Anexo: 005 - Questionário - Respostas.pdf],

onde os respondentes afirmam que não há um Plano de Resposta a Incidentes (ou documento similar) no órgão, ou

- Documento anexado que não atende ao mínimo esperado para o Plano de Resposta a Incidentes [Anexo: 006 - Questionário - Respostas - Anexos.zip: \\Itaboraí\00082_04_decreto-municipal-15-2020.pdf]

4.24.3 Situação Encontrada

O Plano de Respostas a incidentes é um documento que apresenta um processo definido para garantir que os incidentes de segurança da informação sejam devidamente registrados, reportados e solucionados. O plano pode incluir tratativas acerca de análises pós-incidentes para identificar sua fonte e impedir sua reincidência.

A elaboração do Plano de Resposta a Incidentes (ou documento similar) é de suma importância e a LGPD em seu art. 50, parágrafo 2º, inciso I, alínea g, estabelece que esse plano é um dos requisitos mínimos estabelecidos para a implementação do programa de governança na organização.

Ademais, o plano de respostas a incidentes deve contemplar diretrizes para comunicar à ANPD os casos de eventos de segurança que possam acarretar riscos ou danos relevantes aos titulares conforme o art. 48 da LGPD.

A questão H1 buscava verificar se a organização possuía Plano de Resposta a Incidentes (ou documento similar) que abrangesse o tratamento de incidentes que envolvessem violação de dados pessoais. Para este item era obrigatório o envio de arquivo para comprovar a existência do documento.

Das 91 prefeituras que responderam ao questionário, apenas a Prefeitura Municipal de Itaboraí respondeu que possui o Plano de Resposta a Incidentes, enquanto as outras 90 prefeituras responderam que não possuem tal plano. Entretanto, após análise³⁴ pela Equipe de Auditoria do documento enviado pela Prefeitura de Itaboraí, foi verificado que aquela prefeitura não conseguiu comprovar a existência do documento contendo pelo menos um processo formal com passos a serem seguidos na ocorrência de um incidente de segurança da informação, desta forma essa documentação foi desconsiderada e convertida como negativa a resposta desse jurisdicionado ao item.

³⁴ Análise consta na seção relativa ao jurisdicionado no anexo: 013 - Resultado individualizado.pdf

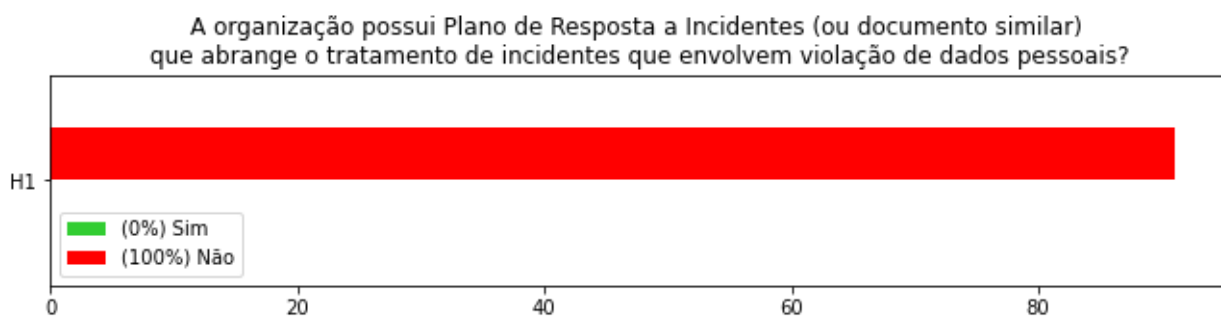


Figura 49: Respostas da questão H1

Cabe rememorar que as análises individuais de cada documento não aceito podem ser encontradas no anexo “013 - Resultado individualizado.pdf”, já a descrição do mínimo esperado para cada um dos documentos solicitados está disponível no anexo³⁵ de n.º 12 deste relatório.

Diante do exposto, o encaminhamento será com sugestão de **determinação** para que os órgãos criem um Plano de Respostas a Incidentes, de forma que seja possível que esta Corte de Contas verifique, em futuros monitoramentos, o cumprimento de suas determinações decorrentes dessa auditoria.

4.24.4 Causas

- Não investigadas

4.24.5 Efeitos

- Omissão em caso de ocorrência de incidente de violação de dados.
- Morosidade no tempo de resolução de incidentes envolvendo violação de dados pessoais.
- Não comunicação à ANPD em caso de violação de dados que gere riscos à privacidade dos dados de titulares.

4.24.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº

³⁵ Anexo: 012 - Requisitos mínimos de documentos solicitados.pdf

63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.

- **DETERMINAÇÃO:** elaborar Plano de Respostas a incidentes que envolva violação de dados pessoais e contendo, ao menos, um processo definido para garantir que os incidentes de segurança da informação sejam devidamente registrados, reportados e solucionados.
- **RESPONDERAM NEGATIVAMENTE:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra do Piraí, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Mesquita, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pinheiral, Piraí, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São João da Barra, São João de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastião do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Valença, Varre-sai, Vassouras e Volta Redonda.
- **RESPONDEU POSITIVAMENTE, MAS FOI CONSIDERADA NEGATIVA:** Itaboraí.

4.25. Achado 25 - Falta de procedimentos para comunicar à ANPD e ao titular dos dados pessoais incidentes envolvendo violação de dados pessoais

4.25.1 Critérios

- Lei Federal nº 13.709/2018, art. 48
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, item 6.13.1.5

4.25.2 Evidências

- Respostas negativas ao item H5 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 - LGPD [Anexo: 005 - Questionário - Respostas.pdf], onde os respondentes afirmam que não há procedimentos estabelecidos para comunicar à ANPD e ao titular a ocorrência de incidente de segurança que possa acarretar risco ou dano relevante aos titulares.

4.25.3 Situação Encontrada

O art. 48 da LGPD determina que em caso de ocorrência de incidente de segurança envolvendo dados pessoais que possa gerar risco ou dano relevante, os titulares dos dados e a Autoridade Nacional de Proteção de Dados devem ser comunicados. Para verificar a aderência dos órgãos a este dispositivo foi elaborada a questão H5.

A organização estabeleceu procedimentos para comunicar à Autoridade Nacional de Proteção de Dados e ao titular a ocorrência de incidente de segurança que possa acarretar risco ou dano relevante aos titulares?

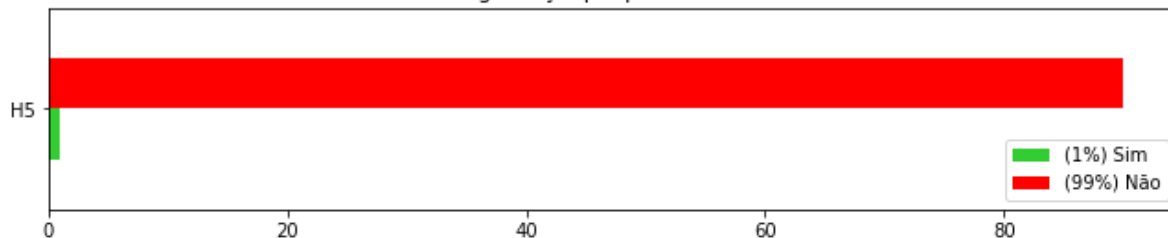


Figura 50: Respostas da questão H5

Apenas a Prefeitura Municipal de Paty do Alferes afirmou que estabeleceu procedimentos para comunicar à ANPD e ao titular a ocorrência de tais incidentes, as outras 90 prefeituras responderam que não estabeleceram tais procedimentos.

Ainda de acordo com o art. 48 da LGPD a comunicação precisa ser feita em prazo razoável, a ser definido pela ANDP, e deve possuir, no mínimo, as seguintes informações:

- I. a descrição da natureza dos dados pessoais afetados;
- II. as informações sobre os titulares envolvidos;
- III. a indicação das medidas técnicas e de segurança utilizadas para a proteção dos dados, observados os segredos comercial e industrial;
- IV. os riscos relacionados ao incidente;
- V. os motivos da demora, no caso de a comunicação não ter sido imediata; e
- VI. as medidas que foram ou que serão adotadas para reverter ou mitigar os efeitos do prejuízo.

Ante o exposto, fica evidente que as 90 prefeituras que ainda não estabeleceram procedimentos para comunicar incidentes de segurança aos titulares dos dados e à ANDP estão infringindo a LGPD. Não é aceitável que um controlador de dados pessoais não possua um processo estabelecido para esse tipo de situação, correndo o risco de não atender a este dispositivo tempestivamente. Assim sendo, as respostas negativas à questão H5 serão objeto de **determinação** na proposta de encaminhamento deste relatório.

4.25.4 Causas

- Não investigadas

4.25.5 Efeitos

- Prejuízo na ciência por parte dos titulares de dados e da ANPD das ações realizadas em caso de incidente de violação de dados.

4.25.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou

esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.

- **DETERMINAÇÃO:** definir procedimentos para comunicar à ANPD e ao titular dos dados pessoais incidentes envolvendo violação de dados pessoais, em conformidade aos requisitos elencados no art. 48 da LGPD.
- **RESPONDERAM NEGATIVAMENTE:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra do Pirai, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Mesquita, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pinheiral, Pirai, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São João da Barra, São João de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastião do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Valença, Varre-Sai, Vassouras e Volta Redonda.

4.26. Achado 26 - Ausência de processo formal para registro, cancelamento e provisionamento de usuários em todos os sistemas que realizam tratamento de dados pessoais

4.26.1 Critérios

- Lei Federal nº 13.709/2018, art. 46
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, item 6.9.4.1

4.26.2 Evidências

- Respostas ao item I2 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 - LGPD [Anexo: 005 - Questionário - Respostas.pdf], onde os respondentes afirmam que não há processo para registro, cancelamento e provisionamento de usuários em sistemas que realizam tratamento de dados pessoais ou que o processo não é executado em sua totalidade.

4.26.3 Situação Encontrada

A questão I2 buscava verificar se a organização implementou um processo para registro, cancelamento e provisionamento de usuários em sistemas que realizam tratamento de dados pessoais. Apenas as Prefeituras de Armação de Búzios, Pinheiral e Rio Bonito responderam que implementaram tal processo, 21 (vinte e uma) responderam que implementaram o processo parcialmente e 67 (sessenta e sete) responderam que não o implementaram.

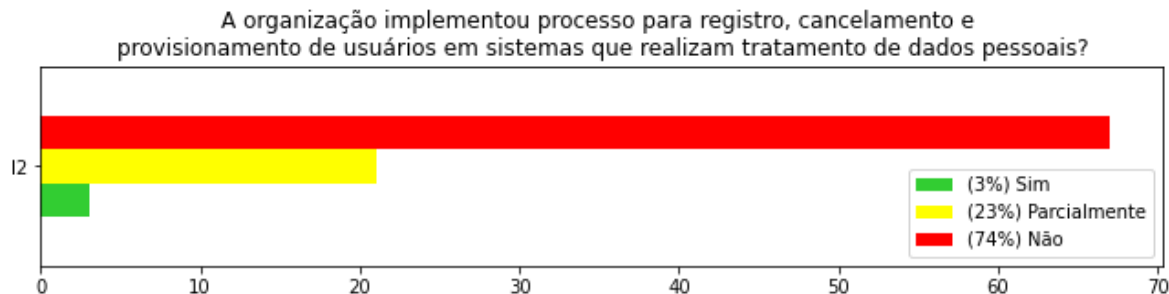


Figura 51: Respostas da questão I2

A implementação de um processo para registro, cancelamento e provisionamento de usuários em sistemas é de extrema importância, tal fato é corroborado pelo artigo 46 da LGPD:

Os agentes de tratamento devem adotar medidas de segurança, técnicas e administrativas aptas a proteger os dados pessoais de acessos não autorizados e de situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou qualquer forma de tratamento inadequado ou ilícito.

A Norma Técnica ABNT NBR ISO/IEC 27701/19 em seu item 6.9.4.1 – registros de eventos – recomenda o acesso a dados pessoais sejam registrados, para que seja

possível auditar quem acessou um dado pessoal, quando o acesso foi realizado e quais eventuais alterações foram feitas.

As prefeituras municipais que não possuem um processo definido para registro, cancelamento e provisionamento de usuários, ou ainda aquelas que implementaram este processo de forma parcial, estão expondo os dados pessoais ao risco de acessos não autorizados e infringindo frontalmente o art. 46 da LGPD.

Dessa forma, as respostas negativas ou parciais à questão 12 serão objeto de **determinação** na proposta de encaminhamento deste relatório.

4.26.4 Causas

- Não investigadas

4.26.5 Efeitos

- Realização de tratamento de dados pessoais por pessoas não autorizadas.
- Prejuízo na documentação e auditabilidade dos usuários dos sistemas que realizam o tratamento dos dados pessoais.

4.26.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.
 - **DETERMINAÇÃO:** implementar processo formal para registro, cancelamento e provisionamento de usuários em todos os sistemas que realizam tratamento de dados pessoais.
 - **RESPONDERAM PARCIALMENTE:** Arraial do Cabo, Barra do Piraí, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Campos dos Goytacazes, Cantagalo, Comendador Levy Gasparian, Cordeiro, Itaboraí,

Nilópolis, Paty do Alferes, Pirai, Porto Real, Resende, Rio das Ostras, São Gonçalo, São João de Meriti, Saquarema, Teresópolis e Valença.

- **RESPONDERAM NEGATIVAMENTE:** Angra dos Reis, Aperibé, Araruama, Areal, Barra Mansa, Belford Roxo, Bom Jardim, Cambuci, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Conceição de Macabu, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Mesquita, Miguel Pereira, Miracema, Natividade, Niterói, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Petrópolis, Porciúncula, Quatis, Queimados, Quissamã, Rio Claro, Rio das Flores, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São João da Barra, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastião do Alto, Sapucaia, Seropédica, Silva Jardim, Sumidouro, Tanguá, Trajano de Moraes, Três Rios, Varre-Sai, Vassouras e Volta Redonda.

4.27. Achado 27 - Falta de registro de eventos de atividades de tratamento de dados pessoais

4.27.1 Critérios

- Lei Federal nº 13.709/2018, arts. 37 e 46
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, item 6.9.4.1

4.27.2 Evidências

- Respostas ao item I3 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 - LGPD [Anexo: 005 - Questionário - Respostas.pdf], onde os respondentes afirmam que não registram ou registram parcialmente as atividades de tratamento de dados pessoais.

4.27.3 Situação Encontrada

A questão I3 buscava verificar se a organização registra os eventos das atividades de tratamento de dados pessoais. As Prefeituras de Arraial do Cabo, Armação de Búzios e Cantagalo responderam que registram tais eventos, 23 (vinte e três) prefeituras responderam que registram os eventos parcialmente e 65 prefeituras responderam que não registram os eventos das atividades de tratamento de dados pessoais.

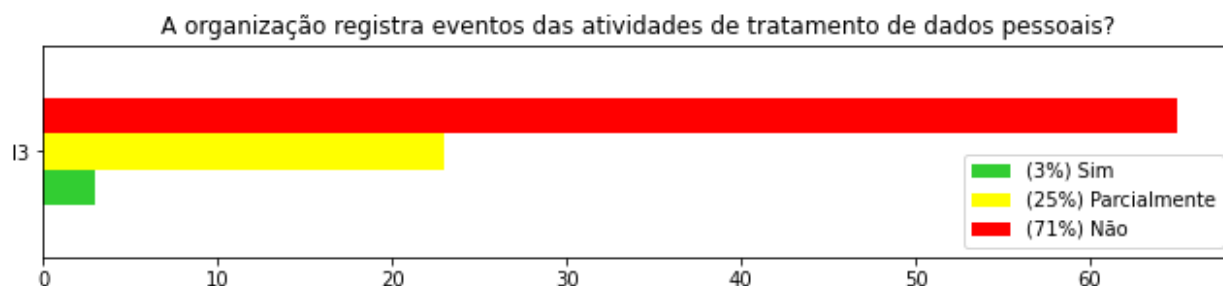


Figura 52: Respostas da questão I3

O registro dos eventos das atividades de tratamento de dados pessoais é de suma importância, tal fato é evidenciado pelo artigo 37 da LGPD que diz que:

O controlador e o operador devem manter registro das operações de tratamento de dados pessoais que realizarem, especialmente quando baseado no legítimo interesse.

Isso também é corroborado pelo artigo 46 da referida Lei que preconiza que:

Os agentes de tratamento devem adotar medidas de segurança, técnicas e administrativas aptas a proteger os dados pessoais de acessos não autorizados e de situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou qualquer forma de tratamento inadequado ou ilícito.

Pelos motivos supracitados, as respostas negativas ou parciais à questão I3 serão objeto de **determinação** na proposta de encaminhamento deste relatório.

4.27.4 Causas

- Não investigadas

4.27.5 Efeitos

- Prejuízo no monitoramento do tratamento dos dados pessoais, impossibilitando identificação de um incidente de violação de dados.

- Impossibilidade de rastreamento e identificação do evento que causou violação de privacidade ou vazamento de dados pessoais.

4.27.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.
 - **DETERMINAÇÃO:** registrar a ocorrência de todas as atividades de tratamento de dados pessoais, assegurando aos agentes de tratamento e ao titular de dados pessoais a auditabilidade necessária para verificar o estrito cumprimento da norma.
 - **RESPONDERAM PARCIALMENTE:** Angra dos Reis, Araruama, Barra do Piraí, Barra Mansa, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cordeiro, Itaboraí, Mesquita, Natividade, Nilópolis, Nova Friburgo, Paracambi, Paty do Alferes, Pinheiral, Piraí, Rio das Ostras, São Gonçalo, Saquarema, Tanguá, Trajano de Moraes e Valença.
 - **RESPONDERAM NEGATIVAMENTE:** Aperibé, Areal, Belford Roxo, Bom Jardim, Cambuci, Campos dos Goytacazes, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Miguel Pereira, Miracema, Niterói, Nova Iguaçu, Paraíba do Sul, Paraty, Petrópolis, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São João da Barra, São João de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastião do Alto, Sapucaia,

Seropédica, Silva Jardim, Sumidouro, Teresópolis, Três Rios, Varre-sai, Vassouras e Volta Redonda.

4.28. Achado 28 - Ausência de medidas para garantir que todas as soluções tecnológicas sejam projetadas em conformidade com a LGPD desde a concepção

4.28.1 Critérios

- Lei Federal nº 13.709/2018, art. 46, parágrafo 2º
- Norma Técnica ABNT NBR ISO/IEC 27.701/2019, item 7.4

4.28.2 Evidências

- Respostas negativas ao item I5 do Questionário que avalia a adequação dos municípios à Lei 13.709/2018 - LGPD [Anexo:005 - Questionário - Respostas.pdf], onde os respondentes confirmam que não adotam medidas para assegurar que processos e sistemas são projetados, desde a concepção, em conformidade com a LGPD.

4.28.3 Situação Encontrada

A questão I5 buscava verificar se a organização adotou medidas para assegurar que processos e sistemas sejam projetados desde a concepção, em conformidade com a LGPD (*Privacy by Design* e *Privacy by Default*). No total, 7 (sete) prefeituras responderam que adotaram as medidas e 84 (oitenta e quatro) prefeituras responderam que não adotaram tais medidas.

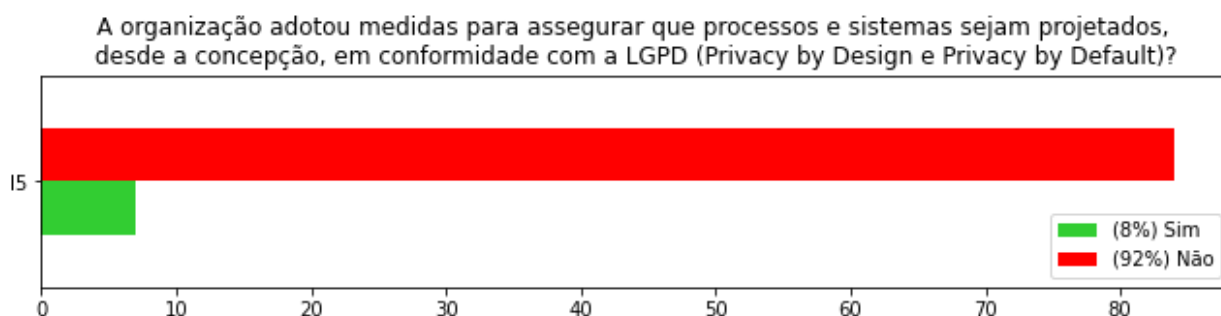


Figura 53: Respostas da questão I5

A legislação exige que sejam adotadas medidas para assegurar que processos e sistemas sejam projetados desde a concepção do produto ou serviço até a execução, tal fato pode ser observado no artigo 46, parágrafo 2º da LGPD:

Art. 46. Os agentes de tratamento devem adotar medidas de segurança, técnicas e administrativas aptas a proteger os dados pessoais de acessos não autorizados e de situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou qualquer forma de tratamento inadequado ou ilícito.

§ 2º. As medidas de que trata o caput deste artigo deverão ser observadas desde a fase de concepção do produto ou do serviço até a sua execução.

A Norma Técnica ABNT NBR ISO/IEC 27701/19 em seu item 7.4 – *Privacy by Design e Privacy by Default* – também ressalta que é necessário assegurar que os processos e sistemas sejam projetados de tal forma que a coleta e o tratamento (incluindo o uso, divulgação, retenção, transmissão e descarte) estejam alinhados ao que é necessário para o propósito identificado.

Dessa forma, as respostas negativas à questão I5 serão objeto de **determinação** na proposta de encaminhamento deste relatório.

4.28.4 Causas

- Não investigadas

4.28.5 Efeitos

- Adoção de solução tecnológica ineficiente ou insegura em relação ao tratamento de dados pessoais.
- Maiores custos para modificar sistemas que não foram projetados em conformidade com a LGPD.

4.28.6 Propostas de encaminhamento

- **COMUNICAÇÃO** às prefeituras dos municípios elencados abaixo, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram a **DETERMINAÇÃO** a seguir, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou

esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.

- **DETERMINAÇÃO:** elaborar medidas para garantir que todas as soluções tecnológicas sejam projetadas em conformidade com a LGPD desde a concepção, assegurando que os agentes de tratamento adotem medidas de segurança, técnicas e administrativas aptas a proteger os dados pessoais de acessos não autorizados e de situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou qualquer forma de tratamento inadequado ou ilícito.
- **RESPONDERAM NEGATIVAMENTE:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra do Piraí, Belford Roxo, Bom Jardim, Cabo Frio, Cachoeiras de Macacu, Cambuci, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Natividade, Macaé, Macuco, Mangaratiba, Maricá, Mendes, Miguel Pereira, Miracema, Nilópolis, Niterói, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pinheiral, Piraí, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São João da Barra, São João de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastião do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Valença, Varre-sai, Vassouras e Volta Redonda.

4.29. Síntese dos achados por dimensão

Dimensão	Situação encontrada
Preparação	• Apenas 4% das prefeituras concluíram a iniciativa para identificar e planejar medidas necessárias de adequação à lei e 46% das prefeituras adotaram alguma iniciativa para adequação à LGPD. • Apenas 3% das prefeituras elaboraram um plano de ação para atendimento integral à LGPD.
Contexto organizacional	• Das prefeituras que possuem operadores que realizam tratamento de dados pessoais em seu nome, somente 8% delas adequaram todos os seus contratos firmados com os operadores e 36% delas adequaram alguns contratos. Somente 32% dessas prefeituras realizaram a adequação dos instrumentos convocatórios para futuros contratos com operadores. • Apenas 8% das prefeituras avaliaram se há tratamento de dados que envolva controlador conjunto. Dessas que avaliaram, somente 14% definiram em contrato as responsabilidades e papéis entre elas e os controladores conjuntos. • Somente 4% das prefeituras identificaram todos os dados pessoais tratados por ela e 30% identificaram parcialmente.
Liderança	• Apenas 6% das prefeituras elaboraram uma Política de Segurança da Informação. • Nenhuma prefeitura elaborou uma Política de Classificação da Informação. • Somente 4% das prefeituras nomearam o encarregado de dados. Dessas que nomearam, 50% publicaram as informações do encarregado na internet.

Capacitação	Apenas 2% das prefeituras elaboraram um Plano de Capacitação que abrange treinamento e conscientização dos seus colaboradores em proteção de dados pessoais.
Conformidade do Tratamento	- Nenhuma prefeitura identificou completamente as finalidades das atividades de tratamento de dados pessoais e 14% identificaram parcialmente. Dessas que identificaram parcialmente, 38% avaliaram se coletam apenas os dados estritamente necessários, 15% avaliaram se os dados são retidos durante o tempo estritamente necessário e 15% publicaram na internet as informações sobre a previsão legal, a finalidade, os procedimentos e as práticas utilizadas para o tratamento de dados pessoais. - Nenhuma prefeitura identificou e documentou todas as bases legais relacionadas às atividades de tratamento de dados pessoais e 15% identificaram e documentaram parcialmente. - Nenhuma prefeitura instituiu um registro (inventário) para consolidar informações relacionadas às características das atividades de tratamento de dados pessoais. - Nenhuma prefeitura elaborou o Relatório de Impacto à Proteção de Dados Pessoais.
Direitos do Titular	- Apenas 3% das prefeituras possuem Política de Privacidade. - Somente 2% das prefeituras implementaram mecanismos para atender os direitos dos titulares elencados no Art. 18 da LGPD e 11% implementaram parcialmente.
Compartilhamento de Dados Pessoais	Apenas 3% das prefeituras identificaram os dados pessoais compartilhados com terceiros e

	13% identificaram parcialmente. Dessas prefeituras que identificaram os dados pessoais compartilhados, 13% estão com os dados pessoais em conformidade com os critérios estabelecidos na LGPD e 53% estão parcialmente em conformidade.
Violação de Dados Pessoais	• Apenas 1% das prefeituras possuem Plano de Resposta a Incidentes que abrange o tratamento de incidentes que envolvem violação de dados pessoais. • Somente 1% das prefeituras estabeleceram procedimentos para comunicar à ANPD e ao titular dos dados a ocorrência de incidente de segurança que possa acarretar risco ou dano relevante aos titulares.
Medidas de Proteção	• Apenas 3% das prefeituras implementaram um processo para registro, cancelamento e provisionamento de usuários em sistemas que realizam tratamento de dados pessoais e 23% implementaram parcialmente. • Somente 3% das prefeituras registram eventos das atividades de tratamento de dados pessoais e 25% registram parcialmente. • Apenas 8% das prefeituras adotaram medidas para assegurar que processos e sistemas sejam projetados desde a concepção, em conformidade com a LGPD (<i>Privacy by Design e Privacy by Default</i>).

5. CONSIDERAÇÕES FINAIS

Na última seção do questionário (Seção K - Conclusão) foi possível mensurar o sentimento dos gestores acerca do trabalho desenvolvido e avaliar a pertinência do tema de proteção de dados pessoais em seus órgãos.

No item K2 foi perguntado se o gestor considerava o questionário como um item de auxílio à adequação do órgão à LGPD. Destaca-se que 86 dos 91 jurisdicionados (94%) avaliaram o questionário como um instrumento capaz de contribuir para a adequação do órgão à lei, consideraram como não capaz apenas as Prefeituras de Duque de Caxias, Magé, Itaguaçu, Itaboraí e Macaé.

Nessa seção também foi adicionado um campo de texto livre (item K3), com o intuito de conceder aos gestores um espaço para registrarem suas considerações acerca da auditoria, incluindo críticas às questões, alertas para situações especiais não contempladas ou qualquer outra contribuição que considerassem válida.

Consta do retorno capturado vários apontamentos dos gestores tratando do reconhecimento da importância do tema e de que estão sendo tomadas providências para regularizar as suas adequações à norma, *in verbis*:

Trata-se de questionário muito efetivo, no sentido de coletar dados para auditoria, possibilitando o levantamento de informações e verificação de conformidade. Apesar do Município não ter avançado muito na implementação dos regramentos da LGPD, essa ferramenta de verificação poderá ser aproveitada para a adoção das medidas necessárias às adequações.

(Prefeitura Municipal de Cachoeiras de Macacu)

Ao respondermos este questionário constatamos que apesar de termos uma norma – Decreto Municipal 15/2020, que regulamenta no âmbito municipal as Leis 12527/2011 e 13709/2018, objeto desta auditoria, verificamos que este carece de mais elementos visando sua adequação diante de todas as informações solicitadas. Considerando que no âmbito da administração pública, a função controle administrativo cabe a todos os servidores, sejam eles do quadro permanente, cargos comissionados, contratados ou terceirizados, como sugestão, seria importante que a equipe de auditoria em seu relatório detalhasse bem as figuras descritas neste questionário. Diferenciando Controlador Conjunto de dado pessoal e Controlador de dado pessoal, do Controlador Geral do Município, ou seja, do responsável pelo Órgão Central de Controle Interno do ente jurisdicionado. Finalizando, parabenizamos a Corte de Contas pela iniciativa desta auditoria, cujo tema é de extrema relevância, aguardando o nosso diagnóstico.

(Prefeitura Municipal de Itaboraí)

O questionário é bastante amplo e sinalizou algumas questões importantes para serem trabalhadas futuramente junto ao encarregado de dados e a Comissão da LGPD do Município.

(Prefeitura Municipal de Rio Claro)

O presente questionário nos alertou para a adequação à LGPD e irá nos direcionar com a recepção normativa.

(Prefeitura Municipal de São José do Vale do Rio Preto)

Dessa forma, por meio desses itens apontados foi possível constatar o caráter indutor e orientador da auditoria corrente que, em conjunto com as determinações e recomendações comunicadas, ensejará a adequação dos jurisdicionados à LGPD.

6. PROPOSTA DE ENCAMINHAMENTO

Considerando o pleno atendimento ao objetivo proposto pela auditoria, qual seja, o de verificar a conformidade das prefeituras municipais à Lei Federal nº 13.709/2018 (LGPD);

Considerando o baixo grau de adequação à LGPD apresentado pelos municípios jurisdicionados desta Corte de Contas, exposto neste Relatório;

Considerando a matriz de achados anexa ao presente relatório (010 - Matriz de Achados.pdf);

Considerando que a LGPD entrou em vigor em agosto de 2020, no auge do enfrentamento à pandemia da COVID-19;

Considerando se tratar da primeira Auditoria Governamental para avaliar o grau de conformidade dos órgãos municipais à LGPD;

Considerando que o foco do presente trabalho é induzir os jurisdicionados a uma maior aderência à LGPD;

Considerando que a adequação à LGPD não se esgota nos controles abordados nessa auditoria, e que deve ser encarada como um processo de melhoria contínua, norteado por uma política de governança de dados centrada na proteção dados pessoais, bem como na observação assídua das orientações e guias disponibilizados pela Autoridade Nacional de Proteção de Dados - ANPD, sugere-se ao Egrégio Plenário desta Corte de Contas a adoção das seguintes propostas:

1. **COMUNICAÇÃO aos atuais prefeitos dos municípios elencados a seguir**, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que cumpram as **DETERMINAÇÕES** abaixo, alertando-os de que o não atendimento injustificado os sujeitam às sanções previstas no art. 63 da Lei Complementar Estadual nº 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.
 - 1.1. **DETERMINAÇÃO:** conduzir iniciativas para identificar e planejar as medidas necessárias para adequação à LGPD, sendo essas materializadas, ao menos, através do estabelecimento de um comitê ou grupo de trabalho que conte com o apoio ou participação direta da alta direção da organização (ACHADO 01).

1.1.1. **MUNICÍPIOS:** Angra dos Reis, Aperibé, Araruama, Armação de Búzios, Arraial do Cabo, Barra do Piraí, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Mesquita, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Piraí, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São João da Barra, São João de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastiao do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Varre-Sai, Vassouras e Volta Redonda.

1.2. **DETERMINAÇÃO:** elaborar plano de ação ou documento similar para direcionar a iniciativa de adequação à LGPD que elenque, ao menos, uma série de metas e objetivos, atividades que serão realizadas, seus prazos e os responsáveis por executá-las. (ACHADO 02).

1.2.1. **MUNICÍPIOS:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra do Piraí, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes,

Mesquita, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Piraí, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São Joao da Barra, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastião do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Valença, Varre-Sai, Vassouras e Volta Redonda.

1.3. **DETERMINAÇÃO:** incluir cláusulas estabelecendo responsabilidades e papéis com relação à proteção de dados pessoais nos próximos contratos firmados com os operadores, contendo, ao menos, as responsabilidades do operador de dados pessoais de forma clara e expressa. Bem como assegurar que os seus contratos com os operadores de dados pessoais contemplem a implementação de controles apropriados, levando em conta o processo de avaliação de riscos de segurança da informação e o escopo do tratamento de dados pessoais realizado pelo operador e também definir a obrigação de reparação por parte de controladores e operadores em caso de tratamento de dados pessoais que desencadeiem em danos de ordem moral, patrimonial, individual ou coletiva. Assim como avaliar a possibilidade de ajustes para inclusão de tais cláusulas nos contratos em vigor. (ACHADO 03).

1.3.1. **MUNICÍPIOS:** Barra do Piraí, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Campos dos Goytacazes, Cantagalo, Casimiro de Abreu, Comendador Levy Gasparian, Itaboraí, Mangaratiba, Maricá, Nova Friburgo, Nova Iguaçu, Pirai, Quissamã, Rio Claro, Santo Antônio de Pádua, São Gonçalo, São Joao de Meriti, São José do Vale do Rio Preto, Saquarema, Teresópolis e Valença.

1.4. **DETERMINAÇÃO:** adequar os instrumentos convocatórios que estão sendo elaborados e os futuros, estabelecendo responsabilidades e papéis com relação à proteção de dados pessoais, contendo, ao menos, as responsabilidades do operador de dados pessoais de forma clara e expressa.

Bem como assegurar que os instrumentos convocatórios contemplem a implementação de controles apropriados, levando em conta o processo de avaliação de riscos de segurança da informação e o escopo do tratamento de dados pessoais realizado pelo operador e também definir a obrigação de reparação por parte de controladores e operadores em caso de tratamento de dados pessoais que desencadeiem em danos de ordem moral, patrimonial, individual ou coletiva. (ACHADO 04).

1.4.1. **MUNICÍPIOS:** Barra do Piraí, Cabo Frio, Cantagalo, Casimiro de Abreu, Itaboraí, Mangaratiba, Maricá, Nova Friburgo, Nova Iguaçu, Piraí, Quissamã, Rio Claro, Santo Antônio de Pádua, São Gonçalo, São Joao de Meriti, São José do Vale do Rio Preto e Valença.

1.5. **DETERMINAÇÃO:** avaliar se há tratamento de dados que envolva controlador conjunto e caso exista, definir os papéis e responsabilidades de cada controlador conjunto identificado em contrato, acordo de cooperação ou instrumento similar. (ACHADO 05).

1.5.1. **MUNICÍPIOS:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra do Piraí, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Carapebus, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Mesquita, Miguel Pereira, Miracema, Natividade, Niterói, Nova Friburgo, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pinheiral, Piraí, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Joao da Barra, São João de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastião do Alto, Sapucaia,

Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Varre-Sai, Vassouras e Volta Redonda.

1.6. **DETERMINAÇÃO:** definir os papéis e responsabilidades de cada controlador conjunto identificado em contrato, acordo de cooperação ou instrumento similar. (ACHADO 06).

1.6.1. **MUNICÍPIOS:** Nilópolis, Nova Iguaçu, São Gonçalo, Saquarema e Valença.

1.7. **DETERMINAÇÃO:** identificar todos os dados pessoais tratados pela organização, efetuando um mapeamento completo e pormenorizado dos dados pessoais custodiados para verificar e armazenar as ocorrências de manipulação destes dados, além de mantê-los registrados por meio de inventário. (ACHADO 07).

1.7.1. **MUNICÍPIOS:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Barra do Pirai, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pinheiral, Pirai, Porciúncula, Porto Real, Quatis, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São Joao da Barra, São Joao de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastiao do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Valença, Varre-Sai, Vassouras e Volta Redonda.

1.8. **DETERMINAÇÃO:** elaborar a Política de Segurança da Informação contendo, ao menos, um subconjunto das seguintes características: orientação e apoio

da direção do órgão sobre a segurança da informação, alinhando-se de acordo com os requisitos de negócio e com as leis e regulamentações relevantes; declarações acerca dos objetivos e princípios a serem usados para orientar todas as atividades relativas à segurança da informação; atribuição de papéis e responsabilidades e um processo para tratamento dos desvios e exceções; tópicos específicos como controle de acesso aos sistemas, classificação e tratamento da informação, segurança física e lógica do ambiente, backup de dados e controles criptográficos. (ACHADO 08).

1.8.1. **MUNICÍPIOS:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra do Pirai, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Mesquita, Miracema, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pinheiral, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São Joao da Barra, São Joao de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastiao do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Valença, Varre-Sai e Vassouras.

1.9. **DETERMINAÇÃO:** elaborar a Política de Classificação da Informação incluindo diretrizes acerca de dados pessoais, dados pessoais sensíveis e dados pessoais de crianças e adolescentes, quando couber, contendo, ao menos, um conjunto de papéis, responsabilidades, critérios e rótulos para a classificação da informação do órgão. (ACHADO 09).

1.9.1. **MUNICÍPIOS:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra do Pirai, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Mesquita, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pinheiral, Pirai, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São Joao da Barra, São Joao de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastiao do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Valença, Varre-Sai, Vassouras e Volta Redonda.

1.10. **DETERMINAÇÃO:** nomear o encarregado de dados pessoais da organização, publicar a nomeação em veículo oficial e divulgar as informações de contato do encarregado em local de fácil acesso no sítio eletrônico da organização (ACHADO 10).

1.10.1. **MUNICÍPIOS:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra do Pirai, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Miguel Pereira,

Miracema, Natividade, Nilópolis, Niterói, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pirai, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São Joao da Barra, São Joao de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastiao do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Varre-Sai, Vassouras e Volta Redonda.

1.11. **DETERMINAÇÃO:** divulgar no sítio eletrônico da organização, em local de fácil acesso, a identidade e as informações de contato do encarregado de dados (ACHADO 11).

1.11.1.**MUNICÍPIOS:** Nova Friburgo e Pinheiral.

1.12. **DETERMINAÇÃO:** documentar e divulgar, no sítio eletrônico do órgão, preferencialmente, na mesma página de divulgação do contato do encarregado de dados, as finalidades de todas as atividades de tratamento de dados pessoais realizadas pelo órgão, bem como coletar e reter os dados estritamente necessários e pelo tempo necessário para cumprir com as finalidades (ACHADO 12).

1.12.1.**MUNICÍPIOS:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra do Pirai, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Mesquita, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pinheiral, Pirai, Porciúncula, Porto Real, Quatis, Queimados, Quissamã,

Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São Joao da Barra, São Joao de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastiao do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Valença, Varre-Sai, Vassouras e Volta Redonda.

1.13. **DETERMINAÇÃO:** verificar se coleta apenas os dados estritamente necessários para cumprir com as finalidades de tratamento de dados pessoais realizados pela organização (ACHADO 13).

1.13.1.**MUNICÍPIOS:** Barra do Pirai, Belford Roxo, Cabo Frio, Cantagalo, Mangaratiba, Nova Friburgo, Pirai e São Gonçalo.

1.14. **DETERMINAÇÃO:** avaliar se os dados pessoais são retidos, e caso seja, reter durante o tempo estritamente necessário para cumprir com as finalidades de tratamento de dados (ACHADO 14).

1.14.1.**MUNICÍPIOS:** Barra do Pirai, Belford Roxo, Bom Jesus do Itabapoana, Cabo Frio, Itaboraí, Mangaratiba, Nova Friburgo, Paty do Alferes, Pirai, São Gonçalo e Valença.

1.15. **DETERMINAÇÃO:** divulgar, no sítio eletrônico da organização, preferencialmente, na mesma página de divulgação do contato do encarregado de dados, a previsão legal, a finalidade, os procedimentos e práticas utilizadas para todas as atividades de tratamento de dados pessoais realizadas pela organização (ACHADO 15).

1.15.1.**MUNICÍPIOS:** Barra do Pirai, Belford Roxo, Bom Jesus do Itabapoana, Cabo Frio, Campos dos Goytacazes, Cantagalo, Itaboraí, Mangaratiba, Nova Friburgo, Paty do Alferes e Pirai.

1.16. **DETERMINAÇÃO:** identificar e documentar as bases legais que fundamentam todas as atividades de tratamento de dados pessoais (ACHADO 16).

1.16.1.**MUNICÍPIOS:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra do Pirai, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu,

Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Mesquita, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pinheiral, Pirai, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São Joao da Barra, São Joao de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastiao do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Valença, Varre-Sai, Vassouras e Volta Redonda.

1.17. **DETERMINAÇÃO:** elaborar um inventário ou lista de atividades de tratamento de dados pessoais contendo, ao menos, um subconjunto das seguintes características: registros necessários ao suporte às obrigações para o tratamento de dados pessoais; o tipo de tratamento; os propósitos para o tratamento; uma descrição das categorias de dados pessoais e dos titulares de dados pessoais (por exemplo, crianças); as categorias de destinatário para quem o dado pessoal tem sido ou será divulgado, incluindo os destinatários em outros países ou organizações internacionais; uma descrição geral das medidas de segurança técnica e organizacional e um relatório de avaliação de impacto de privacidade. (ACHADO 17).

1.17.1. **MUNICÍPIOS:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra do Pirai, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias,

Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Mesquita, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pinheiral, Pirai, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São Joao da Barra, São Joao de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastiao do Alto, Sapucaia, Squarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Valença, Varre-Sai, Vassouras e Volta Redonda.

- 1.18. **DETERMINAÇÃO:** elaborar Relatório de Impacto à Proteção de Dados Pessoais abrangendo todos os processos de tratamento de dados pessoais que podem gerar risco aos titulares e para implementar controles para mitigar todos os riscos identificados no Relatório de Impacto de Proteção de Dados Pessoais (ACHADO 18).

- 1.18.1. **MUNICÍPIOS:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra do Pirai, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Mesquita, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pinheiral, Pirai, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco

de Itabapoana, São Gonçalo, São Joao da Barra, São Joao de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastiao do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Valença, Varre-Sai, Vassouras e Volta Redonda.

1.19. **DETERMINAÇÃO:** elaborar Política de Privacidade que elenque, ao menos, informações acerca da finalidade e sobre como será feito o tratamento de dados pessoais, e divulgar em local de fácil acesso no sítio eletrônico da organização. (ACHADO 19).

1.19.1. **MUNICÍPIOS:** Angra dos Reis, Aperibé, Araruama, Areal, Arraial do Cabo, Barra do Pirai, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pinheiral, Pirai, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Joao da Barra, São Joao de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastiao do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Valença, Varre-Sai, Vassouras e Volta Redonda.

1.20. **DETERMINAÇÃO:** implementar mecanismos para atender todos os direitos dos titulares elencados nos artigos 17-22 da LGPD e aplicáveis à organização (ACHADO 20).

1.20.1.**MUNICÍPIOS:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra do Pirai, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pinheiral, Pirai, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São Joao da Barra, São Joao de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastiao do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Varre-Sai, Vassouras e Volta Redonda.

1.21. **DETERMINAÇÃO:** identificar todos os dados pessoais que são compartilhados com terceiros e adequar todos os compartilhamentos aos critérios estabelecidos na LGPD, bem como registrar toda ocorrência de transferência de dados pessoais (ACHADO 21).

1.21.1.**MUNICÍPIOS:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Barra do Pirai, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cantagalo, Carapebus, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Duas Barras, Duque de Caxias, Guapimirim, Itaboraí, Itaguaí, Itaocara, Macuco, Mangaratiba, Maricá, Mendes, Miguel Pereira, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pinheiral, Pirai, Quatis, Resende, Rio Claro, Santa Maria Madalena, São

Fidélis, São Gonçalo, São Joao de Meriti, São José do Vale do Rio Preto, São Pedro da Aldeia, Sapucaia, Saquarema, Seropédica, Sumidouro, Tanguá, Teresópolis, Três Rios, Valença, Vassouras e Volta Redonda.

1.22. **DETERMINAÇÃO:** adequar todos os compartilhamentos de dados pessoais aos critérios estabelecidos na LGPD, isto é, atendendo a finalidades de execução de políticas públicas e atribuição legal, respeitados os princípios de proteção de dados pessoais. (ACHADO 22).

1.22.1.**MUNICÍPIOS:** Arraial do Cabo, Bom Jardim, Cabo Frio, Cantagalo, Cardoso Moreira, Casimiro de Abreu, Comendador Levy Gasparian, Paty do Alferes, Pinheiral, São Gonçalo, Saquarema, Teresópolis e Valença.

1.23. **DETERMINAÇÃO:** registrar toda ocorrência de transferência de dados pessoais (ACHADO 23).

1.23.1.**MUNICÍPIOS:** Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cantagalo, Cardoso Moreira, Casimiro de Abreu, Comendador Levy Gasparian, Paty do Alferes, Pinheiral, São Gonçalo, Saquarema, Teresópolis e Valença.

1.24. **DETERMINAÇÃO:** elaborar Plano de Respostas a incidentes que envolva violação de dados pessoais e contendo, ao menos, um processo definido para garantir que os incidentes de segurança da informação sejam devidamente registrados, reportados e solucionados (ACHADO 24).

1.24.1.**MUNICÍPIOS:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra do Pirai, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Mesquita, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova

Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pinheiral, Pirai, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São Joao da Barra, São Joao de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastiao do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Valença, Varre-Sai, Vassouras e Volta Redonda.

- 1.25. **DETERMINAÇÃO:** definir procedimentos para comunicar à ANPD e ao titular dos dados pessoais incidentes envolvendo violação de dados pessoais, em conformidade aos requisitos elencados no art. 48 da LGPD (ACHADO 25).

1.25.1. **MUNICÍPIOS:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra do Pirai, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Mesquita, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Petrópolis, Pinheiral, Pirai, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São Joao da Barra, São Joao de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastiao do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Valença, Varre-Sai, Vassouras e Volta Redonda.

1.26. **DETERMINAÇÃO:** implementar processo formal para registro, cancelamento e provisionamento de usuários em todos os sistemas que realizam tratamento de dados pessoais (ACHADO 26).

1.26.1.**MUNICÍPIOS:** Angra dos Reis, Aperibé, Araruama, Areal, Arraial do Cabo, Barra do Pirai, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Mesquita, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pirai, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São Joao da Barra, São Joao de Meriti, São Jose de Ubá, São Jose do Vale do Rio Preto, São Pedro da Aldeia, São Sebastiao do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Valença, Varre-Sai, Vassouras e Volta Redonda.

1.27. **DETERMINAÇÃO:** registrar a ocorrência de todas as atividades de tratamento de dados pessoais, assegurando aos agentes de tratamento e ao titular de dados pessoais a auditabilidade necessária para verificar o estrito cumprimento da norma (ACHADO 27).

1.27.1.**MUNICÍPIOS:** Angra dos Reis, Aperibé, Araruama, Areal, Arraial do Cabo, Barra do Pirai, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo

de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Mesquita, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pirai, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São Joao da Barra, São Joao de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastiao do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Valença, Varre-Sai, Vassouras e Volta Redonda.

- 1.28. **DETERMINAÇÃO:** elaborar medidas para garantir que todas as soluções tecnológicas sejam projetadas em conformidade com a LGPD desde a concepção, assegurando que os agentes de tratamento adotem medidas de segurança, técnicas e administrativas aptas a proteger os dados pessoais de acessos não autorizados e de situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou qualquer forma de tratamento inadequado ou ilícito (ACHADO 28).

- 1.28.1. **MUNICÍPIOS:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra do Pirai, Belford Roxo, Bom Jardim, Cabo Frio, Cachoeiras de Macacu, Cambuci, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Mangaratiba, Maricá, Mendes, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pinheiral, Pirai, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco

de Itabapoana, São Gonçalo, São Joao da Barra, São Joao de Meriti, São José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastiao do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Valença, Varre-Sai, Vassouras e Volta Redonda.

2. **COMUNICAÇÃO aos atuais prefeitos dos municípios elencados a seguir**, nos termos do artigo 26, §1º, do Regimento Interno deste Tribunal, para que adotem as **RECOMENDAÇÕES** a seguir, baseadas na Norma Técnica ABNT NBR ISO/IEC 27.701/2019, no que for cabível, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.

2.1. **RECOMENDAÇÕES**

- 2.1.1. Identificar outros normativos (instruções normativas, regulamentos, portarias, decretos e leis), além da LGPD, que abordam o tema da proteção de dados (ACHADO 01).
- 2.1.2. Identificar todas as categorias de titulares de dados pessoais com os quais se relaciona (ACHADOS 07 e 17).
- 2.1.3. Identificar todos operadores que realizam tratamento de dados pessoais em seu nome (ACHADOS 03 e 17).
- 2.1.4. Identificar todos os processos de negócio que realizam tratamento de dados pessoais (ACHADO 17).
- 2.1.5. Identificar todos os responsáveis por processos de negócio que realizam tratamento de dados pessoais (ACHADO 17).
- 2.1.6. Identificar todos os locais onde são armazenados dados pessoais no órgão (ACHADO 17).
- 2.1.7. Avaliar os riscos de todos processos de tratamento de dados pessoais realizados no órgão (ACHADO 07).
- 2.1.8. Elaborar Política de Proteção de Dados Pessoais do órgão que estabeleça, ao menos, diretrizes e procedimentos para o tratamento dos dados pessoais no órgão e demonstre seu apoio e comprometimento com os normativos de proteção de dados pessoais (ACHADO 19).

- 2.1.9. Elaborar Plano de Capacitação do órgão, abrangendo treinamento e conscientização dos seus colaboradores em proteção de dados pessoais, abrangendo treinamento diferenciado para profissionais que exercem funções com responsabilidades essenciais relacionadas à proteção de dados pessoais.
- 2.1.10. Providenciar treinamento diferenciado para profissionais que exercem funções com responsabilidades essenciais relacionadas à proteção de dados pessoais
- 2.1.11. Providenciar treinamento específico para todos os colaboradores do órgão que estão diretamente envolvidos em atividades que realizam tratamento de dados pessoais
- 2.1.12. Registrar toda ocorrência de incidente que envolva violação de dados pessoais (ACHADOS 24 e 25).
- 2.1.13. Registrar todas as ações adotadas diante de ocorrência de incidente que envolva violação de dados pessoais (ACHADOS 24 e 25).
- 2.1.14. Monitorar proativamente a ocorrência de violação de dados pessoais (ACHADOS 24 e 25).
- 2.1.15. Utilizar criptografia para proteger os dados pessoais (ACHADO 28).
- 2.2. **MUNICÍPIOS:** Angra dos Reis, Aperibé, Araruama, Areal, Armação de Búzios, Arraial do Cabo, Barra do Pirai, Barra Mansa, Belford Roxo, Bom Jardim, Bom Jesus do Itabapoana, Cabo Frio, Cachoeiras de Macacu, Cambuci, Campos dos Goytacazes, Cantagalo, Carapebus, Cardoso Moreira, Carmo, Casimiro de Abreu, Comendador Levy Gasparian, Conceição de Macabu, Cordeiro, Duas Barras, Duque de Caxias, Engenheiro Paulo de Frontin, Guapimirim, Iguaba Grande, Itaboraí, Itaguaí, Italva, Itaocara, Itaperuna, Itatiaia, Japeri, Laje do Muriaé, Macaé, Macuco, Magé, Mangaratiba, Maricá, Mendes, Mesquita, Miguel Pereira, Miracema, Natividade, Nilópolis, Niterói, Nova Friburgo, Nova Iguaçu, Paracambi, Paraíba do Sul, Paraty, Paty do Alferes, Petrópolis, Pinheiral, Pirai, Porciúncula, Porto Real, Quatis, Queimados, Quissamã, Resende, Rio Bonito, Rio Claro, Rio das Flores, Rio das Ostras, Santa Maria Madalena, Santo Antônio de Pádua, São Fidélis, São Francisco de Itabapoana, São Gonçalo, São João da Barra, São João de Meriti, São

José de Ubá, São José do Vale do Rio Preto, São Pedro da Aldeia, São Sebastião do Alto, Sapucaia, Saquarema, Seropédica, Silva Jardim, Sumidouro, Tanguá, Teresópolis, Trajano de Moraes, Três Rios, Valença, Varre-Sai, Vassouras e Volta Redonda.

3. **EXPEDIÇÃO DE OFÍCIO às Unidades de Controle Interno das 91 Prefeituras Municipais jurisdicionados desta Corte de Contas**, para que tomem ciência do inteiro teor do presente Relatório de Auditoria Governamental.
4. **ARQUIVAMENTO** do presente processo.

CAS-TI, 29/07/2022

AUGUSTO CÉSAR BENVENUTO DE ALMEIDA
Analista de Controle Externo
Matrícula 02/004823

GABRIEL DE LEMOS SILVA
Analista de Controle Externo
Matrícula 02/004821

Senhor Coordenador

O presente relatório foi objeto de supervisão conforme as disposições da Portaria SGE nº 05/2019 e material armazenado nos assentamentos internos desta Coordenadoria, estando, portanto, APROVADO por esta supervisão e encaminhado à sua apreciação para adoção das medidas cabíveis.

CAS-TI, 29/07/2022

BRUNO MATTOS SOUZA DE SOUZA MELO
Supervisor
Matrícula 02/004258

Senhor Coordenador-Geral da CAD-GOVERNANÇA,

Manifesto-me de acordo com a equipe técnica desta Coordenadoria.
À consideração de V.Sa.

CAS-TI, 29/07/2022

BRUNO MATTOS SOUZA DE SOUZA MELO
Substituto Eventual do Coordenador
Matrícula 02/004258

Senhor Subsecretário-Adjunto da SUB-CIDADANIA,

Após revisão, nos termos do Manual de Auditoria Governamental do TCE-RJ,
aprovado pela Resolução nº 373, de 16.06.21, manifesto-me DE ACORDO.

CAD-GOVERNANÇA, 29/07/2022

RAFAEL GOULART CERRONE
Coordenador-Geral
Matrícula 02/004300


DE ACORDO.


Ao GAP/NDP, em prosseguimento.

Assinado Digitalmente por: TONEYPSON DA SILVA
ABREU
Data: 2022.08.02 11:02:03 -03:00
Razão: Processo 206972-5/2022
Local: TCERJ

Assinado Digitalmente por: RAFAEL GOULART
CERRONE
Data: 2022.07.29 14:37:41 -03:00
Razão: Processo 206972-5/2022
Local: TCERJ



Assinado Digitalmente por: FLAVIO AUGUSTO DE
OLIVEIRA CORREIA
Data: 2022.07.29 16:30:54 -03:00
Razão: Revisor do Processo 206972-5/2022
Local: TCERJ




TONEYPSON DA SILVA ABREU
Substituto Eventual do Subsecretário-Adjunto
Matrícula 02/003675

Assinado Digitalmente por: GABRIEL DE LEMOS
SILVA
Data: 2022.07.29 14:45:05 -03:00
Razão: Processo 206972-5/2022
Local: TCERJ





Assinado Digitalmente por: AUGUSTO CESAR
BENVENUTO DE ALMEIDA
Data: 2022.07.29 14:38:45 -03:00
Razão: Processo 206972-5/2022
Local: TCERJ